



Auditoria Interna ISO 27701

ALWAYS ON DIGITAL LTDA. / 10/03/2025
até 21/03/2025 / Mariana Sbaite
Gonçalves

Concluído

Resul tado	0 / 0 (0%)	Elementos sinalizados	0	Ações	0
-----------------------	------------	----------------------------------	---	--------------	---

AUDITORIA Interna ISO/IEC 27701:2019

Cliente	ALWAYS ON DIGITAL LTDA.
Período	10/03/2025 até 21/03/2025
Auditor Líder:	Mariana Sbaite Gonçalves
Local	R. Fidêncio Ramos, 101 Vila Olímpia, São Paulo - SP

Participantes

Wesley Ruiz - Diretor (TI, Infra)
Thaiz Souza - Diretora (RH, Financeiro)
Talitha Almeida - Analista de RH
Elcio Santos - Diretor (Marketing e Comercial)
Alexandre da Rocha - Gerente de SI

RESUMO DA AUDITORIA

Não Conformidades (NC)

32 NC Menores e 07 NCs Maiores

22 NCs Menores e 06 NCs Maiores, também registrados no relatório da ISO 27001/2022. Ainda, 10 NCs Menores e 01 NC maior, referentes aos Anexos A e B da ISO 27701/2019.

NC Maior 01: Os Objetivos de SI não foram elencados na PSI, configurando, dessa forma, uma NC Maior com relação ao requisito 6.2.

NC Maior 02: A situação descrita caracteriza uma não conformidade maior, pois o requisito é obrigatório, e a organização não está garantindo a plena implementação desse requisito. A ausência de um cronograma formalizado de treinamentos e a falta de treinamentos sobre privacidade indicam que a organização não está assegurando que seus colaboradores estejam devidamente conscientizados, podendo comprometer a eficácia do SGSIP. Também, o colaborador Henrique de Oliveira não recebeu os treinamentos obrigatórios relacionados ao seu cargo. Ademais, a indisponibilidade da PSI em um local de fácil acesso reforça a gravidade da não conformidade. Se os colaboradores não conseguem acessar esse documento essencial, há um risco significativo de descumprimento dos controles de segurança, impactando a governança do SGSIP. Como resultado, essa falha representa um desvio sistêmico, o que justifica sua classificação como não conformidade maior. Para corrigir essa situação, a organização deve implementar um plano de ação corretiva que inclua a formalização de treinamentos contínuos, a inclusão da privacidade nos programas de conscientização e a garantia de que as políticas estejam acessíveis a todos os colaboradores.

NC Maior 03: Os documentos do SGSI vieram em Word e sem aprovação formal, contrariando os requisitos 7.5.2 c) e 7.5.3 b) da ISO 27001/2022.

NC Maior 04: Não foram evidenciadas ações para controle e correções de não conformidades, nem análises críticas das não conformidades e da eficácia de ações corretivas, contrariando o que estabelece o requisito 10.2.

NC Maior 05: Foram constatadas falhas críticas no processo de gestão de fornecedores da ALWAYS ON como ter um procedimento desatualizado, a falta de evidências com relação as avaliações de fornecedores; não listar seus fornecedores críticos; a ausência de instrumento contratual com o fornecedor Simionato; a falta de monitoramento e análise crítica dos fornecedores, não cumprindo, dessa forma, o que estabelecem os controles 5.19, 5.20, 5.21 e 5.22 do Anexo A da ISO 27001/2022.

NC Maior 06: Foram constatadas falhas críticas no processo de gestão de incidentes, contrariando assim os controles 5.24, 5.25, 5.26, 5.27 e 5.28 do ANEXO A da ISO 27001:2022. Evidências Objetivas: 1. Falta de critérios claros para priorização dos atendimentos, análises e respostas dos incidentes; 2. Falta de evidências objetivas sobre a realização de registros de eventos e análises de incidentes; 3. Falta de diretrizes estabelecidas para coleta, preservação e cadeia de custódia de eventuais evidências dos incidentes; 4. Não há nenhum documento que fale sobre o tema Lições Aprendidas, tampouco há relatórios ou comunicações sobre o tema.

NC Menor 01: Foi constatado, em entrevista, que a ALWAYS ON não considerou as mudanças climáticas quando da elaboração do contexto, contrariando assim o requisito 4.1 da ISO 27001:2022. Assim sendo, fica configurada a NC Menor com relação aos requisitos 4.1 e 4.2.

NC Menor 02: Os Objetivos de SI não foram detalhados, nem o comprometimento com a melhoria contínua. Logo, fica configurada uma NC Menor com relação ao requisito 5.2.

NC Menor 03: O controle exige que papéis e responsabilidades relacionados à segurança da informação e Privacidade sejam definidos e alocados de acordo com as necessidades da organização. Se a política de segurança não aborda as responsabilidades, pode haver lacunas na definição das responsabilidades de atores importantes, como gestores de sistemas, colaboradores ou fornecedores, comprometendo a eficácia na aplicação da segurança da informação. Em complemento, a ISO 27001/2022 requer que essas responsabilidades sejam comunicadas de forma clara. A ausência de designação abrangente de responsabilidades e autoridades pode levar a falhas operacionais, pois as partes envolvidas podem não saber o que se espera delas.

NC Menor 04: Na Declaração de Aplicabilidade apresentada, a organização considerou, de forma inadequada, a não aplicabilidade de alguns controles referentes aos ANEXOS A e B da ISO 27701:2019, contrariando os requisitos 6.1.3 b) e d) da ISO-IEC 27001:2022.

NC Menor 05: Não foi elaborado um plano de tratamento de riscos, conforme abordado na norma.

NC Menor 06: Apesar da existência de um documento com competências pré-definidas, um cronograma de treinamentos obrigatórios e um formulário de avaliação, a auditoria constatou que o colaborador Henrique Barros de Oliveira, analista programador de back-end, não recebeu os treinamentos obrigatórios exigidos para seu cargo, demonstrando uma falha na implementação do processo de capacitação, comprometendo a eficácia das medidas de segurança da informação. O armazenamento dos documentos no Google Drive e a utilização do portal Greg pelo RH não garantem, por si só, que as competências necessárias foram efetivamente adquiridas e aplicadas. Ainda, a ausência de nomeação

formal de um Encarregado pelo Tratamento de Dados Pessoais (DPO) configura uma não conformidade, especialmente considerando a importância desse papel na conformidade com normas de proteção de dados, como a LGPD e a ISO 27701. A falta de um responsável formalmente designado para gerenciar a proteção de dados pessoais pode levar a lacunas na governança da segurança da informação e no cumprimento das obrigações legais e normativas.

NC Menor 07: A ausência de análises críticas para lidar com mudanças não intencionais nos processos e sistemas, pode gerar desvios nos controles implementados e vulnerabilidades não detectadas. Embora a empresa demonstre esforços no planejamento e controle por meio de políticas, procedimentos e ferramentas como a planilha de análise de riscos, a falta de um processo formal para identificar e avaliar mudanças imprevistas compromete a capacidade da organização de manter a eficácia dos controles de segurança. Essa lacuna pode resultar em impactos negativos na confidencialidade, integridade e disponibilidade das informações, especialmente em situações de mudanças inesperadas nos processos organizacionais ou no ambiente tecnológico.

NC Menor 08: Em que pese a organização utilizar ferramentas de monitoramento, ela não definiu um planejamento de monitoramento, medição e análise conforme estabelece o Requisito: 9.1 Monitoramento, medição e análise: A organização deve determinar: a) o que precisa ser monitorado e medido, incluindo processos e controles da segurança da informação; b) os métodos para monitoramento, medição, análise e avaliação, conforme aplicável, para assegurar resultados válidos. Convém que os métodos selecionados produzam resultados comparáveis e reproduzíveis para serem considerados válidos; c) quando o monitoramento e a medição devem ser realizados; d) quem deve monitorar e medir; e) quando os resultados do monitoramento e da medição devem ser analisados e avaliados; f) quem deve analisar e avaliar estes resultados. Informação documentada deve ser disponibilizada como evidência dos resultados. A organização deve avaliar o desempenho da segurança da informação e a eficácia do sistema de gestão da segurança da informação.

NC Menor 09: A Política de Segurança da Informação (PSI) não descreve os objetivos de segurança da informação, o que contraria a cláusula 5.2, que exige que a política seja coerente com os objetivos organizacionais e de SI. O envio em word e a falta de assinatura pela Alta Direção é um problema grave, pois a norma exige que a Alta Direção demonstre liderança e compromisso com a segurança da informação.

NC Menor 10: O controle exige que papéis e responsabilidades relacionados à segurança da informação sejam definidos e alocados de acordo com as necessidades da organização. Se a política de segurança não aborda as responsabilidades, pode haver lacunas na definição das responsabilidades de atores importantes, como gestores de sistemas, colaboradores ou fornecedores, comprometendo a eficácia na aplicação da segurança da informação. Em complemento, a ISO 27001/2022 requer que essas responsabilidades sejam comunicadas de forma clara. A ausência de designação abrangente de responsabilidades e autoridades pode levar a falhas operacionais, pois as partes envolvidas podem não saber o que se espera delas.

NC Menor 11: Em entrevista foi informado que, atualmente, a organização não faz segregação de funções, contrariando o que estabelece o controle 5.3 da norma.

NC Menor 12: A organização demonstra um esforço inicial ao manter uma lista de contatos com autoridades no procedimento de preparação e resposta a emergências, o que está alinhado ao requisito de manter comunicação com autoridades relevantes. No entanto, a ausência do cadastro na ANPD indica falha crítica de conformidade com a LGPD, especialmente no que diz respeito à pronta comunicação de incidentes envolvendo dados pessoais. Essa lacuna não apenas compromete o cumprimento do controle 5.5, mas também expõe a organização a sanções legais e riscos reputacionais.

NC Menor 13: Foi verificado, em entrevista, que não há suspensão de acessos quando os colaboradores estão de férias. Ainda, não são realizadas análises críticas com relação aos acessos.

NC Menor 14: Durante a auditoria, foi verificado que a política de privacidade que consta no site da empresa está desatualizada e não tem informações importantes sobre direitos dos titulares nem sobre o Encarregado pelo Tratamento de Dados Pessoais (não há um Encarregado nomeado formalmente), não há inventário de dados pessoais (ROPA), não há definições de bases legais (é utilizada, por exemplo, a base de consentimento na área de marketing, mas a gestão dos consentimentos não é realizada) com relação aos tratamentos de dados pessoais nem a elaboração de relatórios de impacto à proteção de dados pessoais, documentos essenciais para avaliar os riscos e adotar medidas preventivas adequadas. Em complemento, foi verificado que a organização não tem um procedimento nem fluxo para atendimento aos titulares de dados pessoais, contrariando o que estabelece a norma e a LGPD. É imprescindível que a organização invista em cursos e especializações sobre privacidade e proteção de dados pessoais, bem como considere a contratação de uma consultoria especializada em privacidade e proteção de dados pessoais, a fim de atingir conhecimento e maturidade no tema.

NC Menor 15: Foi constatado que, até a data da realização desta auditoria interna, não foram realizadas análises críticas independentes.

NC Menor 16: Foi verificado que algumas políticas e procedimento estabelecem regras que não são cumpridas na prática. Evidências objetivas: O Procedimento de Gerenciamento de Incidentes descreve um fluxo que não ocorre na prática. A Política de Privacidade que consta no site (<https://aodigital.com.br/o-que-e-politica-de-privacidade/>) da empresa está desatualizada e não menciona os direitos dos titulares nem um canal para atendimentos dos seus direitos. A empresa não nomeou formalmente um Encarregado pelo Tratamento de Dados Pessoais. O Procedimento de Aquisição descreve um fluxo que não ocorre na prática.

NC Menor 17: Foi apresentada a verificação de antecedentes do colaborador Rafael Chagas Palermo,

Analista CRM Pleno (tem acesso ao banco de dados do cliente, como dados de comportamentos de compra, por exemplo), alocado na Renner. Ocorre que, não foi verificada justificativa, eis que tal função lida com dados para marketing. Ainda, o Procedimento de Recursos Humanos não menciona a possibilidade de verificação de antecedentes na empresa.

NC Menor 18: Foi solicitado, em entrevista, o contrato de trabalho do colaborador Henrique de Oliveira, todavia, foi constatado que existe apenas o instrumento contratual de experiência. Após o colaborador passar na experiência, não foi elaborado um novo instrumento contratual. Não foram verificadas cláusulas de SI, de privacidade, de compliance nem de propriedade intelectual. A falta de atualização do contrato para refletir essas novas responsabilidades configura uma não conformidade com esse controle. Ainda, a não formalização da alteração no contrato de trabalho pode gerar risco de passivo trabalhista, e não conformidade com a LGPD e a ISO 27001/2022.

NC Menor 19: Foi evidenciado que a organização ainda não possui diretrizes estabelecidas, nem processos definidos e implementados para a realização de processos disciplinares, quando necessário.

NC Menor 20: A situação apresentada configura uma não conformidade, pois não há uma padronização interna para o desenvolvimento seguro de software na ALWAYS ON. O fato de os desenvolvedores seguirem apenas as metodologias de cada cliente, sem uma abordagem própria e consolidada da empresa, indica a falta de um processo estruturado de segurança no desenvolvimento. Em complemento, a ausência de avaliações de riscos de segurança da informação e privacidade antes dos projetos compromete a identificação e mitigação de vulnerabilidades desde as fases iniciais. A norma exige que regras de desenvolvimento seguro sejam estabelecidas e aplicadas, o que não ocorre na prática, já que o Procedimento de Desenvolvimento de Software não está sendo seguido conforme descrito. Outro fator preocupante é a deficiência nos treinamentos dos desenvolvedores. Embora tenham recebido um treinamento básico de segurança da informação, não houve capacitação sobre privacidade, o que pode levar ao desenvolvimento de aplicações não aderentes à normas e regulamentações de privacidade e proteção de dados pessoais.

NC Menor 21: Foi constatada a ausência de avaliação de riscos de segurança da informação e privacidade antes do início dos projetos, o que compromete a proteção de dados e a conformidade com normas vigentes e aplicáveis. Também, os desenvolvedores não receberam treinamento adequado em privacidade, o que pode resultar em falhas na implementação de medidas de segurança no ciclo de desenvolvimento de software. Outro ponto crítico é que, apesar de o procedimento prever que o Encarregado pelo Tratamento de Dados Pessoais deve ser informado caso novos dados pessoais sejam identificados ou sua finalidade alterada, essa etapa não ocorre na prática, representando uma falha no controle e rastreamento do tratamento de dados, podendo resultar em riscos de incidentes de segurança e violações de dados pessoais.

NC Menor 22: A ausência de pentests após 2023 indica que a organização não está realizando verificações regulares da segurança dos seus sistemas, o que pode levar à manutenção de vulnerabilidades desconhecidas. A norma exige que informações de teste sejam gerenciadas e protegidas, o que inclui a realização periódica de testes para identificar falhas e corrigir possíveis riscos. Sem essa prática contínua, há um risco significativo de exposição a ataques cibernéticos, especialmente considerando a evolução constante das ameaças digitais. Em complemento, a desatualização do Plano de Testes de Continuidade agrava essa não conformidade, pois compromete a confiabilidade das diretrizes estabelecidas para a proteção e gerenciamento das informações de teste. A ausência de testes de phishing com o RH, a falta de confirmação dos prazos de testes com fornecedores e a não utilização do formulário de registro evidenciam um desalinhamento entre a documentação e a prática real.

ANEXO A - CONTROLADORES

NC Maior 01: A política de privacidade verificada no site da empresa, na data de 12/03/2025, não menciona os direitos dos titulares nem um canal para atendimentos dos seus direitos, conforme prints anexos. Além de não ter um Encarregado pelo Tratamento de Dados pessoais nomeado, a empresa não tem um procedimento nem um fluxo para atendimento às demandas dos titulares. Em auditoria, foi verificado que a empresa não criou processos e estruturas que permitam o atendimento aos titulares, nem cumprir os requisitos A.7.3.1 até A.7.3.9, configurando, dessa forma, uma NC Maior no que se refere ao controle 7.3 Obrigações para os Titulares de DP.

NC Menor 01: Foi identificado em auditoria que a empresa não elaborou um inventário que documentasse e identificasse os propósitos específicos pelos quais os dados pessoais são tratados.

NC Menor 02: Foi identificado, em auditoria, que a empresa não determinou nem documentou as bases legais referentes aos tratamentos de dados pessoais realizados.

NC Menor 03: Em que pese a área de Marketing realizar tratamentos de dados pessoais baseados em consentimento, não há um procedimento que trate especificamente sobre como o consentimento é coletado e como é feita a gestão dos consentimentos. O consentimento é coletado, por exemplo, quando alguém se interessa por algum conteúdo ou serviço da empresa e preenche o formulário que consta no site da ALWAYS ON. Ainda, foi verificado que há a utilização de termos de consentimento de forma errônea, quando a base legal para o tratamento de dados pessoais deveria ser outra.

NC Menor 04: A não conformidade com o controle A.7.4.1 da ISO 27701/2019 decorre da falta de transparência e inconsistência nas informações sobre o tratamento de dados pessoais. A Política de

Privacidade interna contém um erro técnico na explicação das bases legais da LGPD, podendo levar a interpretações errôneas, comprometendo a clareza da informação fornecida aos titulares e, consequentemente, violando o princípio da transparência exigido pela norma. Em complemento, há divergência entre a Política de Privacidade apresentada na auditoria e a versão disponível no site da empresa, o que compromete a confiabilidade e acessibilidade das informações prestadas ao titular dos dados. A ISO 27701 exige que as organizações garantam que todas as informações sobre privacidade sejam consistentes, precisas e facilmente acessíveis. A existência de duas versões distintas da política pode gerar confusão, minar a confiança dos titulares e até resultar em risco regulatório, caso alguma das versões não esteja alinhada com as exigências legais. Para garantir a conformidade, é essencial corrigir esses pontos, harmonizar os documentos e garantir que a comunicação com os titulares seja clara, consistente e acessível.

NC Menor 05: A organização não elaborou um ROPA (Registro de Operações de Processamento de Dados) e não identificou as bases legais para a transferência internacional de dados. O controle exige que a organização identifique e documente as bases relevantes para a transferência de dados pessoais entre jurisdições, e a ausência dessas informações demonstra uma falha na conformidade.

NC Menor 06: O fato de a organização não saber informar em quais países os servidores do Google estão localizados compromete a transparência e dificulta a comprovação da conformidade com regulamentos com esta norma e com a LGPD, por exemplo, que exige que os titulares sejam informados sobre a localização de seus dados. Em complemento, a falta de bases legais identificadas para a transferência internacional de dados também reforça a não conformidade, pois a empresa precisa demonstrar que sua operação está amparada por um fundamento jurídico adequado.

ANEXO B - OPERADORES

NC Menor 01: A política de privacidade verificada no site da empresa (<https://aodigital.com.br/o-que-e-politica-de-privacidade/>), na data de 12/03/2025, não menciona os direitos dos titulares nem um canal para atendimentos dos seus direitos, conforme prints anexos. Além de não ter um Encarregado pelo Tratamento de Dados pessoais nomeado, a empresa não tem um procedimento nem um fluxo para atendimento às demandas dos titulares. Em auditoria, foi verificado que a empresa não criou processos e estruturas que permitam o atendimento aos titulares.

NC Menor 02: A organização não elaborou um ROPA (Registro de Operações de Processamento de Dados) e não identificou as bases legais para a transferência internacional de dados. O controle exige que a organização identifique e documente as bases relevantes para a transferência de dados pessoais entre jurisdições, e a ausência dessas informações demonstra uma falha na conformidade.

NC Menor 03: O fato de a organização não saber informar em quais países os servidores do Google estão localizados compromete a transparência e dificulta a comprovação da conformidade com regulamentos com esta norma e com a LGPD, por exemplo, que exige que os titulares sejam informados sobre a localização de seus dados. Em complemento, a falta de bases legais identificadas para a transferência internacional de dados também reforça a não conformidade, pois a empresa precisa demonstrar que sua operação está amparada por um fundamento jurídico adequado.

NC Menor 04: Em que pese o que consta no referido procedimento, durante a auditoria não foi localizada cláusula contratual que garantisse notificação sobre solicitações legalmente obrigatórias para a divulgação de dados pessoais.

Pontos de Preocupação (PP)

33

19 PPs, também registrados no relatório da ISO 27001/2022 e 14 PPs referentes aos Anexos A e B da ISO 27701/2019.

PONTO DE PREOCUPAÇÃO (PP) 01: Em que pese a participação ativa da Alta Direção, políticas e procedimentos recebidos não estão assinados e aprovados. A falta de evidências de aprovação pela Alta Direção é um problema grave, pois a norma exige que a Alta Direção demonstre liderança e compromisso com o sistema de gestão.

PP 02: A PSI veio em formato word e sem as assinaturas necessárias. Consta um quadro de alterações, mas não há assinaturas.

PP 03: Durante a auditoria, foi informado que a PSI está disponível no Google Drive, porém, o documento não foi localizado, evidenciando uma falha no controle e na disseminação dessas diretrizes, indicando que a comunicação de informações essenciais para a segurança da informação não está sendo realizada de forma eficaz, comprometendo a conformidade com o requisito. A organização deve garantir que as políticas e procedimentos sejam facilmente acessíveis a todos os colaboradores e devidamente comunicados, além de revisar e alinhar as práticas reais com as diretrizes documentadas, minimizando riscos operacionais e de conformidade. Ainda, a divergência entre o que está formalizado no procedimento e o que ocorre na prática compromete a eficácia do SGSI, pois gera insegurança na comunicação, dificuldade no acesso a informações essenciais e possíveis riscos de violações de dados pessoais ou falhas na resposta a incidentes. Para garantir a conformidade, a organização deve revisar seu procedimento, alinhar suas práticas reais com o que está documentado e garantir que todas as diretrizes sejam devidamente implementadas e seguidas pelos

colaboradores.

PP 04: Há a necessidade do fortalecimento do processo de avaliação de riscos, realizando a revisão dos documentos, a ampliação da compreensão interna sobre os critérios de aceitação de riscos, e a revisão da Declaração de Aplicabilidade, a fim de assegurar conformidade com os requisitos normativos. Essas ações visam aumentar a clareza, consistência e alinhamento do processo com as melhores práticas de gestão de riscos.

PP 05: Há a necessidade do fortalecimento do processo de avaliação de riscos, realizando a revisão dos documentos, a ampliação da compreensão interna sobre os critérios de aceitação de riscos, e a revisão da Declaração de Aplicabilidade, a fim de assegurar conformidade com os requisitos normativos. Essas ações visam aumentar a clareza, consistência e alinhamento do processo com as melhores práticas de gestão de riscos.

PP 06: É fundamental revisar o procedimento para incluir os elementos faltantes mencionados e garantir o atendimento a todos os requisitos da seção 9.2 da ISO 27001/2022, bem como esclarecer o objetivo da auditoria interna, focando na conformidade com a norma e com os requisitos da organização.

PP 07: A ata cobre grande parte dos requisitos da ISO 27001:2022, mas precisa de ajustes para estar 100% em conformidade. As principais ações recomendadas incluem:

- Incluir mais detalhes sobre mudanças nas expectativas das partes interessadas, com exemplos concretos de como essas mudanças impactam o SGSI;
- Expandir a seção de desempenho da segurança da informação, detalhando detalhes de não conformidades, monitoramento, auditorias e objetivos de segurança;
- Adicionar um resumo da avaliação de riscos realizada e a situação do plano de tratamento de riscos, demonstrando as medidas tomadas e o status atual;
- Apresentar o documento em arquivo protegido e assinado.

PP 08: Em que pese a participação ativa da Alta Direção, políticas e procedimentos recebidos não estão assinados pela Alta Direção. A falta de evidências de aprovação pela Alta Direção é um problema grave, pois a norma exige que a Alta Direção demonstre liderança e compromisso com o sistema de gestão.

PP 09: A ausência de um procedimento formalizado sobre inteligência de ameaças representa uma preocupação significativa, pois indica a falta de sistematização e clareza sobre como informações de ameaças são adquiridas, analisadas e aplicadas. Essa lacuna pode gerar inconsistências no processo e limitar a capacidade da organização de responder proativamente a riscos emergentes.

PP 10: Diferente do controle lógico, que possui uma política formal, o acesso físico parece ser tratado de maneira informal, o que pode gerar inconsistências na aplicação dos controles e dificultar auditorias e conformidade regulatória. É fundamental criar uma política formal de Controle de Acesso Físico, definindo critérios de acesso a áreas sensíveis, identificando responsáveis e implementando registros detalhados de entradas e saídas.

PP 11: Embora exista um PCN, ele aparenta se confundir com um Plano de Recuperação de Desastres (PRD), sem distinção clara entre as estratégias de continuidade de operações críticas e as de restauração de infraestrutura e sistemas. Essa falta de delimitação compromete a eficácia do plano durante situações de crise, pois cada tipo de plano possui objetivos, escopos e respostas distintas. Em complemento, apesar da existência de testes de redundância em servidores, esses controles técnicos isolados não garantem, por si só, a manutenção da confidencialidade, integridade e disponibilidade das informações durante todo o período de interrupção. É necessário haver um plano estruturado e documentado, com responsabilidades definidas, procedimentos operacionais, estratégias de comunicação e salvaguardas específicas para segurança da informação, incluindo medidas para. A ausência de um documento específico e segregado sobre o PRD também dificulta a resposta coordenada e o cumprimento do controle de forma robusta.

PP 12: Este controle exige que a organização identifique, documente e mantenha atualizados os requisitos legais, estatutários, regulamentares e contratuais pertinentes à segurança da informação e, sem essa identificação formalizada, a empresa pode operar sem conhecer integralmente suas obrigações legais, aumentando o risco de não conformidade com legislações vigentes e aplicáveis. Em complemento, a ausência de uma ferramenta de monitoramento de legislação representa um risco contínuo para a atualização dos requisitos legais da empresa. Mudanças regulatórias ocorrem frequentemente, e sem um mecanismo eficaz para acompanhar essas atualizações, a organização pode falhar na adoção tempestiva de medidas de adequação, resultando em exposição a penalidades legais e falhas de governança corporativa. Para mitigar esses riscos, a empresa deve estabelecer um processo formal de identificação e acompanhamento das legislações aplicáveis e implementar um sistema de monitoramento regulatório, garantindo a conformidade contínua e a minimização de riscos jurídicos.

PP 13: Esse controle exige que os procedimentos operacionais estejam documentados e acessíveis para garantir que os processos de segurança sejam executados corretamente. Quando documentos desatualizados são utilizados como referência, há um desalinhamento entre a prática e a documentação formal, o que pode gerar falhas operacionais, confusão entre os colaboradores e dificuldades em auditorias. Ademais, a organização pode ter dificuldades em demonstrar conformidade com requisitos regulatórios e boas práticas de segurança. Outro ponto de preocupação é que a desatualização dos documentos pode comprometer a eficácia dos controles implementados e afetar a resposta a incidentes e a gestão de riscos. Se os procedimentos não refletem a realidade da organização, há o risco de que colaboradores sigam diretrizes obsoletas, o que pode levar a falhas de segurança, não conformidades legais e até mesmo incidentes de segurança e/ou violações de dados pessoais. Para mitigar esses riscos, a organização deve

estabelecer um processo de revisão periódica da documentação, garantindo que os procedimentos estejam sempre alinhados com as práticas atuais e que os colaboradores tenham acesso a informações atualizadas e confiáveis.

PP 14: A situação descrita representa uma não conformidade, pois a organização não garante a realização de treinamentos regulares e abrangentes que incluam segurança da informação e privacidade. A ausência de um cronograma formalizado de treinamentos compromete a continuidade da conscientização e capacitação dos colaboradores, tornando a organização vulnerável a falhas humanas e potenciais incidentes de segurança. Embora existam treinamentos de segurança da informação, a falta de treinamentos específicos sobre privacidade indica uma deficiência no atendimento às exigências da norma, especialmente considerando as obrigações legais da LGPD. Em complemento, a falta de acesso facilitado à Política de Segurança da Informação (PSI) representa um risco operacional e de conformidade. Se os colaboradores não têm acesso imediato às políticas de segurança e privacidade, há um risco significativo de descumprimento das diretrizes do SGSIP, o que pode comprometer a governança da segurança da informação. A alegação de que a PSI está armazenada no Google Drive, mas não foi localizada durante a auditoria, reforça que a organização não assegura a disponibilidade das políticas para os colaboradores.

PP 15: Em que pese existam algumas medidas técnicas de segurança implementadas, como configurações de VPN, autenticação multifator (MFA) e criptografia de notebooks via Bitlocker, o Guia de Trabalho Remoto não aborda os temas de segurança da informação (SI) e privacidade, indicando que a organização pode não estar garantindo que os colaboradores compreendam os riscos e boas práticas ao trabalhar remotamente, podendo gerar falhas operacionais e potenciais incidentes de segurança e violações de dados pessoais.

PP 16: Embora a empresa utilize a ferramenta Bitdefender para detectar vulnerabilidades e possua um processo de abertura de chamados no GLPI, a falta de um documento atualizado compromete a eficácia e rastreabilidade do tratamento dessas falhas, podendo resultar em atrasos ou falhas operacionais na mitigação de riscos. Para mitigar esses riscos, é essencial atualizar o procedimento de infraestrutura, detalhando o fluxo de resposta às vulnerabilidades e garantindo que ele seja seguido de maneira padronizada.

PP 17: O cenário apresentado demonstra um comprometimento com os princípios da engenharia de sistemas seguros, no entanto, há um ponto de preocupação relevante, pois não são realizadas avaliações de riscos de segurança da informação e privacidade antes dos projetos, o que pode comprometer a segurança geral dos sistemas desenvolvidos. A ausência de uma análise de riscos formalizada significa que possíveis vulnerabilidades não são identificadas e tratadas de maneira preventiva, podendo resultar em falhas críticas de segurança ao longo do ciclo de vida do software. Sem essa etapa, o projeto pode apresentar exposição a ameaças como vazamento de dados, falhas de autenticação e insegurança na comunicação. Para mitigar essa preocupação, é fundamental que a organização integre avaliações de riscos de SI e privacidade como parte do ciclo de desenvolvimento, garantindo que todos os princípios documentados sejam efetivamente aplicados na prática e não apenas descritos no Procedimento.

PP 18: O fato de os testes serem realizados apenas no ambiente de desenvolvimento, sem uma estrutura formalizada para testes de segurança, pode comprometer a detecção e mitigação de vulnerabilidades antes da implementação em produção. Também, apesar da apresentação de um plano básico de testes para o cliente Santander, não foram evidenciados relatórios de resultados e verificação da eficácia dos testes realizados, e a ausência de documentação formal impede a rastreabilidade e a melhoria contínua do processo de segurança, dificultando a análise de riscos.

PP 19: A ausência de auditorias compromete a avaliação contínua da segurança, dificultando a identificação de vulnerabilidades, falhas de configuração e riscos operacionais que podem impactar a integridade do ambiente de TI. A norma exige que os testes sejam planejados e acordados entre os testadores e a gestão, o que não está ocorrendo, indicando a necessidade de uma abordagem mais estruturada na governança da segurança da informação. Outro ponto é a disparidade na frequência dos pentests. Embora tenham sido realizados em 2022 e 2023, não há um cronograma formalizado e contínuo para a realização dessas avaliações. A falta de testes periódicos pode permitir que novas vulnerabilidades permaneçam sem detecção, aumentando o risco de exploração por atacantes.

ANEXO A - CONTROLADORES

PP 01: Sem um processo documentado, a empresa não consegue demonstrar, de forma clara e auditável, que o consentimento foi obtido de maneira válida, informada e inequívoca. Outro ponto crítico é o risco de uso indevido do consentimento, especialmente se a base legal correta para o tratamento dos dados pessoais não for avaliada corretamente. Sem um sistema eficaz de rastreamento, há dificuldades em comprovar que os dados estão sendo usados conforme a permissão concedida, além de desafios para atender solicitações de revogação do consentimento, conforme previsto na ISO e na LGPD. Para mitigar essas falhas, a empresa deve implementar um processo estruturado e documentado, garantindo registros claros e mecanismos que permitam a gestão transparente do consentimento ao longo do tempo.

PP 02: Convém que a organização determine os elementos que são necessários para uma avaliação de impacto de privacidade completa, podendo incluir uma lista dos tipos de DP tratados, onde o DP é armazenado e onde ele pode ser transferido. Diagramas de fluxos de dados e mapas de dados podem também ser úteis neste contexto.

PP 03: É fundamental que o ROPA seja realizado com base em todos os processos dentro da organização

que envolvam dados pessoais. Esse documento deve abranger todos os processos da empresa que tratem dados pessoais, pois cada operação (como coleta, armazenamento, compartilhamento ou exclusão) pode gerar riscos diferentes à privacidade dos titulares. A ausência de um registro abrangente pode resultar em lacunas no gerenciamento de riscos, dificultando a demonstração de conformidade em auditorias ou fiscalizações pela Autoridade Nacional de Proteção de Dados (ANPD). Ademais, o registro com base em todos os processos facilita a identificação de vulnerabilidades e ajustes necessários para atender o que estabelece a norma ISO e aos princípios da LGPD, como minimização de dados e segurança. O registro também é fundamental para documentar a base legal do tratamento de dados pessoais em cada processo, servindo não apenas para cumprir a norma e a legislação, mas também como ferramenta de gestão para proteger a privacidade dos titulares e mitigar os riscos de sanções administrativas.

PP 04: Sem o referido mapeamento, a organização não tem clareza sobre quais dados são tratados, por quem, com que finalidade e por quanto tempo, o que impossibilita assegurar o princípio da minimização de dados. Esse cenário representa um risco significativo de tratamento excessivo ou inadequado de dados pessoais, comprometendo tanto a conformidade com a norma quanto com legislações como a LGPD. Ademais, em caso de incidentes ou fiscalizações, a empresa pode não conseguir demonstrar controle sobre os dados que coleta e processa, o que pode levar a sanções administrativas, danos reputacionais e prejuízos à confiança dos titulares.

PP 05: Sem diretrizes bem definidas, a organização pode falhar na manutenção da exatidão, completude e atualização dos dados pessoais, comprometendo a qualidade do tratamento de dados e aumentando a possibilidade de decisões baseadas em informações incorretas, podendo gerar impactos tanto para os titulares, que podem sofrer prejuízos devido a informações erradas, quanto para a própria organização, que pode enfrentar sanções regulatórias por não garantir a precisão dos dados tratados. Ademais, a ausência de um processo estruturado para identificar e corrigir inconsistências pode dificultar a resposta a solicitações de retificação feitas pelos titulares, conforme previsto na LGPD (Art. 18, III). A falta de mecanismos automatizados ou procedimentos manuais claros para revisar e corrigir dados pode resultar em falhas operacionais, dificultando a rastreabilidade das ações corretivas.

PP 06: Em que pese o Procedimento de Exclusão Segura de Informações mencione técnicas como anonimização, minimização e pseudonimização, não há uma abordagem detalhada sobre como esses métodos são aplicados de forma sistemática nos processos da organização. Também, a ausência de um inventário de processos que envolvem dados pessoais (ROPA) compromete a rastreabilidade e a efetividade das práticas de minimização, dificultando auditorias e avaliações de conformidade regulatória. Outro ponto crítico é que a política de privacidade da organização não menciona a minimização de dados, o que pode levar a uma falta de transparência com os titulares de dados e partes interessadas. A minimização é um princípio fundamental da privacidade e deve estar explicitamente documentada para garantir que apenas os dados estritamente necessários para os processos sejam coletados e tratados. Para mitigar esses riscos, a organização deve revisar e atualizar a política de privacidade, além de desenvolver um ROPA.

PP 07: No Mapa de DP quase todos os dados estão com o prazo de retenção de 5 anos. É fundamental verificar se todos os prazos estão atualizados e corretos. Utilizar uma tabela de temporalidade é de suma importância quando se fala em retenção e descarte de dados pessoais. Ainda, é importante realizar auditorias internas e revisões periódicas, verificando se o tratamento de dados segue os princípios da minimização, bem como treinar colaboradores e terceiros, garantindo que todos compreendam os limites do tratamento de dados.

PP 08: Embora a organização trate o tema no Mapa de DP (que precisa ser ajustado) e no Procedimento de Tratamento de Dados Pessoais, a falta de um mapeamento estruturado pode comprometer a rastreabilidade das transferências de dados pessoais, dificultando a conformidade com requisitos regulatórios. Sem um ROPA devidamente documentado, a empresa não tem um registro claro das operações de tratamento e compartilhamento, o que pode afetar sua capacidade de responder a solicitações de titulares e sua governança de privacidade. Em complemento, mesmo havendo cláusulas contratuais que abordam o compartilhamento e a transferência internacional de dados, não há um processo documentado que garanta a rastreabilidade e a comprovação das transferências realizadas. A ausência desse registro pode gerar riscos de descumprimento de obrigações contratuais, bem como dificuldades em auditorias e no atendimento a eventuais investigações regulatórias. É imprescindível a implementação de um ROPA, a fim de cumprir a norma, bem como o que estabelece a LGPD.

ANEXO B - OPERADORES

PP 01: É fundamental que o ROPA seja realizado com base em todos os processos dentro da organização que tratem dados pessoais. Esse documento deve abranger todos os processos da empresa que envolvam dados pessoais, pois cada operação (como coleta, armazenamento, compartilhamento ou exclusão) pode gerar riscos diferentes à privacidade dos titulares. A ausência de um registro abrangente pode resultar em lacunas no gerenciamento de riscos, dificultando a demonstração de conformidade em auditorias ou fiscalizações pela Autoridade Nacional de Proteção de Dados (ANPD). Ademais, o registro com base em todos os processos facilita a identificação de vulnerabilidades e ajustes necessários para atender aos princípios da LGPD, como minimização de dados e segurança. Por exemplo, em uma loja virtual, o registro pode identificar que dados coletados no cadastro de clientes estão sendo armazenados por um período maior do que o necessário, expondo a empresa a riscos desnecessários. O registro também é fundamental

para documentar a base legal do tratamento de dados em cada processo, servindo não apenas para cumprir a legislação, mas também como ferramenta de gestão para proteger a privacidade dos titulares e mitigar os riscos de sanções administrativas.

PP 02: Embora a organização utilize uma base de consentimento para suas campanhas de tráfego pago e trabalhe com prestadores de serviço, a falta de um sistema estruturado para monitorar, atualizar e revogar consentimentos representa um risco significativo de não conformidade com a ISO 27701/2019 e a LGPD. Sem um gerenciamento eficaz, não há como garantir que os titulares tenham controle contínuo sobre seus dados ou que as campanhas de marketing estejam sendo direcionadas apenas a pessoas que deram consentimento válido e atual. Ademais, a falta de rastreabilidade dos consentimentos pode comprometer a capacidade da organização de responder a auditorias, solicitações de titulares para exclusão de seus dados ou questionamentos de autoridades regulatórias. Caso um titular de DP solicite a revogação do consentimento, a empresa pode não conseguir comprovar quando e como esse consentimento foi obtido e atualizado, o que pode resultar em reclamações, sanções e danos à reputação da organização. Para mitigar esse risco, é essencial implementar um sistema automatizado de gerenciamento de consentimentos, garantindo que todas as interações de marketing respeitem as preferências dos titulares e que seja possível demonstrar conformidade em caso de auditorias ou fiscalizações.

PP 03: É fundamental que o ROPA seja realizado com base em todos os processos dentro da organização que envolvam dados pessoais. Esse documento deve abranger todos os processos da empresa que tratem dados pessoais, pois cada operação (como coleta, armazenamento, compartilhamento ou exclusão) pode gerar riscos diferentes à privacidade dos titulares. A ausência de um registro abrangente pode resultar em lacunas no gerenciamento de riscos, dificultando a demonstração de conformidade em auditorias ou fiscalizações pela Autoridade Nacional de Proteção de Dados (ANPD). Ademais, o registro com base em todos os processos facilita a identificação de vulnerabilidades e ajustes necessários para atender o que estabelece a norma ISO e aos princípios da LGPD, como minimização de dados e segurança. O registro também é fundamental para documentar a base legal do tratamento de dados pessoais em cada processo, servindo não apenas para cumprir a norma e a legislação, mas também como ferramenta de gestão para proteger a privacidade dos titulares e mitigar os riscos de sanções administrativas.

PP 04: Sem uma diretriz clara sobre como lidar com solicitações de órgãos governamentais, autoridades judiciais ou outras entidades com base legal, a organização pode acabar divulgando dados sem o devido controle ou, inversamente, recusando divulgações obrigatórias, resultando em não conformidade legal e possíveis penalidades. Também, a falta de procedimentos formais pode gerar inconsistências operacionais, levando a decisões arbitrárias ou à ausência de registro adequado dessas solicitações. Outro ponto crítico é a necessidade de consultar o cliente antes de qualquer divulgação não obrigatória e de garantir que somente solicitações autorizadas sejam atendidas. Sem um procedimento detalhado, a empresa corre o risco de não realizar essa consulta ou de não registrar adequadamente a decisão do cliente, dificultando auditorias e investigações futuras. Para mitigar esse problema, o Procedimento de Tratamento de Dados Pessoais deve ser atualizado para incluir diretrizes claras sobre como identificar, documentar e processar solicitações legais de divulgação de DP, assegurando que apenas pedidos legítimos sejam atendidos e que haja transparência e rastreabilidade em todas as operações de compartilhamento de dados.

PP 05: O fato de o tema em tela não estar tratado no Procedimento de Tratamento de Dados Pessoais nem em nenhum outro documento da organização demonstra ausência de governança e controle na gestão de subcontratados, podendo gerar riscos operacionais e jurídicos, pois não há garantia de que os clientes sejam devidamente informados sobre quais terceiros terão acesso ou tratarão dados pessoais. A ausência desse controle também pode comprometer a conformidade com a LGPD, por exemplo, que exige transparência no tratamento de dados. Ademais, embora tenha sido apresentado um contrato com o cliente Santander que restringe a subcontratação sem prévia autorização, não há nenhuma menção sobre a obrigatoriedade de divulgação desses subcontratados aos clientes nem sobre como eventuais mudanças contratuais serão comunicadas, o que pode ocasionar insegurança jurídica e risco de descumprimento contratual, caso a empresa utilize subcontratados sem um processo estruturado de comunicação e aprovação formal.

PP 06: Os pontos de preocupação identificados estão relacionados à ausência de um processo formal para comunicação de mudanças nos subcontratados que tratam dados pessoais. Embora o contrato com o cliente Santander estabeleça que qualquer subcontratação exige autorização prévia, não há evidências de um mecanismo documentado que regule como essa autorização deve ser obtida e registrada, tampouco há diretrizes sobre a comunicação prévia de alterações nos subcontratados. A falta dessa regulamentação pode levar a falhas na transparência e no cumprimento dos requisitos contratuais, além de comprometer a conformidade com normas de privacidade e segurança da informação. Outro ponto crítico é que, apesar de o contrato conter cláusulas sobre proteção de dados e segurança da informação, não há menção específica sobre a necessidade de informar o cliente sobre mudanças de subcontratados e permitir que ele se oponha, podendo gerar riscos regulatórios, especialmente em auditorias ou em casos de incidentes de segurança e violações de dados pessoais, pois a organização não tem evidências concretas de que a substituição de subcontratados foi devidamente comunicada e aprovada. Para mitigar esses riscos, a organização deve estabelecer um processo formal de comunicação dessas mudanças, garantindo que os clientes tenham tempo hábil para avaliar e aprovar ou rejeitar qualquer nova subcontratação antes que ela ocorra.

Oportunidades de Melhoria (OM)

18

12 OMs, também registrados no relatório da ISO 27001/2022 e 06 OMs referentes aos Anexos A e B da ISO 27701/2019.

OPORTUNIDADE DE MELHORIA (OM) 01: Considerando o que estabelece o requisito 5.2.3 da ISO 27701/2019, a ALWAYS ON deve incluir o tratamento de DP no escopo. A descrição pode ser ampliada para incluir armazenamento, processamento e transmissão de informações e dados pessoais.

OM 2: Inserir no procedimento a necessidade de identificação dos proprietários dos riscos.

OM 03: Criar uma lista, identificando as autoridades relevantes para a organização e designar um ponto de contato para a comunicação com as autoridades.

OM 04: É importante identificar os grupos de interesse especial relevantes para a organização e fazer cadastro em grupos de discussão e participar de eventos, a fim de se manter atualizada sobre assuntos pertinentes à segurança da informação e privacidade.

OM 05: Elaborar um termo de devolução de equipamentos, com informações dos equipamentos e a assinatura do colaborador.

OM 06: É importante criar uma política formal de segurança para uso de serviços em nuvem, definindo critérios para armazenamento e processamento de dados, níveis de acesso, requisitos de criptografia, práticas de backup e diretrizes para auditoria e monitoramento contínuo. Ainda, deve contemplar regras de responsabilidade compartilhada, garantindo que as obrigações da empresa e do provedor de nuvem sejam bem definidas e específicas.

OM 07: A fragmentação do tema entre diferentes políticas e procedimentos pode levar a inconsistências na aplicação e monitoramento das práticas de segurança. O uso de ferramentas como BitDefender para proteção contra malware, Bitlocker para criptografia, além do controle de acessos, demonstra boas práticas, mas a falta de um documento consolidado e abrangente pode dificultar a rastreabilidade e a governança eficaz sobre os registros. É recomendável que a organização elabore um procedimento específico que integre e detalhe as práticas existentes, garantindo que todos os registros sejam protegidos de forma uniforme contra perda, acesso não autorizado e outros riscos.

OM 08: Atualmente, a organização utiliza apenas um e-mail para relatos, sem um formulário estruturado ou um sistema dedicado para capturar informações de forma detalhada e organizada, podendo levar a relatos incompletos, falta de rastreabilidade e dificuldades na triagem e resposta a eventos e/ou incidentes. A implementação de um formulário padronizado garantiria que todos os incidentes fossem relatados com os detalhes essenciais, como data, tipo de evento, sistemas afetados e impacto percebido, facilitando uma resposta ágil e eficiente. Outra oportunidade de melhoria seria a adoção de um canal mais estruturado, como uma plataforma de gestão de incidentes, que permita rastreamento, notificação e resposta automatizada. Em complemento, campanhas de conscientização poderiam ser realizadas para garantir que os colaboradores saibam quando e como relatar um evento de segurança. Essas melhorias não apenas aumentariam a conformidade com a norma, mas também fortaleceriam a capacidade de resposta a incidentes da organização.

OM 09: Uma oportunidade de melhoria seria a implementação de monitoramento interno por câmeras dentro da sala da ALWAYS ON, garantindo a proteção adicional dos ativos e informações sensíveis. Ademais, a utilização de crachás de identificação para colaboradores e visitantes facilitaria o controle de entrada e permanência no ambiente.

OM 10: Uma oportunidade de melhoria seria a implementação de monitoramento interno por câmeras dentro da sala da ALWAYS ON, garantindo a proteção adicional dos ativos e informações sensíveis. Ademais, a utilização de crachás de identificação para colaboradores e visitantes facilitaria o controle de entrada e permanência no ambiente.

OM 11: Uma oportunidade de melhoria seria a implementação de monitoramento interno por câmeras dentro da sala da ALWAYS ON, garantindo a proteção adicional dos ativos e informações sensíveis.

OM 12: Uma oportunidade de melhoria seria a implementação de monitoramento interno por câmeras dentro da sala da ALWAYS ON, garantindo a proteção adicional dos ativos e informações sensíveis.

ANEXO A - CONTROLADORES

OM 01: Para fortalecer esse controle, recomenda-se que a organização inclua no Procedimento de Tratamento de DP uma descrição mais clara das medidas aplicadas à transmissão de dados pessoais, especificando os protocolos, ferramentas de segurança e procedimentos de monitoramento ativos. Embora a organização informe contratualmente os clientes sobre a transmissão de dados, não há menção à validação contínua dessas transmissões para garantir que os dados cheguem corretamente ao destino pretendido, sem alterações ou interceptações não autorizadas. A implementação de um sistema de logs de auditoria específico para transmissões de DP e a realização de testes periódicos de segurança na rede ajudariam a garantir que os controles aplicados são eficazes e que eventuais vulnerabilidades possam ser detectadas e corrigidas de maneira proativa.

OM 02: É essencial definir um procedimento formal de registro, a fim de garantir que qualquer transferência de DP para terceiros seja documentada, podendo utilizar planilhas, sistemas de gestão ou softwares de

governança para rastrear todas as divulgações. Ainda, é recomendável detalhar o compartilhamento de dados, incluindo qual tipo de dado, para quem foi enviado, quando foi enviado, qual a finalidade da divulgação, quem é o responsável pela divulgação e qual a base legal utilizada. Também, é importante implementar controles de acesso para que apenas pessoas autorizadas possam visualizar ou modificar os registros de divulgação.

ANEXO B - OPERADORES

OM 01: Uma melhoria seria incluir um processo claro de requisição e confirmação de descarte, bem como auditorias regulares para garantir que a remoção dos dados foi realizada corretamente e que não há armazenamento residual em backups. Adicionar diretrizes específicas sobre políticas de retenção de dados, controles de acesso pós-contrato e a necessidade de garantir que cópias de segurança sejam devidamente apagadas quando não forem mais necessárias ajudaria a elevar o nível de conformidade com a ISO 27701/2019.

OM 02: Para fortalecer esse controle, recomenda-se que a organização inclua no Procedimento de Tratamento de DP uma descrição mais clara das medidas aplicadas à transmissão de dados pessoais, especificando os protocolos, ferramentas de segurança e procedimentos de monitoramento ativos. Embora a organização informe contratualmente os clientes sobre a transmissão de dados, não há menção à validação contínua dessas transmissões para garantir que os dados cheguem corretamente ao destino pretendido, sem alterações ou interceptações não autorizadas. A implementação de um sistema de logs de auditoria específico para transmissões de DP e a realização de testes periódicos de segurança na rede ajudariam a garantir que os controles aplicados são eficazes e que eventuais vulnerabilidades possam ser detectadas e corrigidas de maneira proativa.

OM 03: É essencial definir um procedimento formal de registro, a fim de garantir que qualquer transferência de DP para terceiros seja documentada, podendo utilizar planilhas, sistemas de gestão ou softwares de governança para rastrear todas as divulgações. Ainda, é recomendável detalhar o compartilhamento de dados, incluindo qual tipo de dado, para quem foi enviado, quando foi enviado, qual a finalidade da divulgação, quem é o responsável pela divulgação e qual a base legal utilizada. Também, é importante implementar controles de acesso para que apenas pessoas autorizadas possam visualizar ou modificar os registros de divulgação.

OM 04: É fundamental incluir no Procedimento de Tratamento de Dados Pessoais um processo específico para a contratação de subcontratados, definindo critérios claros para a avaliação, aprovação e monitoramento desses terceiros. Esse procedimento deve prever a necessidade de autorização prévia dos clientes antes de qualquer subcontratação, assegurando que todas as exigências contratuais e regulatórias sejam cumpridas. Em complemento, a organização pode criar um registro centralizado de subcontratados, onde constem todas as autorizações dos clientes, cláusulas específicas dos contratos e os compromissos assumidos pelos terceiros em relação à segurança da informação e privacidade, o que permitiria um melhor acompanhamento das obrigações contratuais e facilitaria auditorias futuras.

Pontos Fortes

Engajamento, transparência e cordialidade dos colaboradores da ALWAYS ON.

Pontos Fracos

Demonstrados através dos pontos de preocupação e não conformidades neste relatório.

Nota do Sistema de Gestão implementado

4
De 0 a 10

INFORMAÇÕES GERAIS DA AUDITORIA

Objetivo da Auditoria: Avaliar o Sistema de Gestão com base no referencial normativo adotado pela organização.

Escopo da Auditoria: ABNT ISO 27701:2019

Itens Não Aplicáveis?

Sim

Itens Não Aplicáveis e Justificativas

6.11.2.7 - Desenvolvimento terceirizado

Foi constatado, em auditoria, que os desenvolvedores PJs são classificados como internos, eis que trabalham exclusivamente para a ALWAYS ON, seguem as diretrizes internas da empresa, utilizam a infraestrutura da empresa e têm acesso contínuo a informações.

7.2.7 - Controlador conjunto de DP

Em entrevista, o Diretor Wesley Ruiz informou que a empresa fez uma análise e não há controladoria conjunta com qualquer outra organização.

7.3.10 - Tomada de decisão automatizada

Foi informado, em entrevista, pelo Diretor Wesley Ruiz, que todos os processos automatizados têm supervisão humana.

Porte e Tempo de Mercado

A Always On é uma empresa que está há 9 anos no mercado, especializada em ciência de dados e experiência do cliente, dedicada a descomplicar as relações entre marcas e consumidores por meio de soluções tecnológicas avançadas. Seu foco está em transformar dados complexos em valor e resultados concretos, otimizando estratégias e processos empresariais.

Processos Mapeados

Alta Direção
Financeiro
Adm
Comercial
Marketing
Compras
RH
TI
SI

Descrição geral da situação da organização e seu sistema de gestão

A ALWAYS ON, no que tange à privacidade e proteção de dados pessoais está em um estágio inicial de implementação do Sistema de Gestão de Segurança da Informação e Privacidade (SGSIP), com alguns documentos elaborados e controles de segurança aplicados. Em que pese existam práticas estabelecidas, sistema ainda carece de uma abordagem mais estruturada e abrangente para atender plenamente aos requisitos da ISO 27701/2019.

Recomenda-se, que a organização dê ênfase na nomeação do Encarregado pelo Tratamento de Dados Pessoais, na gestão dos consentimentos, no controle de seus riscos com relação ao gerenciamento de incidentes e violações de dados pessoais, na estruturação e gestão de atendimento às demandas dos titulares e na adequação à LGPD. Com o planejamento adequado e o apoio da alta direção, a organização estará em posição de transformar o SGSIP em um sistema eficaz, reduzindo riscos, aumentando a confiança de partes interessadas e alcançando a conformidade com os padrões internacionais.

Assim sendo, entende-se que o sistema de gestão está em fase inicial de implementação, necessitando dos

ajustes apontados neste relatório para sua melhoria contínua.

CONSTATAÇÕES

GESTÃO DA EMPRESA

5.2 - Contexto da organização

5.2.1 - Entendendo a organização e seu contexto

Averiguou-se, que a ALWAYS ON determinou suas questões internas e externas no documento Gestão de Contexto. Com base no referido documento, as questões internas e externas foram definidas com bases nas respostas dos questionários, resultando em:

Contexto Interno: Risco Baixo (36%);

Contexto Externo: Risco Baixo (30%).

Também, foram definidas as diretrizes de missão, valores e objetivo estratégico.

PARTES INTERESSADAS

Verificou-se que as partes interessadas foram elencadas no documento Gestão de Contexto.

NC Menor 01: Foi constatado, em entrevista, que a ALWAYS ON não considerou as mudanças climáticas (*) quando da elaboração do contexto, contrariando assim o requisito 5.2.1 da ISO 27701:2019. Assim sendo, fica configurada a NC Menor com relação ao requisito 5.2.1 e 5.2.2.

(*) Comunicado a partir da divulgação do IAF & ISO a respeito da inclusão da temática de Mudanças Climáticas nos requisitos 4.1 e 4.2 de todas as normas de sistema de gestão / As alterações (emendas /Amendments) nas normas foram publicadas em 23 de fevereiro de 2024. As alterações (duas novas declarações) foram incorporadas no novo texto da Estrutura Harmonizada (Apêndice 2 do Anexo SL nas Directivas ISO/IEC Parte 1 Suplemento ISO Consolidado).

5.2.2 - Entendendo as necessidades e as expectativas das partes interessadas

Verificou-se que as partes interessadas foram elencadas no documento Gestão de Contexto, conforme evidenciado em auditoria.

5.2.3 - Determinando o escopo do sistema de gestão da segurança da informação

Oportunidade de Melhoria

Foi identificada a declaração do escopo do SGSIP da ALWAYS ON no documento "Gestão de Contexto" (Aba "Análise de Contexto"), estabelecendo que: "O sistema de Gestão de Segurança da Informação e Privacidade tem como objetivo garantir a segurança das informações e privacidade dos dados pessoais nos serviços (Serviços prestados de ciência de dados referente ao marketing de vendas no varejo, físico e online dos nossos clientes usando a inteligência artificial) bem como nos processos internos que apoiam nossa operação."

OPORTUNIDADE DE MELHORIA (OM) 01: Considerando o que estabelece o requisito 5.2.3 da ISO 27701/2019, a ALWAYS ON deve incluir o tratamento de DP no escopo. A descrição pode ser ampliada para incluir armazenamento, processamento e transmissão de informações e dados pessoais.

5.2.4 - Sistema de gestão da segurança da informação

Preocupação

PP: Foi verificado um SGSI em estágio intermediário, com alguns documentos elaborados e ferramentas utilizadas, mas com pontos de preocupação e não conformidades em diversos controles da norma ISO 27701/2019.

5.3 - Liderança

5.3.1 - Liderança e comprometimento

Preocupação

O Wesley Ruiz (Diretor) informou que tudo começou com a necessidade de responder as questões dos clientes. Passaram a implementar tudo o que não havia na empresa, considerando segurança da informação. Desde sempre, tiveram o pensamento de engajar os colaboradores e contrataram o Alexandre da Rocha para o objetivo das certificações.

Foi informado que hoje há um comitê, mas não tão ativo quanto gostariam. Há reuniões de comitê em conjunto com as reuniões executivas da empresa, a cada 2 meses, com a elaboração de atas. Atualmente, a maioria dos documentos é aprovada pelo Wesley.

Há um budget específico para SI e privacidade, mas é um budget mínimo: conforme surgem necessidades, eles vão investindo.

Antes, saíam informações dos e-mails da Alta Direção, mas hoje, os comunicados saem pelo RH.

PONTO DE PREOCUPAÇÃO (PP) 01: Em que pese a participação ativa da Alta Direção, políticas e procedimentos recebidos não estão assinados e aprovados. A falta de evidências de aprovação pela Alta Direção é um problema grave, pois a norma exige que a Alta Direção demonstre liderança e compromisso com o sistema de gestão.

5.3.2 - Política

Não Conforme

Foi elaborada uma Política de Segurança da Informação e Privacidade, todavia, ela não elenca os objetivos de segurança da informação nem o comprometimento com a melhoria contínua do SGSI. A ausência de objetivos de segurança da informação e comprometimento com a melhoria contínua em uma política de segurança da informação durante uma auditoria interna de ISO 27001/2022 pode levantar preocupações significativas. Esses elementos são essenciais para a conformidade com os requisitos da norma e para a eficácia do SGSI. Sem objetivos definidos, a organização carece de um direcionamento estratégico claro para implementar controles, monitorar resultados e alinhar suas operações com as necessidades de segurança.

Ademais, a ausência de comprometimento formal com a melhoria contínua indica uma abordagem reativa à gestão da segurança da informação, em vez de uma abordagem proativa.

Também, na Política de Privacidade específica, não foram estabelecidos os Objetivos de Privacidade da organização, e a Política de Privacidade publicada no site está incorreta.

NC Menor 02: Os Objetivos de SI e Privacidade não foram detalhados, nem o comprometimento com a melhoria contínua. Logo, fica configurada uma NC Menor com relação ao requisito 5.3.2.

5.3.3 - Autoridades, responsabilidades e papéis organizacionais

Não Conforme

A Política de Segurança da Informação e de Privacidade não descrevem os papéis e responsabilidades com relação ao SGSI.

NC Menor 03: O controle exige que papéis e responsabilidades relacionados à segurança da informação e Privacidade sejam definidos e alocados de acordo com as necessidades da organização. Se a política de segurança não aborda as responsabilidades, pode haver lacunas na definição das responsabilidades de atores importantes, como gestores de sistemas, colaboradores ou fornecedores, comprometendo a eficácia na aplicação da segurança da informação. Em complemento, a ISO 27001/2022 e a 27701/2019 requerem que essas responsabilidades sejam comunicadas de forma clara. A ausência de designação abrangente de responsabilidades e autoridades pode levar a falhas operacionais, pois as partes envolvidas podem não saber o que se espera delas.

5.4 - Planejamento

5.4.1 - Ações para contemplar riscos e oportunidades

Conforme

Neste controle, foram considerados os dados evidenciados nos requisitos 5.2.1 e 5.2.2, quais sejam: Averiguou-se, que a organização determinou suas questões internas e externas no documento Gestão de Contexto. Com base no referido documento, as questões internas e externas foram definidas com bases nas respostas dos questionários, resultando em: Contexto Interno: Risco Baixo (36%); Contexto Externo: Risco Baixo (30%). Também, foram definidas as diretrizes de missão, valores e objetivo estratégico.

A organização estabeleceu o Procedimento de Análise de Riscos, no qual define seu processo de identificação, avaliação e tratamento de riscos para a segurança da informação. Os riscos são identificados e relacionados a informações, dados pessoais, hardwares e softwares. A organização classifica os riscos identificados em quatro níveis de vulnerabilidade e ameaça, resultando no cálculo do risco potencial através da fórmula $R = V * A$ (onde R é o risco, V é a vulnerabilidade e A é a ameaça).

Após a definição do risco potencial, realiza-se a análise do valor final do risco, ponderando quatro níveis de pontuação para frequência e severidade, resultando na fórmula $VF = R + (F * S)$ (onde VF é o valor final do risco, F é a frequência e S é a severidade). A organização determinou que atuará nos riscos com valores finais acima de 16 pontos, enquanto os riscos com valores abaixo de 16 pontos serão monitorados. Após a definição de ações para mitigação do risco, realiza-se uma nova análise do risco residual, utilizando a fórmula $RR = R + (F * S)$ (onde RR é o risco residual).

Em auditoria, foi informado que há um procedimento de análise de riscos e é utilizada uma planilha para análise e tratamento de riscos. Futuramente, as informações serão passadas para o sistema GLPI.

5.4.1.1 - Geral

Conforme

5.4.1.2 - Avaliação de riscos de segurança da informação

Oportunidade de Melhoria

A organização estabeleceu o Procedimento de Análise de Riscos, no qual define seu processo de identificação, avaliação e tratamento de riscos para a segurança da informação. Os riscos são identificados e relacionados a informações, dados pessoais, hardwares e softwares. A organização classifica os riscos identificados em quatro níveis de vulnerabilidade e ameaça, resultando no cálculo do risco potencial através da fórmula $R = V * A$ (onde R é o risco, V é a vulnerabilidade e A é a ameaça).

Após a definição do risco potencial, realiza-se a análise do valor final do risco, ponderando quatro níveis de pontuação para frequência e severidade, resultando na fórmula $VF = R + (F * S)$ (onde VF é o valor final do risco, F é a frequência e S é a severidade). A organização determinou que atuará nos riscos com valores finais acima de 16 pontos, enquanto os riscos com valores abaixo de 16 pontos serão monitorados. Após a definição de ações para mitigação do risco, realiza-se uma nova análise do risco residual, utilizando a fórmula $RR = R + (F * S)$ (onde RR é o risco residual).

Foram apresentados a planilha de Análise de Riscos, que demonstra os riscos considerados pela empresa, no que se refere à SI, bem como o Procedimento de Análise de Risco, que não faz menção à identificação dos proprietários dos riscos, que é um requisito da norma.

OM: Inserir no procedimento a necessidade de identificação dos proprietários dos riscos.

5.4.1.3 - Tratamento dos riscos de segurança da informação

Não Conforme

Na planilha de Análise de Risco foram evidenciadas ações necessárias na aba "Plano de Ação", todavia, o Procedimento de Análise de Riscos não faz menção à identificação dos proprietários dos riscos, o que é um requisito da norma. O procedimento não aborda a seleção de opções de tratamento de riscos, como evitar, mitigar, transferir ou aceitar os riscos. Ademais, não há informações sobre como o plano de tratamento de riscos é elaborado, aprovado e implementado.

Foi informado, em auditoria, que foi feita a comparação dos riscos existentes, com o que clientes apresentam, a título de melhoria contínua (comprovação demonstrada em auditoria). Além disso, foram implementando conforme as orientações da Templum.

O objetivo é trazer toda a parte de análises e tratamento de riscos para a ferramenta GLPI. Por ora, há a planilha em excel atualizada.

Por fim, a organização evidenciou a Declaração de Aplicabilidade, na qual informa como atende os controles estabelecidos pelos requisitos normativos para redução dos riscos, contudo, considerou de forma inadequada a não aplicabilidade de alguns controles referentes aos ANEXOS A e B da ISO 27701:2019.

NC Menor 04: Na Declaração de Aplicabilidade apresentada, a organização considerou, de forma inadequada, a não aplicabilidade de alguns controles referentes aos ANEXOS A e B da ISO 27701:2019, contrariando os requisitos 6.1.3 b) e d) da ISO-IEC 27001:2022.

NC Menor 05: Não foi elaborado um plano de tratamento de riscos, conforme abordado na norma.

5.4.2 - Objetivos de segurança da informação e planejamento para alcançá-los

Não Conforme

NC Maior 01: Os Objetivos de SI e de Privacidade não foram elencados na Política de Segurança e Privacidade, configurando, dessa forma, uma NC Maior com relação ao requisito 5.4.2.

Fotos

PLANEJAMENTO

5.5 - Apoio

5.5.1- Recursos

Conforme

Foi informado, em auditoria, que o colaborador Alexandre da Rocha foi contratado por conta das certificações. Tiveram investimentos em storage, em ferramentas como Bitdefender e o Fortigate e a empresa usa também ferramentas opensource, como linux, por exemplo. Ainda, atualizaram os servidores por questão de privacidade e segurança. Hoje, todo o parque está dentro do Equinix.

Em conversa com Thaiz, responsável pelo financeiro, foi informado que ela está a frente de todo o processo financeiro, mas conta com o auxílio de uma empresa terceirizada (GGP) na contabilidade e no dia a dia de fluxo de caixa, contas a pagar etc. Todo final de ano, é analisado tudo o que foi provisionado, se as contas foram pagas de forma correta e provisionam o ano seguinte. Foi informado que foi disponibilizado 5% (para 2025) do budget da empresa para as certificações.

Ainda, a GGP tem uma plataforma própria, na qual a ALWAYS ON insere as informações e dados pessoais dos colaboradores. A GGP realiza atividades financeiras e de departamento pessoal.

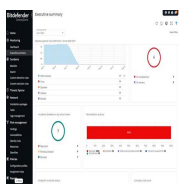


Foto 1

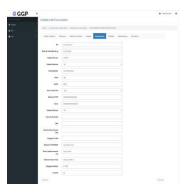


Foto 2

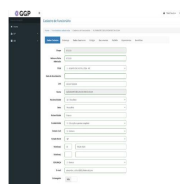


Foto 3

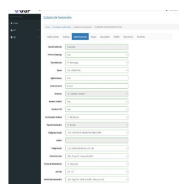


Foto 4

5.5.2 -Competência

Não Conforme

Durante a entrevista, foi constatado que há um documento que tem as competências pré-definidas, um cronograma de treinamentos obrigatórios e um formulário para avaliador, que é utilizado durante as entrevistas dos candidatos. Os referidos documentos ficam armazenados no Google Drive. Foi verificado o diploma do colaborador Henrique Barros de Oliveira, analista programador de back end. Em auditoria, foi constatado que o referido funcionário não recebeu os treinamentos obrigatórios com relação ao cargo dele.

Também, foi averiguado que a empresa não nomeou, formalmente, um Encarregado pelo Tratamento de Dados Pessoais.

Hoje, há o portal Greg, utilizando pelo RH para armazenamento de avaliações de competências, treinamentos e comunicações com os colaboradores.

NC Menor 06: Apesar da existência de um documento com competências pré-definidas, um cronograma de treinamentos obrigatórios e um formulário de avaliação, a auditoria constatou que o colaborador Henrique Barros de Oliveira, analista programador de back-end, não recebeu os treinamentos obrigatórios exigidos para seu cargo, demonstrando uma falha na implementação do processo de capacitação, comprometendo a eficácia das medidas de segurança da informação. O armazenamento dos documentos no Google Drive e a utilização do portal Greg pelo RH não garantem, por si só, que as competências necessárias foram efetivamente adquiridas e aplicadas. Ainda, a ausência de nomeação formal de um Encarregado pelo Tratamento de Dados Pessoais (DPO) configura uma não conformidade, especialmente considerando a importância desse papel na conformidade com normas de proteção de dados, como a LGPD e a ISO 27701. A falta de um responsável formalmente designado para gerenciar a proteção de dados pessoais pode levar a lacunas na governança da segurança da informação e no cumprimento das obrigações legais e

normativas.

5.5.3 - Conscientização

Não Conforme

Hoje, sempre que um novo colaborador inicia, há o onboarding que trata de SI, mas não de privacidade. Ainda, há uma reunião e o colaborador é encaminhado para acessar a plataforma Greg.

Em auditoria, foram verificados o NDA e o aditivo de home office do colaborador Henrique Barros de Oliveira. Ele recebeu um treinamento de SI, mas em auditoria, foi constatado que o referido funcionário não recebeu os treinamentos obrigatórios (elencados na planilha do RH) com relação ao cargo dele.

Durante a entrevista, foi averiguado que a empresa faz treinamentos específicos para os colaboradores, bem como avaliações de desempenho, contudo, não há um cronograma com treinamentos de SI e privacidade. Em adição, foi constatado que há treinamentos de SI, todavia, não foram realizados treinamentos voltados à privacidade.

Outro ponto importante é que as políticas de segurança da informação e privacidade não estão localizadas em ponto de fácil acesso dos colaboradores. Foi informado pelo Diretor Wesley Ruiz que a PSI se encontra no Google Drive da empresa, porém, durante a auditoria, o documento não foi localizado.

NC Maior 02: A situação descrita caracteriza uma não conformidade maior, pois o requisito é obrigatório, e a organização não está garantindo a plena implementação desse requisito. A ausência de um cronograma formalizado de treinamentos e a falta de treinamentos sobre privacidade indicam que a organização não está assegurando que seus colaboradores estejam devidamente conscientizados, podendo comprometer a eficácia do SGSIP. Também, o colaborador Henrique de Oliveira não recebeu os treinamentos obrigatórios relacionados ao seu cargo. Ademais, a indisponibilidade da PSI em um local de fácil acesso reforça a gravidade da não conformidade. Se os colaboradores não conseguem acessar esse documento essencial, há um risco significativo de descumprimento dos controles de segurança, impactando a governança do SGSIP. Como resultado, essa falha representa um desvio sistêmico, o que justifica sua classificação como não conformidade maior. Para corrigir essa situação, a organização deve implementar um plano de ação corretiva que inclua a formalização de treinamentos contínuos, a inclusão da privacidade nos programas de conscientização e a garantia de que as políticas estejam acessíveis a todos os colaboradores.

5.5.4 - Comunicação

Preocupação

O tema é tratado no Procedimento de Comunicação Interna e Externa, mas há orientações no documento que são diferentes do que tem sido feito na prática.

No que tange à comunicação são utilizados: Slack, e-mail (Gmail), workspace do Google. Dependendo do cliente, utilizam as ferramentas utilizadas por eles. Utilizam Whatsapp para alguns casos mais informais. Ainda, usam o Asana para projetos.

Em auditoria, foi dito que políticas e procedimentos ficam no Workspace, todavia, as políticas de segurança da informação e privacidade não estão localizadas em ponto de fácil acesso dos colaboradores. Foi informado pelo Diretor Wesley Ruiz que a PSI se encontra no Google Drive da empresa, porém, durante a auditoria, o documento não foi localizado.

A ideia é usar o GLPI como principal canal de comunicação com relação à infraestrutura. Utilizam, também, o GregHub, um portal do RH, onde constam resultados de avaliação dos funcionários e comunicações para os colaboradores. No caso de incidentes, utilizam a ferramenta GLPI.

PP 03: Durante a auditoria, foi informado que a PSI está disponível no Google Drive, porém, o documento não foi localizado, evidenciando uma falha no controle e na disseminação dessas diretrizes, indicando que a comunicação de informações essenciais para a segurança da informação não está sendo realizada de forma eficaz, comprometendo a conformidade com o requisito. A organização deve garantir que as políticas e procedimentos sejam facilmente acessíveis a todos os colaboradores e devidamente comunicados, além de revisar e alinhar as práticas reais com as diretrizes documentadas, minimizando riscos operacionais e de conformidade. Ainda, a divergência entre o que está formalizado no procedimento e o que ocorre na prática compromete a eficácia do SGSI, pois gera insegurança na comunicação, dificuldade no acesso a informações essenciais e possíveis riscos de violações de dados pessoais ou falhas na resposta a incidentes. Para garantir a conformidade, a organização deve revisar seu procedimento, alinhar suas práticas reais com o que está documentado e garantir que todas as diretrizes sejam devidamente implementadas e seguidas pelos colaboradores.

5.5.5 - Informação documentada

Não Conforme

Foi constatado que há uma planilha nomeada "FO Controle da Informação Documentada", na qual concentra os documentos e informações como localização, formato, meio acesso etc. Ainda, há a elaboração de políticas e procedimentos que dão base para o sistema de gestão, todavia, tais documentos recebidos em auditoria vieram em formato Word e sem assinaturas.

NC Maior 03: Os documentos do SGSI vieram em Word e sem aprovação formal, contrariando os requisitos 5.5.5.2 e 5.5.5.3 da ISO 27701/2019.

5.5.5.1 - Geral

Foi constatado que há uma planilha nomeada "FO Controle da Informação Documentada", na qual concentra os documentos e informações como localização, formato, meio acesso etc. Ainda, há a elaboração de políticas e procedimentos que dão base para o sistema de gestão, todavia, tais documentos recebidos em auditoria vieram em formato Word e sem assinaturas.

NC Maior 03: Os documentos do SGSI vieram em Word e sem aprovação formal, contrariando os requisitos 5.5.5.2 e 5.5.5.3 da ISO 27701/2019.

5.5.5.2 - Criando e atualizando

Não Conforme

Foi constatado que há uma planilha nomeada "FO Controle da Informação Documentada", na qual concentra os documentos e informações como localização, formato, meio acesso etc. Ainda, há a elaboração de políticas e procedimentos que dão base para o sistema de gestão, todavia, tais documentos recebidos em auditoria vieram em formato Word e sem assinaturas.

NC Maior 03: Os documentos do SGSI vieram em Word e sem aprovação formal, contrariando os requisitos 5.5.5.2 e 5.5.5.3 da ISO 27701/2019.

5.5.5.3 - Controle da informação documentada

Não Conforme

Foi constatado que há uma planilha nomeada "FO Controle da Informação Documentada", na qual concentra os documentos e informações como localização, formato, meio acesso etc. Ainda, há a elaboração de políticas e procedimentos que dão base para o sistema de gestão, todavia, tais documentos recebidos em auditoria vieram em formato Word e sem assinaturas.

NC Maior 03: Os documentos do SGSI vieram em Word e sem aprovação formal, contrariando os requisitos 5.5.5.2 e 5.5.5.3 da ISO 27701/2019.

Fotos

OPERAÇÃO

5.6 - Operação

5.6.1 - Planejamento e controle operacional

Não Conforme

A organização demonstra planejamento e implementação de controle através de políticas e procedimentos evidenciados em entrevista, da utilização de ferramentas de SI e de mapeamento de processos organizacionais (planilha Análise de Riscos). Todavia, não foram evidenciadas análises críticas de mudanças não intencionais.

NC Menor 07: A ausência de análises críticas para lidar com mudanças não intencionais nos processos e sistemas, pode gerar desvios nos controles implementados e vulnerabilidades não detectadas. Embora a empresa demonstre esforços no planejamento e controle por meio de políticas, procedimentos e ferramentas como a planilha de análise de riscos, a falta de um processo formal para identificar e avaliar mudanças imprevistas compromete a capacidade da organização de manter a eficácia dos controles de segurança. Essa lacuna pode resultar em impactos negativos na confidencialidade, integridade e disponibilidade das informações, especialmente em situações de mudanças inesperadas nos processos

organizacionais ou no ambiente tecnológico.

5.6.2 - Avaliação de riscos de segurança da informação

Preocupação

Foi informado, em auditoria, que a cada 6, 8 meses, são feitas análises de riscos.

Foram apresentados o Procedimento de Análise de Risco e a planilha de Análise de risco. Na planilha de Análise de Risco, foram evidenciadas ações necessárias na aba "Plano de Ação", todavia, o Procedimento de Análise de Riscos não faz menção à identificação dos proprietários dos riscos, o que é um requisito da norma. O procedimento não aborda a seleção de opções de tratamento de riscos, como evitar, mitigar, transferir ou aceitar os riscos. Ademais, não há informações sobre como o plano de tratamento de riscos é elaborado, aprovado e implementado.

PP 04: Há a necessidade do fortalecimento do processo de avaliação de riscos, realizando a revisão dos documentos, a ampliação da compreensão interna sobre os critérios de aceitação de riscos, e a revisão da Declaração de Aplicabilidade, a fim de assegurar conformidade com os requisitos normativos. Essas ações visam aumentar a clareza, consistência e alinhamento do processo com as melhores práticas de gestão de riscos.

5.6.3 - Tratamento de riscos de segurança da informação

Preocupação

Foi informado, em auditoria, que a cada 6, 8 meses, são feitas análises de riscos.

Foram apresentados o Procedimento de Análise de Risco e a planilha de Análise de risco. Na planilha de Análise de Risco, foram evidenciadas ações necessárias na aba "Plano de Ação", todavia, o Procedimento de Análise de Riscos não faz menção à identificação dos proprietários dos riscos, o que é um requisito da norma. O procedimento não aborda a seleção de opções de tratamento de riscos, como evitar, mitigar, transferir ou aceitar os riscos. Ademais, não há informações sobre como o plano de tratamento de riscos é elaborado, aprovado e implementado.

PP 05: Há a necessidade do fortalecimento do processo de avaliação de riscos, realizando a revisão dos documentos, a ampliação da compreensão interna sobre os critérios de aceitação de riscos, e a revisão da Declaração de Aplicabilidade, a fim de assegurar conformidade com os requisitos normativos. Essas ações visam aumentar a clareza, consistência e alinhamento do processo com as melhores práticas de gestão de riscos.

Fotos

CHECAR

5.7 - Avaliação de desempenho

5.7.1 - Monitoramento, medição, análise e avaliação

Não Conforme

A organização implementou uma série de controles de monitoramento, medição e análise de seu sistema de gestão conforme descrito nos controles do anexo A, auditados neste processo. Alguns exemplos evidenciados: uso de antivírus BitDefender, e o uso das ferramentas Fortinet, Cockpit (monitoramento de servidores e logs), Zabbix e GLPI.

A organização implementou o seu SGSI recentemente e está em fase de medição destes e outros índices que devem ser reportados em sua análise crítica da direção.

NC Menor 08: Em que pese a organização utilizar ferramentas de monitoramento, ela não definiu um planejamento de monitoramento, medição e análise conforme estabelece o Requisito: 9.1 Monitoramento, medição e análise: A organização deve determinar: a) o que precisa ser monitorado e medido, incluindo processos e controles da segurança da informação; b) os métodos para monitoramento, medição, análise e avaliação, conforme aplicável, para assegurar resultados válidos. Convém que os métodos selecionados produzam resultados comparáveis e reproduzíveis para serem considerados válidos; c) quando o monitoramento e a medição devem ser realizados; d) quem deve monitorar e medir; e) quando os resultados do monitoramento e da medição devem ser analisados e avaliados; f) quem deve analisar e avaliar estes resultados. Informação documentada deve ser disponibilizada como evidência dos resultados.

A organização deve avaliar o desempenho da segurança da informação e a eficácia do sistema de gestão da segurança da informação.

5.7.2 - Auditoria interna

Preocupação

Foi evidenciado que o tema foi tratado no Procedimento de Auditoria Interna, porém, há informação errada (item 5.2 Plataforma Evolutto). Embora o procedimento apresente elementos relevantes, como planejamento, execução e elaboração de relatórios de auditoria, ele não aborda de maneira clara e estruturada todos os requisitos específicos da seção 9.2 da ISO 27001/2022, como critérios detalhados de auditoria, frequência baseada em risco e uma abordagem sistemática para avaliar a eficácia contínua do SGSI. Em complemento, não há uma explicação clara sobre como os critérios de auditoria são estabelecidos para assegurar que cubram todos os requisitos normativos e organizacionais.

Este é o primeiro processo de auditoria da organização, servindo também de primeira evidência do processo de auditoria.

PP 06: É fundamental revisar o procedimento para incluir os elementos faltantes mencionados e garantir o atendimento a todos os requisitos da seção 5.7.2 da ISO 27701/2019, bem como esclarecer o objetivo da auditoria interna, focando na conformidade com a norma e com os requisitos da organização.

5.7.3 - Análise crítica pela Direção

Preocupação

Foi apresentado o documento "Ata de Análise Crítica", todavia, há alguns pontos a serem observados:

- 1) Mudanças nas necessidades e expectativas das partes interessadas - Parcialmente atendido: A ata menciona feedback de clientes e partes interessadas, mas não detalha as mudanças em suas necessidades e expectativas;
- 2) Feedback sobre o desempenho da segurança da informação - Parcialmente atendido: A ata cita a "Satisfação de Clientes" e "Partes Interessadas", mas não especifica métricas claras sobre não conformidades, monitoramento, auditorias ou cumprimento de objetivos de segurança;
- 3) Resultados da avaliação de riscos e plano de tratamento de riscos - Não atendido: A ata menciona "Riscos e Oportunidades", mas não apresenta detalhes sobre avaliações de riscos nem planos de tratamento. Ainda, a referida ata foi apresentada em formato word e sem assinatura.

PP 07: Ata cobre grande parte dos requisitos da norma, mas precisa de ajustes para estar 100% em conformidade. As principais ações recomendadas incluem:

- Incluir mais detalhes sobre mudanças nas expectativas das partes interessadas, com exemplos concretos de como essas mudanças impactam o SGSI;
- Expandir a seção de desempenho da segurança da informação, detalhando detalhes de não conformidades, monitoramento, auditorias e objetivos de segurança;
- Adicionar um resumo da avaliação de riscos realizada e a situação do plano de tratamento de riscos, demonstrando as medidas tomadas e o status atual;
- Apresentar o documento em arquivo protegido e assinado.

Fotos

MELHORIA

5.8 - Melhoria

5.8.1 - Não conformidade e ação corretiva

Não Conforme

Foi averiguado que o tema em tela é mencionado no Procedimento de Saídas Não Conforme e Ação Corretiva, mas tal procedimento é focado no Sistema de Gestão da Qualidade (SGQ) e em aspectos operacionais, como não conformidades de materiais e serviços, mas não considera explicitamente as não conformidades no contexto do Sistema de Gestão da Segurança da Informação (SGSI).

O procedimento não estabelece uma relação clara com a mitigação de riscos de segurança da informação ou melhoria contínua da segurança. A definição de "saídas não conformes" está limitada a produtos e serviços, não abordando de forma abrangente situações de não conformidade relacionadas a processos, políticas ou controles específicos de segurança da informação.

Em auditoria, foi explicado que hoje há ferramentas de monitoramento, mas não há elaboração de relatórios de não conformidades.

NC Maior 04: Não foram evidenciadas ações para controle e correções de não conformidades, nem análises críticas das não conformidades e da eficácia de ações corretivas, contrariando o que estabelece o requisito 5.8.1.

5.8.2 - Melhoria contínua

Conforme

Considerando que é o primeiro processo de auditoria, a organização planeja a melhora contínua do SGSIP por meio de elaboração de políticas e procedimento, utilização de ferramentas de antivírus, firewall, dentre outras, contudo, foram identificadas não conformidades (já registradas) acerca da falta dos objetivos de SI e de ações para controle e correções de não conformidades.

Por fim, a própria implementação de um sistema de gestão e a busca pela certificação com critérios internacionais é por si só um ato de melhoria contínua.

Fotos

6 - Diretrizes específicas de SGPI relacionadas à ABNT NBR ISO/IEC 27002

6.1 - Geral

6.2 - Políticas de segurança da informação

6.2.1 - Orientação da Direção para segurança da informação

Preocupação

A Alta Direção demonstrou seu compromisso, especialmente com a participação ativa dos diretores. Durante a entrevista, foi verificado o envolvimento de representantes da alta direção nas iniciativas do Sistema de Gestão de Segurança da Informação e Privacidade da empresa.

PP 08: Em que pese a participação ativa da Alta Direção, políticas e procedimentos recebidos não estão assinados pela Alta Direção. A falta de evidências de aprovação pela Alta Direção é um problema grave, pois a norma exige que a Alta Direção demonstre liderança e compromisso com o sistema de gestão.

6.2.1.1 - Políticas para segurança da informação

Não Conforme

Foi verificada a existência de uma Política de Segurança da Informação, aprovada em 04/02/2025, no entanto ela não descreve os objetivos de SI e não está assinada (o documento foi enviado em word). Ainda, a Política de Privacidade que consta no site da empresa não é a Política de Privacidade apresentada em auditoria, e não está assinada (o documento foi enviado em word).

NC Menor 09: A Política de Segurança da Informação (PSI) não descreve os objetivos de segurança da informação, o que contraria a cláusula 5.2, que exige que a política seja coerente com os objetivos organizacionais e de SI. O envio em word e a falta de assinatura pela Alta Direção é um problema grave, pois a norma exige que a Alta Direção demonstre liderança e compromisso com a segurança da informação. No que tange à Política de Privacidade, a ausência de uma versão única, válida e assinada pode comprometer a credibilidade da organização, gerar insegurança jurídica e dificultar a aplicação das diretrizes de proteção de dados.

6.2.1.2 - Análise crítica das políticas para segurança da informação

Não Conforme

NC Menor 09: A Política de Segurança da Informação (PSI) não descreve os objetivos de segurança da informação, o que contraria a cláusula 5.2, que exige que a política seja coerente com os objetivos organizacionais e de SI. O envio em word e a falta de assinatura pela Alta Direção é um problema grave, pois a norma exige que a Alta Direção demonstre liderança e compromisso com a segurança da informação. No que tange à Política de Privacidade, a ausência de uma versão única, válida e assinada pode comprometer a

credibilidade da organização, gerar insegurança jurídica e dificultar a aplicação das diretrizes de proteção de dados.

6.3 - Organização da segurança da informação

6.3.1 - Organização interna

Não Conforme

A Política de Segurança da Informação não descreve os papéis e responsabilidades com relação ao SGSIP.

NC Menor 10: O controle exige que papéis e responsabilidades relacionados à segurança da informação sejam definidos e alocados de acordo com as necessidades da organização. Se a política de segurança não aborda as responsabilidades, pode haver lacunas na definição das responsabilidades de atores importantes, como gestores de sistemas, colaboradores ou fornecedores, comprometendo a eficácia na aplicação da segurança da informação. Em complemento, a ISO 27001/2022 requer que essas responsabilidades sejam comunicadas de forma clara. A ausência de designação abrangente de responsabilidades e autoridades pode levar a falhas operacionais, pois as partes envolvidas podem não saber o que se espera delas.

6.3.1.1 - Responsabilidades e papéis da segurança da informação

Não Conforme

A Política de Segurança da Informação não descreve os papéis e responsabilidades com relação ao SGSIP.

NC Menor 10: O controle exige que papéis e responsabilidades relacionados à segurança da informação sejam definidos e alocados de acordo com as necessidades da organização. Se a política de segurança não aborda as responsabilidades, pode haver lacunas na definição das responsabilidades de atores importantes, como gestores de sistemas, colaboradores ou fornecedores, comprometendo a eficácia na aplicação da segurança da informação. Em complemento, a ISO 27001/2022 requer que essas responsabilidades sejam comunicadas de forma clara. A ausência de designação abrangente de responsabilidades e autoridades pode levar a falhas operacionais, pois as partes envolvidas podem não saber o que se espera delas.

6.3.1.2 - Segregação de funções

Não Conforme

NC Menor 11: Em entrevista foi informado que, atualmente, a organização não faz segregação de funções, contrariando o que estabelece o controle 6.3.1.2 da norma.

6.3.1.3 - Contato com autoridades

Não Conforme

Dentro do Procedimento de Preparação e Resposta à Emergências, há uma lista com as autoridades, telefones e os contatos, que foi evidenciada em entrevista. Foi constatado, em auditoria, que a organização ainda não fez o cadastro na ANPD para relatos de ocorrências de violações de dados pessoais.

NC Menor 12: A organização demonstra um esforço inicial ao manter uma lista de contatos com autoridades no procedimento de preparação e resposta a emergências, o que está alinhado ao requisito de manter comunicação com autoridades relevantes. No entanto, a ausência do cadastro na ANPD indica falha crítica de conformidade com a LGPD, especialmente no que diz respeito à pronta comunicação de incidentes envolvendo dados pessoais. Essa lacuna não apenas compromete o cumprimento do controle 6.3.1.3, mas também expõe a organização a sanções legais e riscos reputacionais.

OM 03: Criar uma lista, identificando as autoridades relevantes para a organização e designar um ponto de contato para a comunicação com as autoridades.

6.3.1.4 - Contato com grupos especiais

Oportunidade de Melhoria

Em entrevista, foi verificado que a organização costuma receber newsletters sobre segurança da informação. Foi demonstrado o e-mail recebido da Fortigate.

OM 04: É importante identificar os grupos de interesse especial relevantes para a organização e fazer cadastro em grupos de discussão e participar de eventos, a fim de se manter atualizada sobre assuntos pertinentes à segurança da informação e privacidade.

6.3.1.5 - Segurança da informação no gerenciamento de projetos

Conforme

Todos os projetos estão no ambiente da Always, havendo reuniões frequentes para tratar sobre eles. O Alexandre responde por toda a parte de segurança da informação de todos os projetos. Em auditoria, foi verificada a ferramenta Confluence, mostrando medidas de segurança na realização dos projetos.

6.3.2 - Dispositivos móveis e trabalho remoto

6.3.2.1 - Política para o uso de dispositivo móvel

Conforme

O inventário de ativos está todo dentro do GLPI, considerando computadores, monitores etc. São utilizadas as ferramentas Bitdefender, Fortigate, Bitlocker e AD. Ainda, foi informado que todos os dispositivos são criptografados, e alguns colaboradores utilizam VPN.

Hoje, há uma lista de chaves criptográficas no google drive, que está sendo transferida para o GLPI.

6.3.2.2 - Trabalho remoto

Preocupação

O tema é tratado no Guia de Trabalho Remoto, contudo, o documento não trata sobre os temas SI e privacidade. Também, foram evidenciadas em entrevista as configurações de VPN e MFA. E os notebooks estão criptografados (Bitlocker).

PP 15: Em que pese existam algumas medidas técnicas de segurança implementadas, como configurações de VPN, autenticação multifator (MFA) e criptografia de notebooks via Bitlocker, o Guia de Trabalho Remoto não aborda os temas de segurança da informação (SI) e privacidade, indicando que a organização pode não estar garantindo que os colaboradores compreendam os riscos e boas práticas ao trabalhar remotamente, podendo gerar falhas operacionais e potenciais incidentes de segurança e violações de dados pessoais.

6.4 - Segurança em recursos humanos

6.4.1 - Antes da contratação

Não Conforme

NC Menor 17: Foi apresentada a verificação de antecedentes do colaborador Rafael Chagas Palermo, Analista CRM Pleno (tem acesso ao banco de dados do cliente, como dados de comportamentos de compra, por exemplo), alocado na Renner. Ocorre que, não foi verificada justificativa, eis que tal função lida com dados para marketing. Ainda, o Procedimento de Recursos Humanos não menciona a possibilidade de verificação de antecedentes na empresa.

6.4.1.1 - Seleção

Não Conforme

NC Menor 17: Foi apresentada a verificação de antecedentes do colaborador Rafael Chagas Palermo, Analista CRM Pleno (tem acesso ao banco de dados do cliente, como dados de comportamentos de compra, por exemplo), alocado na Renner. Ocorre que, não foi verificada justificativa, eis que tal função lida com dados para marketing. Ainda, o Procedimento de Recursos Humanos não menciona a possibilidade de verificação de antecedentes na empresa.

6.4.1.2 - Termos e condições de contratação

Não Conforme

NC Menor 18: Foi solicitado, em entrevista, o contrato de trabalho do colaborador Henrique de Oliveira, todavia, foi constatado que existe apenas o instrumento contratual de experiência. Após o colaborador passar na experiência, não foi elaborado um novo instrumento contratual. Não foram verificadas cláusulas de SI, de privacidade, de compliance nem de propriedade intelectual. A falta de atualização do contrato para refletir essas novas responsabilidades configura uma não conformidade com esse controle. Ainda, a não formalização da alteração no contrato de trabalho pode gerar risco de passivo trabalhista, e não conformidade com a LGPD e a ISO 27001/2022.

6.4.2 - Durante a contratação

Conforme

Em auditoria, foi verificado que a organização fez aditivos aos contratos de trabalho, incluindo confidencialidade e cláusulas de proteção de dados pessoais.

6.4.2.1 - Responsabilidades da Direção

Preocupação

A Alta Direção demonstrou seu compromisso, especialmente com a participação ativa dos diretores. Durante a entrevista, foi verificado o envolvimento de representantes da alta direção nas iniciativas do Sistema de Gestão de Segurança da Informação e Privacidade da empresa.

PP 08: Em que pese a participação ativa da Alta Direção, políticas e procedimentos recebidos não estão assinados pela Alta Direção. A falta de evidências de aprovação pela Alta Direção é um problema grave, pois a norma exige que a Alta Direção demonstre liderança e compromisso com o sistema de gestão.

6.4.2.2 - Conscientização, educação e treinamento em segurança da informação

Preocupação

Em auditoria, foi verificado que a empresa faz treinamentos específicos para os colaboradores, bem como avaliações de desempenho, todavia, não há um cronograma com treinamentos de SI e privacidade e proteção de dados pessoais. Ainda, foi constatado que há treinamentos de SI, todavia, não foram realizados treinamentos voltados à privacidade. Outro ponto importante é que as políticas de segurança da informação e privacidade não estão localizadas em ponto de fácil acesso dos colaboradores. Foi informado pelo Diretor Wesley Ruiz que a PSI se encontra no Google Drive, todavia, durante a auditoria, o documento não foi localizado.

PP 14: A situação descrita representa uma não conformidade, pois a organização não garante a realização de treinamentos regulares e abrangentes que incluam segurança da informação e privacidade. A ausência de um cronograma formalizado de treinamentos compromete a continuidade da conscientização e capacitação dos colaboradores, tornando a organização vulnerável a falhas humanas e potenciais incidentes de segurança. Embora existam treinamentos de segurança da informação, a falta de treinamentos específicos sobre privacidade indica uma deficiência no atendimento às exigências da norma, especialmente considerando as obrigações legais da LGPD. Em complemento, a falta de acesso facilitado à Política de Segurança da Informação (PSI) representa um risco operacional e de conformidade. Se os colaboradores não têm acesso imediato às políticas de segurança e privacidade, há um risco significativo de descumprimento das diretrizes do SGSIP, o que pode comprometer a governança da segurança da informação. A alegação de que a PSI está armazenada no Google Drive, mas não foi localizada durante a auditoria, reforça que a organização não assegura a disponibilidade das políticas para os colaboradores.

6.4.2.3 - Procedimentos disciplinares

Não Conforme

NC Menor 19: Foi evidenciado que a organização ainda não possui diretrizes estabelecidas, nem processos definidos e implementados para a realização de processos disciplinares, quando necessário.

6.4.3 - Encerramento e mudança da contratação

Conforme

Em auditoria, foi verificado o desligamento do ex-colaborador Hélio Marcelus Honorio Carlos, analista programador. Foram apresentados o e-mail de desligamento e a revogação dos acessos.

6.4.3.1 - Responsabilidades pelo encerramento ou mudança da contratação

Conforme

Em auditoria, foi verificado o desligamento do ex-colaborador Hélio Marcelus Honorio Carlos, analista programador. Foram apresentados o e-mail de desligamento e a revogação dos acessos.

6.5 - Gestão de ativos

6.5.1 - Responsabilidade pelos ativos

Conforme

O inventário de ativos está no GLPI, demonstrando 63 máquinas, sendo feitos controles de hardwares e softwares. O sistema mostra cada máquina associada à um usuário específico, com detalhes como fabricantes, modelos, números de série e a data do último inventário. Foi demonstrada a máquina da

colaboradora Giovana Victória Marques. Esses dados são cruciais para auditorias e controle de ativos, fornecendo visibilidade sobre o estado dos equipamentos em uso na organização.

6.5.1.1 - Inventário dos ativos

Conforme

O inventário de ativos está no GLPI, demonstrando 63 máquinas, sendo feitos controles de hardwares e softwares. O sistema mostra cada máquina associada a um usuário específico, com detalhes como fabricantes, modelos, números de série e a data do último inventário. Foi demonstrada a máquina da colaboradora Giovana Victória Marques. Esses dados são cruciais para auditorias e controle de ativos, fornecendo visibilidade sobre o estado dos equipamentos em uso na organização.

6.5.1.2 - Proprietário dos ativos

Conforme

O inventário de ativos está no GLPI, demonstrando 63 máquinas, sendo feitos controles de hardwares e softwares. O sistema mostra cada máquina associada a um usuário específico, com detalhes como fabricantes, modelos, números de série e a data do último inventário. Foi demonstrada a máquina da colaboradora Giovana Victória Marques. Esses dados são cruciais para auditorias e controle de ativos, fornecendo visibilidade sobre o estado dos equipamentos em uso na organização.

6.5.1.3 - Uso aceitável dos ativos

Conforme

O tema é tratado no Procedimento de Infra Geral. A organização estabeleceu os cuidados e usos aceitáveis de seus ativos por meio de treinamentos e documentos. Alguns desses instrumentos são: Treinamento de Segurança da Informação, Política de Tela e Mesa Limpa, Guia de Trabalho Remoto e Formulário de Autorização para Uso Externo de Equipamentos (em entrevista foi apresentado o formulário do colaborador Pedro Pereira).

6.5.1.4 - Devolução de ativos

Oportunidade de Melhoria

O tema é tratado no Procedimento de Infra Geral. Quando da saída da empresa, o colaborador recebe um e-mail da área de SI, solicitando a devolução do equipamento. Toda a tratativa é feita por e-mail e não há um termo de devolução de equipamentos.

OM 05: Elaborar um termo de devolução de equipamentos, com informações dos equipamentos e a assinatura do colaborador.

6.5.2 - Classificação da informação

Conforme

A organização estabeleceu o Procedimento Classificação e Rotulagem de Informações e Dados Pessoais, aprovado em 02/01/2025, que estabelece classificações das informações tais como:

1. Informação Pública

A informação deve ser classificada como pública quando ela puder ser divulgada a todos, isto é, funcionários, terceirizados, clientes, fornecedores e público em geral, sem que isso provoque impactos no negócio, por exemplo: Manual de Fornecedores;

2. Informação Interna

A informação deve ser classificada como interna quando não for desejável que ela se torne conhecida por pessoas de fora da organização, por exemplo: Procedimentos Internos;

3. Informação Restrita

A informação deve ser classificada como restrita quando acessos não autorizados a ela, mesmo que por membros da própria organização, sejam capazes de trazer sérios danos ao negócio, por exemplo: Plano de Negócios;

4. Informação Confidencial

A informação deve ser classificada como confidencial quando sua exposição fora do ambiente da organização possa acarretar perdas financeiras, de imagem, de competitividade, por exemplo: Fórmula/Composição de um Produto.

Ainda, é possível verificar classificação e rotulagem nos rodapés dos documentos, tais como em políticas e procedimentos, bem como nos e-mails do Gmail.

6.5.2.1 - Classificação da informação

Conforme

A organização estabeleceu o Procedimento Classificação e Rotulagem de Informações e Dados Pessoais, aprovado em 02/01/2025, que estabelece classificações das informações tais como:

1. Informação Pública

A informação deve ser classificada como pública quando ela puder ser divulgada a todos, isto é, funcionários, terceirizados, clientes, fornecedores e público em geral, sem que isso provoque impactos no negócio, por exemplo: Manual de Fornecedores;

2. Informação Interna

A informação deve ser classificada como interna quando não for desejável que ela se torne conhecida por pessoas de fora da organização, por exemplo: Procedimentos Internos;

3. Informação Restrita

A informação deve ser classificada como restrita quando acessos não autorizados a ela, mesmo que por membros da própria organização, sejam capazes de trazer sérios danos ao negócio, por exemplo: Plano de Negócios;

4. Informação Confidencial

A informação deve ser classificada como confidencial quando sua exposição fora do ambiente da organização possa acarretar perdas financeiras, de imagem, de competitividade, por exemplo: Fórmula/Composição de um Produto.

Ainda, é possível verificar classificação e rotulagem nos rodapés dos documentos, tais como em políticas e procedimentos, bem como nos e-mails do Gmail.

6.5.2.2 - Rótulos e tratamento da informação

Conforme

A organização estabeleceu o Procedimento Classificação e Rotulagem de Informações e Dados Pessoais, aprovado em 02/01/2025, que estabelece possibilidade de rótulos das informações, tais como:

Os níveis de confidencialidade são rotulados da seguinte maneira:

- Documento em papel: o nível de confidencialidade é indicado de uma forma destacada em todas as páginas do documento; ele também é indicado na capa ou no envelope que contém um documento ou na pasta de armazenamento em que o documento é armazenado
- Documento eletrônico: o nível de confidencialidade é indicado de uma forma destacada em todas as páginas do documento
- Informação transmitida oralmente: o nível de confidencialidade das informações confidenciais a serem transmitidas pessoalmente, por telefone ou por outros meios de comunicações deve ser comunicado antes das informações em si.

Ainda, é possível verificar classificação e rotulagem nos rodapés dos documentos, tais como em políticas e procedimentos, bem como nos e-mails do Gmail.

6.5.2.3 - Tratamento dos ativos

Conforme

O tema é tratado no Procedimento de Infra Geral. A organização estabeleceu os cuidados e usos aceitáveis de seus ativos por meio de treinamentos e documentos. Alguns desses instrumentos são: Treinamento de Segurança da Informação, Política de Tela e Mesa Limpa, Guia de Trabalho Remoto e Formulário de Autorização para Uso Externo de Equipamentos (em entrevista foi apresentado o formulário do colaborador Pedro Pereira).

6.5.3 - Tratamento de mídias

Conforme

O tema é tratado no Procedimento de Infra Geral:

2.6 GERENCIAMENTO DE MÍDIAS

São definidas como mídias removíveis todos os locais de armazenamento de informação que seja removível. Exemplos de mídias são: Cartão de memória, USB, câmeras digitais, HD externo, smartphones e tablets.

2.6.1 Identificação e Registro da Mídia

A identificação das mídias removível é realizada e usada só pelo departamento de Service Desk (para dar boot no sistema operacional Windows 11 nos notebooks, quando há necessidade de nova instalação do Windows 11. Os registros das mídias são realizados no FO Controle de Equipamentos).

2.6.2 Armazenamento de Mídias

O armazenamento da mídia é realizado em local protegido de umidade e calor. (só guardamos HD SSD em caso de necessidade para os notebooks para troca, o mesmo é

armazenado e lacrado no armário do escritório).

É indicado um local sem umidade, calor, poeira, principalmente próximo a entrada USB e uma caixa ou estojo para cada mídia removível).

Informações valiosas são armazenadas em duplicidade. Para informações valiosas o armazenamento deve ser duplicado em mais de uma mídia

2.6.3 Criptografia para Mídias Removíveis

Mídias removíveis que armazenam informações classificadas como confidenciais ou secretas são criptografados de acordo com a Política Uso de Controles Criptográficos.

Em auditoria foi informado que não são utilizados pen drives, apenas há um estoque de HD SSDs para trocas, quando necessárias, nos notebooks da organização. Ainda, foi informado que sempre que há algum problema, as mídias quando utilizadas, são formatadas e preparadas para reutilização.

6.5.3.1 - Gerenciamento de mídias removíveis

Conforme

O tema é tratado no Procedimento de Infra Geral:

2.6 GERENCIAMENTO DE MÍDIAS

São definidas como mídias removíveis todos os locais de armazenamento de informação que seja removível. Exemplos de mídias são: Cartão de memória, USB, câmeras digitais, HD externo, smartphones e tablets.

2.6.1 Identificação e Registro da Mídia

A identificação das mídias removível é realizada e usada só pelo departamento de Service Desk (para dar boot no sistema operacional Windows 11 nos notebooks, quando há necessidade de nova instalação do Windows 11. Os registros das mídias são realizados no FO Controle de Equipamentos).

2.6.2 Armazenamento de Mídias

O armazenamento da mídia é realizado em local protegido de umidade e calor.

(só guardamos HD SSD em caso de necessidade para os notebooks para troca, o mesmo é armazenado e lacrado no armário do escritório).

É indicado um local sem umidade, calor, poeira, principalmente próximo a entrada USB e uma caixa ou estojo para cada mídia removível).

Informações valiosas são armazenadas em duplicidade. Para informações valiosas o armazenamento deve ser duplicado em mais de uma mídia

2.6.3 Criptografia para Mídias Removíveis

Mídias removíveis que armazenam informações classificadas como confidenciais ou secretas são criptografados de acordo com a Política Uso de Controles Criptográficos.

Em auditoria foi informado que não são utilizados pen drives, apenas há um estoque de HD SSDs para trocas, quando necessárias, nos notebooks da organização. Ainda, foi informado que sempre que há algum problema, as mídias quando utilizadas, são formatadas e preparadas para reutilização.

6.5.3.2 - Descarte de mídias

Conforme

O tema é tratado no Procedimento de Infra Geral:

2.6 GERENCIAMENTO DE MÍDIAS

São definidas como mídias removíveis todos os locais de armazenamento de informação que seja removível. Exemplos de mídias são: Cartão de memória, USB, câmeras digitais, HD externo, smartphones e tablets.

2.6.1 Identificação e Registro da Mídia

A identificação das mídias removível é realizada e usada só pelo departamento de Service Desk (para dar boot no sistema operacional Windows 11 nos notebooks, quando há necessidade de nova instalação do Windows 11. Os registros das mídias são realizados no FO Controle de Equipamentos).

2.6.2 Armazenamento de Mídias

O armazenamento da mídia é realizado em local protegido de umidade e calor.

(só guardamos HD SSD em caso de necessidade para os notebooks para troca, o mesmo é armazenado e lacrado no armário do escritório).

É indicado um local sem umidade, calor, poeira, principalmente próximo a entrada USB e uma caixa ou estojo para cada mídia removível).

Informações valiosas são armazenadas em duplicidade. Para informações valiosas o armazenamento deve ser duplicado em mais de uma mídia

2.6.3 Criptografia para Mídias Removíveis

Mídias removíveis que armazenam informações classificadas como confidenciais ou secretas são criptografados de acordo com a Política Uso de Controles Criptográficos.

Em auditoria foi informado que não são utilizados pen drives, apenas há um estoque de HD SSDs para trocas, quando necessárias, nos notebooks da organização. Ainda, foi informado que sempre que há algum problema, as mídias quando utilizadas, são formatadas e preparadas para reutilização.

6.5.3.3 - Transferência física de mídias

Conforme

O tema é tratado no Procedimento de Infra Geral:

2.6 GERENCIAMENTO DE MÍDIAS

São definidas como mídias removíveis todos os locais de armazenamento de informação que seja removível. Exemplos de mídias são: Cartão de memória, USB, câmeras digitais, HD externo, smartphones e tablets.

2.6.1 Identificação e Registro da Mídia

A identificação das mídias removível é realizada e usada só pelo departamento de Service Desk (para dar boot no sistema operacional Windows 11 nos notebooks, quando há necessidade de nova instalação do Windows 11. Os registros das mídias são realizados no FO Controle de Equipamentos).

2.6.2 Armazenamento de Mídias

O armazenamento da mídia é realizado em local protegido de umidade e calor.

(só guardamos HD SSD em caso de necessidade para os notebooks para troca, o mesmo é armazenado e lacrado no armário do escritório).

É indicado um local sem umidade, calor, poeira, principalmente próximo a entrada USB e uma caixa ou estojo para cada mídia removível).

Informações valiosas são armazenadas em duplicidade. Para informações valiosas o armazenamento deve ser duplicado em mais de uma mídia

2.6.3 Criptografia para Mídias Removíveis

Mídias removíveis que armazenam informações classificadas como confidenciais ou secretas são criptografados de acordo com a Política Uso de Controles Criptográficos.

Em auditoria foi informado que não são utilizados pen drives, apenas há um estoque de HD SSDs para trocas, quando necessárias, nos notebooks da organização. Ainda, foi informado que sempre que há algum problema, as mídias quando utilizadas, são formatadas e preparadas para reutilização.

6.6 - Controle de acesso

6.6.1 - Requisitos do negócio para controle de acesso

Preocupação

O tema "Controle de Acesso Lógico" é tratado na Política de Uso e Controle de Acessos. Com relação aos "Acessos Físicos", há apenas uma planilha chamada Controle de Acesso Físico, com alguns registros.

PP 10: Diferente do controle lógico, que possui uma política formal, o acesso físico parece ser tratado de maneira informal, o que pode gerar inconsistências na aplicação dos controles e dificultar auditorias e conformidade regulatória. É fundamental criar uma política formal de Controle de Acesso Físico, definindo critérios de acesso a áreas sensíveis, identificando responsáveis e implementando registros detalhados de entradas e saídas.

6.6.1.1 - Política de controle de acesso

Preocupação

O tema "Controle de Acesso Lógico" é tratado na Política de Uso e Controle de Acessos. Com relação aos "Acessos Físicos", há apenas uma planilha chamada Controle de Acesso Físico, com alguns registros.

PP 10: Diferente do controle lógico, que possui uma política formal, o acesso físico parece ser tratado de maneira informal, o que pode gerar inconsistências na aplicação dos controles e dificultar auditorias e conformidade regulatória. É fundamental criar uma política formal de Controle de Acesso Físico, definindo critérios de acesso a áreas sensíveis, identificando responsáveis e implementando registros detalhados de entradas e saídas.

6.6.1.2 - Acesso às redes e aos serviços de rede

Preocupação

O tema "Controle de Acesso Lógico" é tratado na Política de Uso e Controle de Acessos. Com relação aos "Acessos Físicos", há apenas uma planilha chamada Controle de Acesso Físico, com alguns registros.

PP 10: Diferente do controle lógico, que possui uma política formal, o acesso físico parece ser tratado de maneira informal, o que pode gerar inconsistências na aplicação dos controles e dificultar auditorias e conformidade regulatória. É fundamental criar uma política formal de Controle de Acesso Físico, definindo critérios de acesso a áreas sensíveis, identificando responsáveis e implementando registros detalhados de entradas e saídas.

6.6.2 - Gerenciamento de acesso do usuário

6.6.2.1 - Registro e cancelamento de usuário

Conforme

O tema é tratado na Política de Uso e Controle de Acessos. Hoje, as identidades são controladas pelo AD que está integrado com o GLPI. Os desenvolvedores terceiros tem acesso a todo o workspace. Os dispositivos de endpoint possuem criptografia de disco e controles de acesso, atuando nas aplicações via VPN.

Para a criação e exclusão de identidades, há um checklist enviado pelo RH. Em auditoria, foi demonstrado o desligamento do ex-colaborador Leonardo Nunes Moreira do Vale. Ainda, há a utilização de política de senhas no Gmail.

6.6.2.2 - Provisionamento para acesso de usuário

Não Conforme

As diretrizes sobre controle de acesso estão na Política de Uso e Controle de Acesso. Foi verificado que há revisões de acesso, mas não há documentação estabelecida.

NC Menor 13: Foi verificado, em entrevista, que não há suspensão de acessos quando os colaboradores estão de férias. Ainda, não são realizadas análises críticas com relação aos acessos.

6.6.2.3 - Gerenciamento de direitos de acesso privilegiado

Conforme

O tema é tratado na Política de Uso e Controle de Acessos. Em auditoria, foram verificados os acessos privilegiados no AD. No Google, foram demonstrados os acessos privilegiados à pasta de Tecnologia dos colaboradores Wesley, Alexandre e Carlos Eduardo.

6.6.2.4 - Gerenciamento da informação de autenticação secreta de usuários

Conforme

O tema é tratado na Política de Uso e Controle de Acessos. O sistema Bitwarden (cofre de senhas) foi verificado em auditoria. Esses pontos demonstram o compromisso da organização em adotar medidas proativas para proteger os sistemas e as informações contra acessos não autorizados.

6.6.2.5 - Análise crítica dos direitos de acesso de usuário

Não Conforme

As diretrizes sobre controle de acesso estão na Política de Uso e Controle de Acesso. Foi verificado que há revisões de acesso, mas não há documentação estabelecida.

NC Menor 13: Foi verificado, em entrevista, que não há suspensão de acessos quando os colaboradores estão de férias. Ainda, não são realizadas análises críticas com relação aos acessos.

6.6.2.6 - Retirada ou ajuste dos direitos de acesso

Não Conforme

As diretrizes sobre controle de acesso estão na Política de Uso e Controle de Acesso. Foi verificado que há revisões de acesso, mas não há documentação estabelecida.

NC Menor 13: Foi verificado, em entrevista, que não há suspensão de acessos quando os colaboradores estão de férias. Ainda, não são realizadas análises críticas com relação aos acessos.

6.6.3 - Responsabilidades dos usuários

6.6.3.1 - Uso da informação de autenticação secreta

Conforme

O tema é tratado na Política de Uso e Controle de Acessos. O sistema Bitwarden (cofre de senhas) foi verificado em auditoria. Esses pontos demonstram o compromisso da organização em adotar medidas proativas para proteger os sistemas e as informações contra acessos não autorizados.

6.6.4 - Controle de acesso ao sistema e à aplicação**6.6.4.1- Restrição de acesso à informação**

Conforme

O tema é tratado na Política de Uso e Controle de Acessos. Hoje, há controle de acesso de acordo com as funções de cada colaborador, conforme verificado em entrevista (foram apresentados os acessos dos desenvolvedores). Em vez de conceder permissões individuais a cada usuário, as permissões são atribuídas a funções específicas, e os usuários recebem essas funções conforme suas responsabilidades.

Também, há política de uso e controle de acessos e procedimento de classificação e rotulagem de informações. Foi verificado que a empresa faz controle de acessos físicos e lógicos e segregação redes. Ainda, os dispositivos de endpoint possuem criptografia de disco e há a utilização de VPN por alguns colaboradores.

6.6.4.2 - Procedimentos seguros de entrada no sistema (log-on)

Conforme

O tema é tratado na Política de Uso e Controle de Acesso:

3.5 CANCELAMENTO DE ACESSO

O acesso de qualquer colaborador será imediatamente removido ou desativado ao deixar a empresa. Isso inclui a desativação do ID de usuário e o cancelamento de acesso aos sistemas.

3.6 AUTENTICAÇÃO MULTIFATOR (MFA)

Para fortalecer a segurança de acesso, a autenticação multifator (MFA) é obrigatória nos seguintes sistemas e serviços:

Sistemas de gestão de informações sensíveis (e.g., ERP, CRM)

Sistemas de e-mail corporativo

Acesso remoto a redes corporativas (VPN)

Sistemas de gestão de identidade e acesso (IAM)

Outros sistemas críticos especificados pela área de TI

3.7 GERENCIAMENTO DE SENHA DO USUÁRIO

As senhas da Organização são gerenciadas utilizando o sistema (especificar o sistema de gerenciamento de senhas).

Limite seguro de caracteres para senhas: deve ser de no mínimo 14 caracteres.

São consideradas obrigações dos usuários:

A não divulgação de senhas a outras pessoas;

As senhas geradas pelos usuários não devem ser distribuídas por meio de qualquer canal;

Devem ser criadas senhas fortes que considerem o uso de doze caracteres, utilização de números e caracteres especiais;

Não utilizar senhas baseadas em palavras de dicionário;

Não utilizar senhas baseadas em dados pessoais;

As senhas usadas para fins particulares não devem ser as mesmas de fins comerciais.

É de responsabilidade do gerente de senha que:

Todos os usuários devem ter a opção de escolher a senha, quando aplicável;

As senhas temporárias devem ser comunicadas ao usuário de forma segura e com a identidade preservada;

O sistema de gerenciamento de senha deve solicitar a troca de senha pelo usuário no primeiro acesso ao sistema;

O sistema de gerenciamento deve solicitar que o usuário utilize senhas fortes;

O sistema de gerenciamento deve solicitar que o usuário altere a senha pelo menos a cada três meses;

Se o usuário solicitar uma nova senha, o sistema de gerenciamento deve determinar a identidade do usuário, como por exemplo o envio de um e-mail;

O usuário deve confirmar o recebimento da senha;

As senhas criadas pelo fabricante de software devem ser alteradas na instalação.

Em auditoria, foi informado que se aplica MFA em todas as autenticações, e foi demonstrado o Azure.

6.6.4.3 - Sistema de gerenciamento de senha

Conforme

O tema é tratado na Política de Uso e Controle de Acessos. O sistema Bitwarden (cofre de senhas) foi verificado em auditoria. Esses pontos demonstram o compromisso da organização em adotar medidas proativas para proteger os sistemas e as informações contra acessos não autorizados.

6.6.4.4 - Uso de programas utilitários privilegiados

Conforme

O tema é tratado no Procedimento de Infra de TI. Hoje, a ferramenta com privilégio é o BitDefender, conforme demonstrado em entrevista.

6.6.4.5 - Controle de acesso ao código-fonte de programas

Conforme

O tema é tratado no Procedimento de Codificação Segura. Em auditoria, foi verificado que é utilizada a ferramenta GitHub, com controle de acesso, e apenas 6 pessoas têm acesso aos repositórios.

[PROCEDIMENTO DE CODIFICAÇÃO SEGURA.pdf](#)

6.7 - Criptografia

6.7.1 - Controles criptográficos

Conforme

O tema é tratado na Política de Controle Criptográfico. Em auditoria, foi constatado que todos os dispositivos são criptografados. São utilizadas as ferramentas Bitlocker, Fortinet e Azure, demonstradas em entrevista.

6.7.1.1 - Política para o uso de controles criptográficos

Conforme

O tema é tratado na Política de Controle Criptográfico. Em auditoria, foi constatado que todos os dispositivos são criptografados. São utilizadas as ferramentas Bitlocker, Fortinet e Azure, demonstradas em entrevista.

6.7.1.2 - Gerenciamento de chaves

Conforme

O tema é tratado na Política de Controle Criptográfico. Em auditoria, foi constatado que todos os dispositivos são criptografados. São utilizadas as ferramentas Bitlocker, Fortinet e Azure, demonstradas em entrevista.

6.8 - Segurança física e do ambiente

6.8.1 - Áreas seguras

6.8.1.1 - Perímetro de segurança física

Oportunidade de Melhoria

O tema é tratado no Procedimento de Infra Geral:

2.7 CONTROLE DE ACESSO

O controle de acesso às dependências físicas da Always On é realizado no 4º andar por meio de biometria digital de cada funcionário cadastrado. Além desse controle, há também o controle na portaria do prédio, realizado na recepção mediante apresentação de documentação e biometria antes da liberação do acesso. O controle do prédio conta com câmeras de videomonitoramento, detectores de fumaça e detectores de movimento com alarmes.

O monitoramento é realizado pelo condomínio, por meio de câmeras instaladas nos elevadores e distribuídas por todo o prédio, incluindo o estacionamento.

A empresa está localizada em um prédio comercial. Para entrar, tem que passar pela recepção e fazer um cadastro com documentos. Sempre que entra um colaborador novo, ele é cadastrado, com a apresentação de documentos. Funcionários da empresa passam pelo reconhecimento facial, que é de responsabilidade da segurança do prédio. No caso de visitantes, todos têm que fazer o cadastro biométrico temporário e é registrado no sistema do prédio. Ainda, há câmeras administradas pelo prédio.

Para a entrada na ALWAYS ON, o colaborador precisa de reconhecimento da digital. A biometria é feita pela empresa ELSYS, e somente tem acesso ao sistema a equipe de TI. As imagens ficam no hardware e a empresa não tem acesso. A atualização da fechadura é feita semestralmente (o próprio fabricante envia) e para casos de emergência, há uma chave, com cópias com os diretores Wesley e Thaiz. Sendo visitante, ele precisa tocar o interfone e um colaborador da empresa vai buscá-lo.

Hoje, não há monitoramento feito por câmeras dentro da sala da ALWAYS ON (mas há câmeras na entrada do edifício, nos corredores e no estacionamento), nem a utilização de crachás.

Há armários que são fechados com chave, para uso de todos os colaboradores: para equipamentos de hardware (com acesso somente o Diretor Wesley e os colaboradores Alexandre e Carlos Eduardo), para documentos etc.

OM 09: Uma oportunidade de melhoria seria a implementação de monitoramento interno por câmeras dentro da sala da ALWAYS ON, garantindo a proteção adicional dos ativos e informações sensíveis. Ademais, a utilização de crachás de identificação para colaboradores e visitantes facilitaria o controle de entrada e permanência no ambiente.

6.8.1.2 - Controles de entrada física

Oportunidade de Melhoria

O tema é tratado no Procedimento de Infra Geral:

2.7 CONTROLE DE ACESSO

O controle de acesso às dependências físicas da Always On é realizado no 4º andar por meio de biometria digital de cada funcionário cadastrado. Além desse controle, há também o controle na portaria do prédio, realizado na recepção mediante apresentação de documentação e biometria antes da liberação do acesso. O controle do prédio conta com câmeras de videomonitoramento, detectores de fumaça e detectores de movimento com alarmes.

O monitoramento é realizado pelo condomínio, por meio de câmeras instaladas nos elevadores e distribuídas por todo o prédio, incluindo o estacionamento.

A empresa está localizada em um prédio comercial. Para entrar, tem que passar pela recepção e fazer um cadastro com documentos. Sempre que entra um colaborador novo, ele é cadastrado, com a apresentação de documentos. Funcionários da empresa passam pelo reconhecimento facial, que é de responsabilidade da segurança do prédio. No caso de visitantes, todos têm que fazer o cadastro biométrico temporário e é registrado no sistema do prédio. Ainda, há câmeras administradas pelo prédio.

Para a entrada na ALWAYS ON, o colaborador precisa de reconhecimento da digital. A biometria é feita pela empresa ELSYS, e somente tem acesso ao sistema a equipe de TI. As imagens ficam no hardware e a empresa não tem acesso. A atualização da fechadura é feita semestralmente (o próprio fabricante envia) e para casos de emergência, há uma chave, com cópias com os diretores Wesley e Thaiz. Sendo visitante, ele precisa tocar o interfone e um colaborador da empresa vai buscá-lo.

Hoje, não há monitoramento feito por câmeras dentro da sala da ALWAYS ON (mas há câmeras na entrada do edifício, nos corredores e no estacionamento), nem a utilização de crachás.

Há armários que são fechados com chave, para uso de todos os colaboradores: para equipamentos de hardware (com acesso somente o Diretor Wesley e os colaboradores Alexandre e Carlos Eduardo), para documentos etc.

OM 10: Uma oportunidade de melhoria seria a implementação de monitoramento interno por câmeras dentro da sala da ALWAYS ON, garantindo a proteção adicional dos ativos e informações sensíveis. Ademais, a utilização de crachás de identificação para colaboradores e visitantes facilitaria o controle de entrada e permanência no ambiente.

6.8.1.3 - Segurança em escritórios, salas e instalações

Conforme

O ambiente da ALWYAS ON se encontra no quarto andar, sendo todo aberto com baias. Se precisarem fazer uma reunião, utilizam a sala de reuniões do térreo. Os documentos ficam pastas suspensas nomeadas e em armários com chaves, controlados pelos diretores Thaiz e Elcio.

Dentro da sala da empresa há extintores e sprinklers. Foi apresentado um checklist de infraestrutura, datado de 03/02/2025, incluindo iluminação, umidade, elevadores, ar condicionado etc. Ainda, foi apresentada a lista de presença e certificados da brigada de emergência do edifício.

6.8.1.4 - Proteção contra ameaças externas e do meio ambiente

Conforme

Hoje, há a utilização de no-breaks e gerador, há serviço de backup em nuvem e medidas de redundância. Ainda, há um plano de continuidade de negócios (que precisa ser ajustado), evidenciado em entrevista.

O ambiente da ALWYAS ON se encontra no quarto andar, sendo todo aberto com baias. Se precisarem fazer uma reunião, utilizam a sala de reuniões do térreo. Os documentos ficam pastas suspensas nomeadas e em armários com chaves, controlados pelos diretores Thaiz e Elcio.

Há um Procedimento de Preparação e Resposta à Emergências e foi apresentado o AVCB, com validade até 16/12/2027. Dentro da sala da empresa há extintores e sprinklers. Foi apresentado um checklist de infraestrutura, datado de 03/02/2025, incluindo iluminação, umidade, elevadores, ar condicionado etc. Ainda, foi apresentada a lista de presença e certificados da brigada de emergência do edifício.

6.8.1.5 - Trabalhando em áreas seguras

Oportunidade de Melhoria

O tema é tratado no Procedimento de Infra Geral:

2.7 CONTROLE DE ACESSO

O controle de acesso às dependências físicas da Always On é realizado no 4º andar por meio de biometria digital de cada funcionário cadastrado. Além desse controle, há também o controle na portaria do prédio, realizado na recepção mediante apresentação de documentação e biometria antes da liberação do acesso. O controle do prédio conta com câmeras de videomonitoramento, detectores de fumaça e detectores de movimento com alarmes.

O monitoramento é realizado pelo condomínio, por meio de câmeras instaladas nos elevadores e distribuídas por todo o prédio, incluindo o estacionamento.

A empresa está localizada em um prédio comercial. Para entrar, tem que passar pela recepção e fazer um cadastro com documentos. Sempre que entra um colaborador novo, ele é cadastrado, com a apresentação de documentos. Funcionários da empresa passam pelo reconhecimento facial, que é de responsabilidade da segurança do prédio. No caso de visitantes, todos têm que fazer o cadastro biométrico temporário e é registrado no sistema do prédio. Ainda, há câmeras administradas pelo prédio.

Para a entrada na ALWAYS ON, o colaborador precisa de reconhecimento da digital. A biometria é feita pela empresa ELSYS, e somente tem acesso ao sistema a equipe de TI. As imagens ficam no hardware e a empresa não tem acesso. A atualização da fechadura é feita semestralmente (o próprio fabricante envia) e para casos de emergência, há uma chave, com cópias com os diretores Wesley e Thaiz. Sendo visitante, ele precisa tocar o interfone e um colaborador da empresa vai buscá-lo.

Hoje, não há monitoramento feito por câmeras dentro da sala da ALWAYS ON (mas há câmeras na entrada do edifício, nos corredores e no estacionamento), nem a utilização de crachás.

Há armários que são fechados com chave, para uso de todos os colaboradores: para equipamentos de hardware (com acesso somente o Diretor Wesley e os colaboradores Alexandre e Carlos Eduardo), para documentos etc.

OM 12: Uma oportunidade de melhoria seria a implementação de monitoramento interno por câmeras dentro da sala da ALWAYS ON, garantindo a proteção adicional dos ativos e informações sensíveis.

6.8.1.6 - Áreas de entrega e de carregamento

Oportunidade de Melhoria

O tema é tratado no Procedimento de Infra Geral:

2.7 CONTROLE DE ACESSO

O controle de acesso às dependências físicas da Always On é realizado no 4º andar por meio de biometria digital de cada funcionário cadastrado. Além desse controle, há também o controle na portaria do prédio, realizado na recepção mediante apresentação de documentação e biometria antes da liberação do acesso. O controle do prédio conta com câmeras de videomonitoramento, detectores de fumaça e detectores de movimento com alarmes.

O monitoramento é realizado pelo condomínio, por meio de câmeras instaladas nos elevadores e distribuídas por todo o prédio, incluindo o estacionamento.

A empresa está localizada em um prédio comercial. Para entrar, tem que passar pela recepção e fazer um cadastro com documentos. Sempre que entra um colaborador novo, ele é cadastrado, com a apresentação de documentos. Funcionários da empresa passam pelo reconhecimento facial, que é de responsabilidade da segurança do prédio. No caso de visitantes, todos têm que fazer o cadastro biométrico temporário e é registrado no sistema do prédio. Ainda, há câmeras administradas pelo prédio.

Para a entrada na ALWAYS ON, o colaborador precisa de reconhecimento da digital. A biometria é feita pela empresa ELSYS, e somente tem acesso ao sistema a equipe de TI. As imagens ficam no hardware e a empresa não tem acesso. A atualização da fechadura é feita semestralmente (o próprio fabricante envia) e para casos de emergência, há uma chave, com cópias com os diretores Wesley e Thaiz. Sendo visitante, ele precisa tocar o interfone e um colaborador da empresa vai buscá-lo.

Hoje, não há monitoramento feito por câmeras dentro da sala da ALWAYS ON (mas há câmeras na entrada do edifício, nos corredores e no estacionamento), nem a utilização de crachás.

Há armários que são fechados com chave, para uso de todos os colaboradores: para equipamentos de hardware (com acesso somente o Diretor Wesley e os colaboradores Alexandre e Carlos Eduardo), para documentos etc.

OM 10: Uma oportunidade de melhoria seria a implementação de monitoramento interno por câmeras dentro da sala da ALWAYS ON, garantindo a proteção adicional dos ativos e informações sensíveis. Ademais, a utilização de crachás de identificação para colaboradores e visitantes facilitaria o controle de entrada e permanência no ambiente.

6.8.2 - Equipamentos

Conforme

Foi constatado, em entrevista, que na organização há bloqueios por portas, armários trancados com chave e equipamentos contra incêndio (sprinklers e extintores).

Ainda, os ativos fora das dependências são seguradas com implementação de controles criptográficos nos notebooks com bitlocker, uso de MFA, VPN e controles através do AD.

6.8.2.1 - Localização e proteção do equipamento

Conforme

Foi constatado, em entrevista, que na organização há bloqueios por portas, armários trancados com chave e equipamentos contra incêndio (sprinklers e extintores).

Ainda, os ativos fora das dependências são seguradas com implementação de controles criptográficos nos notebooks com bitlocker, uso de MFA, VPN e controles através do AD.

6.8.2.2 - Utilidades

Conforme

Foi constatado que há utilização de no-break, gerador, backup em nuvem e redundância. Há contrato com o fornecedor Equinix. Ainda, há PCN (que precisa ser ajustado), Plano de Testes e Procedimento de Preparação e Resposta à Emergências.

6.8.2.3 - Segurança do cabeamento

Conforme

Atualmente, foi verificado que só há utilização de wi-fi, e com relação aos cabos de energia, foram apresentadas fotos das canaletas e das tomadas das mesas.

6.8.2.4 - Manutenção dos equipamentos

Conforme

Foi verificada, em auditoria, a planilha de Checklist de Infraestrutura, que demonstra verificações da parte

de infra (ar condicionado, iluminação, alarmes de incêndio, energia elétrica, no-breaks, cabeamento, impressoras etc.).

A manutenção de notebooks é feita através de abertura de ticket e controlada através da ferramentas GLPI. Foi demonstrada a máquina DEADPOOL60, do colaborador Henrique de Oliveira.

6.8.2.5 - Remoção de ativos

Conforme

O tema é tratado no Procedimento de Infra Geral:

2.6 GERENCIAMENTO DE MÍDIAS

São definidas como mídias removíveis todos os locais de armazenamento de informação que seja removível. Exemplos de mídias são: Cartão de memória, USB, câmeras digitais, HD externo, smartphones e tablets.

2.6.1 Identificação e Registro da Mídia

A identificação das mídias removível é realizada e usada só pelo departamento de Service Desk (para dar boot no sistema operacional Windows 11 nos notebooks, quando há necessidade de nova instalação do Windows 11. Os registros das mídias são realizados no FO Controle de Equipamentos).

2.6.2 Armazenamento de Mídias

O armazenamento da mídia é realizado em local protegido de umidade e calor.

(só guardamos HD SSD em caso de necessidade para os notebooks para troca, o mesmo é armazenado e lacrado no armário do escritório).

É indicado um local sem umidade, calor, poeira, principalmente próximo a entrada USB e uma caixa ou estojo para cada mídia removível).

Informações valiosas são armazenadas em duplicidade. Para informações valiosas o armazenamento deve ser duplicado em mais de uma mídia

2.6.3 Criptografia para Mídias Removíveis

Mídias removíveis que armazenam informações classificadas como confidenciais ou secretas são criptografados de acordo com a Política Uso de Controles Criptográficos.

Em auditoria foi informado que não são utilizados pen drives, apenas há um estoque de HD SSDs para trocas, quando necessárias, nos notebooks da organização. Ainda, foi informado que sempre que há algum problema, as mídias quando utilizadas, são formatadas e preparadas para reutilização.

6.8.2.6 - Segurança de equipamentos e ativos fora das dependências da organização

Conforme

O tema é tratado no Procedimento de Infra Geral. Foi evidenciado em entrevista que há utilização de criptografia de disco nos notebooks, antivírus, firewall, todas as autenticações são feita via MFA e a realização de monitoramentos (MDM). Ademais, há um Guia de Trabalho Remoto (precisa ser ajustado) e uma Política de Dispositivos BYOD.

6.8.2.7 - Reutilização ou descarte seguro de equipamentos

Conforme

O tema é tratado no Procedimento de Descarte de Dados Pessoais. Em entrevista, foi informado que há um triturador (print anexo), para descarte de documentos físicos. Também, são utilizadas as ferramentas Eraser e Bleachbit.

6.8.2.8 - Equipamento de usuário sem monitoração

Conforme

O inventário de ativos está todo dentro do GLPI, considerando computadores, monitores etc. São utilizadas as ferramentas Bitdefender, Fortigate, Bitlocker e AD. Ainda, foi informado que todos os dispositivos são criptografados, e alguns colaboradores utilizam VPN.

Hoje, há uma lista de chaves criptográficas no google drive, que está sendo transferida para o GLPI.

6.8.2.9 - Política de mesa limpa e tela limpa

Conforme

A organização implementou a Política de Mesa Limpa e Tela Limpa, com revisão 1.02 em 02/02/2025, contendo as orientações quanto ao uso dos equipamentos. Foi aplicado um treinamento de 1h sobre o tema (gravado), em 08/12/2024, mas não há uma lista de presença assinada.

Durante as entrevistas no processo de auditoria, não foram identificadas situações nas quais houvesse descumprimento desta política.

6.9 - Segurança nas operações

6.9.1 - Responsabilidades e procedimentos operacionais

Preocupação

A organização determinou uma série de políticas, processos e procedimentos, referentes ao seu sistema de segurança da informação e privacidade, considerados suficientes para a amostragem desta auditoria, no entanto, alguns dos documentos estão desatualizados e não demonstram a realidade da organização.

PP 13: Esse controle exige que os procedimentos operacionais estejam documentados e acessíveis para garantir que os processos de segurança sejam executados corretamente. Quando documentos desatualizados são utilizados como referência, há um desalinhamento entre a prática e a documentação formal, o que pode gerar falhas operacionais, confusão entre os colaboradores e dificuldades em auditorias. Ademais, a organização pode ter dificuldades em demonstrar conformidade com requisitos regulatórios e boas práticas de segurança. Outro ponto de preocupação é que a desatualização dos documentos pode comprometer a eficácia dos controles implementados e afetar a resposta a incidentes e a gestão de riscos. Se os procedimentos não refletem a realidade da organização, há o risco de que colaboradores sigam diretrizes obsoletas, o que pode levar a falhas de segurança, não conformidades legais e até mesmo incidentes de segurança e/ou violações de dados pessoais. Para mitigar esses riscos, a organização deve estabelecer um processo de revisão periódica da documentação, garantindo que os procedimentos estejam sempre alinhados com as práticas atuais e que os colaboradores tenham acesso a informações atualizadas e confiáveis.

6.9.1.1 - Documentação dos procedimentos de operação

Preocupação

A organização determinou uma série de políticas, processos e procedimentos, referentes ao seu sistema de segurança da informação e privacidade, considerados suficientes para a amostragem desta auditoria, no entanto, alguns dos documentos estão desatualizados e não demonstram a realidade da organização.

PP 13: Esse controle exige que os procedimentos operacionais estejam documentados e acessíveis para garantir que os processos de segurança sejam executados corretamente. Quando documentos desatualizados são utilizados como referência, há um desalinhamento entre a prática e a documentação formal, o que pode gerar falhas operacionais, confusão entre os colaboradores e dificuldades em auditorias. Ademais, a organização pode ter dificuldades em demonstrar conformidade com requisitos regulatórios e boas práticas de segurança. Outro ponto de preocupação é que a desatualização dos documentos pode comprometer a eficácia dos controles implementados e afetar a resposta a incidentes e a gestão de riscos. Se os procedimentos não refletem a realidade da organização, há o risco de que colaboradores sigam diretrizes obsoletas, o que pode levar a falhas de segurança, não conformidades legais e até mesmo incidentes de segurança e/ou violações de dados pessoais. Para mitigar esses riscos, a organização deve estabelecer um processo de revisão periódica da documentação, garantindo que os procedimentos estejam sempre alinhados com as práticas atuais e que os colaboradores tenham acesso a informações atualizadas e confiáveis.

6.9.1.2 - Gestão de mudanças

Conforme

O tema é tratado no Procedimento de Controle de Mudanças. Havendo necessidade de mudança, há o preenchimento de um formulário, enviando para o responsável de SI. Há avaliação e o envio para a aprovação do Wesley e/ou da Thais. A aprovação é feita por e-mail, mas o objetivo é utilizar o GLPI para fazer as mudanças. Após a aprovação, ou ela já é implementada ou entra na lista de agendamento para realização.

6.9.1.3 - Gestão de capacidade

Conforme

O tema é tratado no Procedimento de Infra de TI. Em auditoria, foi verificada a ferramenta Cloudstack, demonstrando as gestões de capacidade de hardware, de software e de redes.

6.9.1.4 - Separação dos ambientes de desenvolvimento, teste e de produção

Conforme

Em auditoria, foram demonstrados os ambientes de desenvolvimento e de produção, via ferramenta Cloudstack. Os testes são realizados dentro do ambiente de desenvolvimento e muitas vezes, o desenvolvimento é feito na máquina local, e posteriormente, publicado para a máquina de teste.

6.9.2 - Proteção contra códigos maliciosos

6.9.2.1 - Controles contra códigos maliciosos

Conforme

O tema é tratado no Procedimento de Infra de TI:

3.4 PROTEÇÃO CONTRA MALWARE

Com o objetivo de aumentar a proteção contra malware a Always On utiliza Bitdefender Endpoint instalados nos equipamentos que processam as informações (Servidores e notebooks).

Os Equipamentos são analisados em espaços de tempo planejados periodicamente e semanalmente para análise da efetividade da atualização do antivírus nos equipamentos.

Foi demonstrada, em entrevista, a ferramenta Bitdefender (antivírus), verificando a máquina 33, do colaborador Henrique Oliveira. Ainda, foi informado que todas as máquinas tem Bitdefender. Também, foi visto o Fortigate (firewall).

6.9.3 - Cópias de segurança

6.9.3.1 - Cópias de segurança das informações

Conforme

O tema é tratado no Procedimento de Infra de TI 2.

Foram verificadas, em entrevista, as ferramentas Cloudstack e o Azure. Nos dispositivos, os backups são salvos no GoogleDrive. No Cloudsatck, o backup é diário. No Azure, o backup é feito a cada 4 horas. E também, dependendo do caso específico, pode ser diário. Com o tempo, o Azure vai excluindo os mais antigos.

6.9.4 - Registros e monitoramento

6.9.4.1 - Registros de eventos (logs)

Conforme

O tema é tratado no Procedimento de Infra de TI 2. Foram demonstrados o AD e o Bitdefender (máquina DEADPOOL10).

6.9.4.2 - Proteção das informações dos registros de eventos (logs)

Conforme

O tema é tratado no Procedimento de Infra de TI 2. Foram demonstrados o AD e o Bitdefender (máquina DEADPOOL10).

6.9.4.3 - Registros de eventos (log) de administrador e operador

Conforme

O tema é tratado no Procedimento de Infra de TI 2. Foram demonstrados o AD e o Bitdefender (máquina DEADPOOL10).

6.9.4.4 - Sincronização dos relógios

Conforme

O tema é tratado no Procedimento de Infra de TI 2. A sincronização é feita pelo servidor de NTP HULK01 e todos os computadores da rede são sincronizados conforme GPO.

6.9.5 - Controle de software operacional

6.9.5.1 - Instalação de software nos sistemas operacionais

Conforme

O tema é tratado no Procedimento de Infra de TI 2. Quando entra um novo colaborador, o SI recebe um checklist do RH, dizendo o que ele precisará, a partir daí, as máquinas são configuradas, criptografadas e entregues aos colaboradores.

Hoje, o gerenciamento dos softwares é feito via planilha Checklist de Softwares Instalados. Há um servidor WSUS que faz atualização de patches em todas as máquinas. As aprovações são feitas via sistema.

6.9.6 - Gestão de vulnerabilidades técnicas

6.9.6.1 - Gestão de vulnerabilidades técnicas

Preocupação

O tema é tratado no Procedimento de Infra de TI 2:

3.5. VULNERABILIDADE TÉCNICA

A gestão de vulnerabilidade técnica é realizada na Gestão de Ativos na aba Análise de Risco onde qualquer vulnerabilidade identificada é analisada e tratada rapidamente.

É utilizada a ferramenta Bitdefender, que aponta a vulnerabilidade, manda e-mail e o colaborador Alexandre da Rocha abre um chamado no GLPI. No Procedimento de Infra de TI 2 não consta o fluxo atualizado com relação a gestão das vulnerabilidades técnicas.

PP 16: Embora a empresa utilize a ferramenta Bitdefender para detectar vulnerabilidades e possua um processo de abertura de chamados no GLPI, a falta de um documento atualizado compromete a eficácia e rastreabilidade do tratamento dessas falhas, podendo resultar em atrasos ou falhas operacionais na mitigação de riscos. Para mitigar esses riscos, é essencial atualizar o procedimento de infraestrutura, detalhando o fluxo de resposta às vulnerabilidades e garantindo que ele seja seguido de maneira padronizada.

6.9.6.2 - Restrições quanto à instalação de software

Conforme

O tema é tratado no Procedimento de Infra de TI 2. Quando entra um novo colaborador, o SI recebe um checklist do RH, dizendo o que ele precisará, a partir daí, as máquinas são configuradas, criptografadas e entregues aos colaboradores.

Hoje, o gerenciamento dos softwares é feito via planilha Checklist de Softwares Instalados. Há um servidor WSUS que faz atualização de patches em todas as máquinas. As aprovações são feitas via sistema.

6.9.7 - Considerações quanto à auditoria de sistemas de informação

6.9.7.1 - Controles de auditoria de sistemas de informação

Preocupação

Em auditoria, foi relatado que não ocorreu nenhuma auditoria de sistemas operacionais. Ainda, foi realizado um pentest em 2022, com a empresa ESecurity e foi mostrado um pentest da Equinix, de 2023, todavia, após essa data não foram realizados mais testes de penetração.

PP 19: A ausência de auditorias compromete a avaliação contínua da segurança, dificultando a identificação de vulnerabilidades, falhas de configuração e riscos operacionais que podem impactar a integridade do ambiente de TI. A norma exige que os testes sejam planejados e acordados entre os testadores e a gestão, o que não está ocorrendo, indicando a necessidade de uma abordagem mais estruturada na governança da segurança da informação. Outro ponto é a disparidade na frequência dos pentests. Embora tenham sido realizados em 2022 e 2023, não há um cronograma formalizado e contínuo para a realização dessas avaliações. A falta de testes periódicos pode permitir que novas vulnerabilidades permaneçam sem detecção, aumentando o risco de exploração por atacantes.

6.10 - Segurança nas comunicações

6.10.1 - Gerenciamento da segurança em redes

6.10.1.1 - Controles de redes

Conforme

O tema é tratado no Procedimento de Infra de TI:

3.1.2 SEGREGAÇÃO DE REDES

As redes são segmentadas por unidade organizacional (Vendas, RH, Financeiro, TI, Marketing) e, quando necessário, são estabelecidas combinações baseadas em critérios de confiança (perfil de acesso). Ativos que exigem alta confidencialidade trafegam por redes fisicamente exclusivas. Dados ultrasseguros são transmitidos por redes exclusivas com fibra óptica dedicada à equipe de gestão ou por meio de Redes Privadas Virtuais (Virtual Private Network – VPN).

3.1.3 MONITORAMENTO DE REDES

O monitoramento da rede é realizado para detectar possíveis comportamentos anômalos e prevenir incidentes de segurança da informação. São utilizadas as ferramentas Zabbix e Bitdefender Antivírus em todo o ambiente da Always On.

Os resultados do monitoramento são registrados em logs e relatórios gerados pelas ferramentas, contendo informações sobre o desempenho dos dispositivos de rede, estado de conectividade, alertas sobre problemas identificados e outros dados relevantes sobre o tráfego da rede e o status dos serviços.

A parte de gestão de redes é feita pela ferramenta cloudstack. Ainda, são utilizadas ferramentas como Bitdefender, Fortinet e Zabbix.

Foi verificado, em auditoria, o monitoramento de rede, via Bitdefender, da máquina DEADPOOL51, conforme prints anexos. O monitoramento de internet é feito pelo Fortinet.

Foi apresentada a ferramenta Cloudstack, na qual as redes são segregadas, sendo separados os ambientes de produção e de testes. Foi criada uma rede separada, para monitoramento, uma de backup e uma de administração.

6.10.1.2 - Segurança dos serviços de rede

Conforme

O tema é tratado no Procedimento de Infra de TI:

3.1.2 SEGREGAÇÃO DE REDES

As redes são segmentadas por unidade organizacional (Vendas, RH, Financeiro, TI, Marketing) e, quando necessário, são estabelecidas combinações baseadas em critérios de confiança (perfil de acesso). Ativos que exigem alta confidencialidade trafegam por redes fisicamente exclusivas. Dados ultrasseguros são transmitidos por redes exclusivas com fibra óptica dedicada à equipe de gestão ou por meio de Redes Privadas Virtuais (Virtual Private Network – VPN).

3.1.3 MONITORAMENTO DE REDES

O monitoramento da rede é realizado para detectar possíveis comportamentos anômalos e prevenir incidentes de segurança da informação. São utilizadas as ferramentas Zabbix e Bitdefender Antivírus em todo o ambiente da Always On.

Os resultados do monitoramento são registrados em logs e relatórios gerados pelas ferramentas, contendo informações sobre o desempenho dos dispositivos de rede, estado de conectividade, alertas sobre problemas identificados e outros dados relevantes sobre o tráfego da rede e o status dos serviços.

A parte de gestão de redes é feita pela ferramenta cloudstack. Ainda, são utilizadas ferramentas como Bitdefender, Fortinet e Zabbix.

Foi verificado, em auditoria, o monitoramento de rede, via Bitdefender, da máquina DEADPOOL51, conforme prints anexos. O monitoramento de internet é feito pelo Fortinet.

Foi apresentada a ferramenta Cloudstack, na qual as redes são segregadas, sendo separados os ambientes de produção e de testes. Foi criada uma rede separada, para monitoramento, uma de backup e uma de administração.

6.10.1.3 - Segregação de redes

Conforme

O tema é tratado no Procedimento de Infra de TI:

3.1.2 SEGREGAÇÃO DE REDES

As redes são segmentadas por unidade organizacional (Vendas, RH, Financeiro, TI, Marketing) e, quando necessário, são estabelecidas combinações baseadas em critérios de confiança (perfil de acesso). Ativos que exigem alta confidencialidade trafegam por redes fisicamente exclusivas. Dados ultrasseguros são transmitidos por redes exclusivas com fibra óptica dedicada à equipe de gestão ou por meio de Redes Privadas Virtuais (Virtual Private Network – VPN).

3.1.3 MONITORAMENTO DE REDES

O monitoramento da rede é realizado para detectar possíveis comportamentos anômalos e prevenir incidentes de segurança da informação. São utilizadas as ferramentas Zabbix e Bitdefender Antivírus em todo o ambiente da Always On.

Os resultados do monitoramento são registrados em logs e relatórios gerados pelas ferramentas, contendo informações sobre o desempenho dos dispositivos de rede, estado de conectividade, alertas sobre problemas identificados e outros dados relevantes sobre o tráfego da rede e o status dos serviços.

A parte de gestão de redes é feita pela ferramenta cloudstack. Ainda, são utilizadas ferramentas como Bitdefender, Fortinet e Zabbix.

Foi verificado, em auditoria, o monitoramento de rede, via Bitdefender, da máquina DEADPOOL51, conforme prints anexos. O monitoramento de internet é feito pelo Fortinet.

Foi apresentada a ferramenta Cloudstack, na qual as redes são segregadas, sendo separados os ambientes de produção e de testes. Foi criada uma rede separada, para monitoramento, uma de backup e uma de administração.

6.10.2 - Transferência de informação

6.10.2.1 - Políticas e procedimentos para transferência de informações

Conforme

O tema em tela é tratado no Procedimento de Transferência de Informações e Dados Pessoais, que menciona os seguintes canais de comunicação:

As informações e dados pessoais que a empresa opera são trocadas por meio dos seguintes canais de comunicação:

- E-mail;
- Portal <https://peopleon.greghub.com.br/news>
- Google Drive
- Github
- transfer.aodigital.com.br (sftp externo)

Em auditoria, foram verificadas as ferramentas Google Worksapce, Greg e Github. Ainda, foi verificado que a organização adota medidas de segurança como antivírus, firewall, controle de acessos, monitoramentos, criptografia, dentre outras.

6.10.2.2 - Acordos para transferência de informações

Conforme

O tema em tela é tratado no Procedimento de Transferência de Informações e Dados Pessoais, que menciona os seguintes canais de comunicação:

As informações e dados pessoais que a empresa opera são trocadas por meio dos seguintes canais de comunicação:

- E-mail;
- Portal <https://peopleon.greghub.com.br/news>
- Google Drive
- Github

- transfer.aodigital.com.br (sftp externo)

Em auditoria, foram verificadas as ferramentas Google Worksapce, Greg e Github. Ainda, foi verificado que a organização adota medidas de segurança como antivírus, firewall, controle de acessos, monitoramentos, criptografia, dentre outras.

6.10.2.3 - Mensagens eletrônicas

Conforme

O tema em tela é tratado no Procedimento de Transferência de Informações e Dados Pessoais, que menciona os seguintes canais de comunicação:

As informações e dados pessoais que a empresa opera são trocadas por meio dos seguintes canais de comunicação:

- E-mail;
- Portal <https://peopleon.greghub.com.br/news>
- Google Drive
- Github
- transfer.aodigital.com.br (sftp externo)

Em auditoria, foram verificadas as ferramentas Google Worksapce, Greg e Github. Ainda, foi verificado que a organização adota medidas de segurança como antivírus, firewall, controle de acessos, monitoramentos, criptografia, dentre outras.

6.10.2.4 - Acordos de confidencialidade e não divulgação

Conforme

Foram verificados, em auditoria, os acordos de confidencialidade do colaborador Henrique de Oliveira e do ex-colaborador Hélio Marcellus.

6.11 - Aquisição, desenvolvimento e manutenção de sistemas

6.11.1.2 - Serviços de aplicação seguros em redes públicas

Não Conforme

O tema é tratado no Procedimento de Desenvolvimento de Software. Hoje, os programadores desenvolvem para os clientes, seguindo a metodologia de cada cliente. O cliente treina os colaboradores e eles seguem as regras. Ainda, há algumas tarefas de desenvolvimento para a própria ALWAYS ON. Foi constatado que não são feitas avaliações de riscos de SI nem de privacidade antes dos projetos.

Foi demonstrado, em auditoria, que os desenvolvedores receberam um treinamento básico sobre SI e não receberam treinamento sobre privacidade. Em entrevista, foi apresentado o treinamento do colaborador Massaharu Shimizi.

Para os projetos com os clientes, há a realização de uma reunião, com a equipe da ALWAYS ON e a equipe do cliente, a fim de coletar informações e criar o "Documento de Software". Foram evidenciados cronogramas e documento de arquitetura do cliente NATURAPAY, contudo, o "Documento de Software" mencionado no Procedimento não foi localizado nesse cliente.

No Procedimento de Desenvolvimento de Software diz que "Se a ferramenta a ser desenvolvida, utilizar Dados Pessoais ainda não identificados ou se a finalidade de algum dado pessoal for alterada, o Encarregado de Dados Pessoais deve ser informado para contemplar essa atualização na Gestão de Ativos no mapa do processo identificado, Mapa de DP e Fluxo de DP", no entanto, foi apurado em entrevista que essa etapa não ocorre na prática.

No que tange à mudanças, foi relatado que existe uma área de GMUD no cliente, então, toda mudança feita pela ALWAYS ON é apresentada em reunião, para que o cliente avalie. Também, há realização de testes pela ALWAYS ON e pelo cliente. Há o desenvolvimento, depois há testes unitários e integrados. Foi verificado que são utilizadas ferramentas para testes, e os relatórios ficam com os clientes, sem compartilhamento com a ALWAYS ON.

NC Menor 21: Foi constatada a ausência de avaliação de riscos de segurança da informação e privacidade antes do início dos projetos, o que compromete a proteção de dados e a conformidade com normas vigentes e aplicáveis. Também, os desenvolvedores não receberam treinamento adequado em privacidade, o que pode resultar em falhas na implementação de medidas de segurança no ciclo de desenvolvimento de

software. Outro ponto crítico é que, apesar de o procedimento prever que o Encarregado pelo Tratamento de Dados Pessoais deve ser informado caso novos dados pessoais sejam identificados ou sua finalidade alterada, essa etapa não ocorre na prática, representando uma falha no controle e rastreamento do tratamento de dados, podendo resultar em riscos de incidentes de segurança e violações de dados pessoais.

6.11.1.3 - Protegendo as transações nos aplicativos de serviços

Não Conforme

O tema é tratado no Procedimento de Desenvolvimento de Software. Hoje, os programadores desenvolvem para os clientes, seguindo a metodologia de cada cliente. O cliente treina os colaboradores e eles seguem as regras. Ainda, há algumas tarefas de desenvolvimento para a própria ALWAYS ON. Foi constatado que não são feitas avaliações de riscos de SI nem de privacidade antes dos projetos.

Foi demonstrado, em auditoria, que os desenvolvedores receberam um treinamento básico sobre SI e não receberam treinamento sobre privacidade. Em entrevista, foi apresentado o treinamento do colaborador Massaharu Shimizi.

Para os projetos com os clientes, há a realização de uma reunião, com a equipe da ALWAYS ON e a equipe do cliente, a fim de coletar informações e criar o "Documento de Software". Foram evidenciados cronogramas e documento de arquitetura do cliente NATURAPAY, contudo, o "Documento de Software" mencionado no Procedimento não foi localizado nesse cliente.

No Procedimento de Desenvolvimento de Software diz que "Se a ferramenta a ser desenvolvida, utilizar Dados Pessoais ainda não identificados ou se a finalidade de algum dado pessoal for alterada, o Encarregado de Dados Pessoais deve ser informado para contemplar essa atualização na Gestão de Ativos no mapa do processo identificado, Mapa de DP e Fluxo de DP", no entanto, foi apurado em entrevista que essa etapa não ocorre na prática.

No que tange à mudanças, foi relatado que existe uma área de GMUD no cliente, então, toda mudança feita pela ALWAYS ON é apresentada em reunião, para que o cliente avalie. Também, há realização de testes pela ALWAYS ON e pelo cliente. Há o desenvolvimento, depois há testes unitários e integrados. Foi verificado que são utilizadas ferramentas para testes, e os relatórios ficam com os clientes, sem compartilhamento com a ALWAYS ON.

NC Menor 21: Foi constatada a ausência de avaliação de riscos de segurança da informação e privacidade antes do início dos projetos, o que compromete a proteção de dados e a conformidade com normas vigentes e aplicáveis. Também, os desenvolvedores não receberam treinamento adequado em privacidade, o que pode resultar em falhas na implementação de medidas de segurança no ciclo de desenvolvimento de software. Outro ponto crítico é que, apesar de o procedimento prever que o Encarregado pelo Tratamento de Dados Pessoais deve ser informado caso novos dados pessoais sejam identificados ou sua finalidade alterada, essa etapa não ocorre na prática, representando uma falha no controle e rastreamento do tratamento de dados, podendo resultar em riscos de incidentes de segurança e violações de dados pessoais.

6.11.2 - Segurança em processos de desenvolvimento e de suporte

6.11.2.1 - Política de desenvolvimento seguro

Não Conforme

O tema é tratado no Procedimento de Desenvolvimento de Software. Hoje, os programadores desenvolvem para os clientes, seguindo a metodologia de cada cliente. O cliente treina os colaboradores e eles seguem as regras. Ainda, há algumas tarefas de desenvolvimento para a própria ALWAYS ON. Foi constatado que não são feitas avaliações de riscos de SI nem de privacidade antes dos projetos.

Foi demonstrado, em auditoria, que os desenvolvedores receberam um treinamento básico sobre SI e não receberam treinamento sobre privacidade. Em entrevista, foi apresentado o treinamento do colaborador Massaharu Shimizi.

Para os projetos com os clientes, há a realização de uma reunião, com a equipe da ALWAYS ON e a equipe do cliente, a fim de coletar informações e criar o "Documento de Software". Foram evidenciados cronogramas e documento de arquitetura do cliente NATURAPAY, contudo, o "Documento de Software" mencionado no Procedimento não foi localizado nesse cliente.

No Procedimento de Desenvolvimento de Software diz que "Se a ferramenta a ser desenvolvida, utilizar

Dados Pessoais ainda não identificados ou se a finalidade de algum dado pessoal for alterada, o Encarregado de Dados Pessoais deve ser informado para contemplar essa atualização na Gestão de Ativos no mapa do processo identificado, Mapa de DP e Fluxo de DP", no entanto, foi apurado em entrevista que essa etapa não ocorre na prática.

No que tange à mudanças, foi relatado que existe uma área de GMUD no cliente, então, toda mudança feita pela ALWAYS ON é apresentada em reunião, para que o cliente avalie. Também, há realização de testes pela ALWAYS ON e pelo cliente. Há o desenvolvimento, depois há testes unitários e integrados. Foi verificado que são utilizadas ferramentas para testes, e os relatórios ficam com os clientes, sem compartilhamento com a ALWAYS ON.

NC Menor 20: A situação apresentada configura uma não conformidade, pois não há uma padronização interna para o desenvolvimento seguro de software na ALWAYS ON. O fato de os desenvolvedores seguirem apenas as metodologias de cada cliente, sem uma abordagem própria e consolidada da empresa, indica a falta de um processo estruturado de segurança no desenvolvimento. Em complemento, a ausência de avaliações de riscos de segurança da informação e privacidade antes dos projetos compromete a identificação e mitigação de vulnerabilidades desde as fases iniciais. A norma exige que regras de desenvolvimento seguro sejam estabelecidas e aplicadas, o que não ocorre na prática, já que o Procedimento de Desenvolvimento de Software não está sendo seguido conforme descrito. Outro fator preocupante é a deficiência nos treinamentos dos desenvolvedores. Embora tenham recebido um treinamento básico de segurança da informação, não houve capacitação sobre privacidade, o que pode levar ao desenvolvimento de aplicações não aderentes à normas e regulamentações de privacidade e proteção de dados pessoais.

6.11.2.2 - Procedimentos para controle de mudanças de sistemas

Conforme

O tema é tratado no Procedimento de Controle de Mudanças. Havendo necessidade de mudança, há o preenchimento de um formulário, enviando para o responsável de SI. Há avaliação e o envio para a aprovação do Wesley e/ou da Thais. A aprovação é feita por e-mail, mas o objetivo é utilizar o GLPI para fazer as mudanças. Após a aprovação, ou ela já é implementada ou entra na lista de agendamento para realização.

6.11.2.3 - Análise crítica técnica das aplicações após mudanças nas plataformas operacionais

Conforme

O tema é tratado no Procedimento de Controle de Mudanças. Havendo necessidade de mudança, há o preenchimento de um formulário, enviando para o responsável de SI. Há avaliação e o envio para a aprovação do Wesley e/ou da Thais. A aprovação é feita por e-mail, mas o objetivo é utilizar o GLPI para fazer as mudanças. Após a aprovação, ou ela já é implementada ou entra na lista de agendamento para realização.

6.11.2.4 - Restrições sobre mudanças em pacotes de software

Conforme

O tema é tratado no Procedimento de Controle de Mudanças. Havendo necessidade de mudança, há o preenchimento de um formulário, enviando para o responsável de SI. Há avaliação e o envio para a aprovação do Wesley e/ou da Thais. A aprovação é feita por e-mail, mas o objetivo é utilizar o GLPI para fazer as mudanças. Após a aprovação, ou ela já é implementada ou entra na lista de agendamento para realização.

6.11.2.5 - Princípios para projetar sistemas seguros

Preocupação

O Procedimento de Desenvolvimento de software estabelece:

3.2 PROJETAR SISTEMAS SEGUROS

O desenvolvimento de software seguro é essencial para proteger os dados sensíveis dos usuários e garantir a integridade do sistema. Para alcançar esse objetivo, adotamos os seguintes princípios, procedimentos e técnicas de engenharia de segurança:

Princípios:

Princípio do Menor Privilégio: Conceder acesso mínimo necessário aos usuários e aos componentes do

sistema, limitando assim o potencial de exposição a ameaças.

Princípio da Defesa em Profundidade: Implementar múltiplas camadas de segurança em todo o sistema, incluindo medidas de prevenção, detecção e resposta a ameaças.

Princípio da Segurança por Design: Integrar a segurança desde a fase inicial do desenvolvimento do software, considerando aspectos de segurança em todos os aspectos do design e arquitetura do sistema.

Princípio da Visibilidade e Controle: Monitorar constantemente as atividades do sistema e manter a capacidade de controlar e responder a eventos de segurança de maneira eficaz.

Foram identificadas medidas de segurança como controle de acesso, utilização de antivírus, firewall, dentre outras, contudo, foi constatado que não são feitas avaliações de riscos de SI nem de privacidade antes dos projetos.

Ainda, foram apresentados em auditoria documentos de status report, especificação técnica e especificação funcional do cliente Naturapay.

PP 17: O cenário apresentado demonstra um comprometimento com os princípios da engenharia de sistemas seguros, no entanto, há um ponto de preocupação relevante, pois não são realizadas avaliações de riscos de segurança da informação e privacidade antes dos projetos, o que pode comprometer a segurança geral dos sistemas desenvolvidos. A ausência de uma análise de riscos formalizada significa que possíveis vulnerabilidades não são identificadas e tratadas de maneira preventiva, podendo resultar em falhas críticas de segurança ao longo do ciclo de vida do software. Sem essa etapa, o projeto pode apresentar exposição a ameaças como vazamento de dados, falhas de autenticação e insegurança na comunicação. Para mitigar essa preocupação, é fundamental que a organização integre avaliações de riscos de SI e privacidade como parte do ciclo de desenvolvimento, garantindo que todos os princípios documentados sejam efetivamente aplicados na prática e não apenas descritos no Procedimento.

6.11.2.6 - Ambiente seguro para desenvolvimento

Conforme

Em auditoria, foram demonstrados os ambientes de desenvolvimento e de produção, via ferramenta Cloudstack. Os testes são realizados dentro do ambiente de desenvolvimento e muitas vezes, o desenvolvimento é feito na máquina local, e posteriormente, publicado para a máquina de teste.

6.11.2.7 - Desenvolvimento terceirizado

Não Aplicável

Foi constatado, em auditoria, que os desenvolvedores PJs são classificados como internos, eis que trabalham exclusivamente para a ALWAYS ON, seguem as diretrizes internas da empresa, utilizam a infraestrutura da empresa e têm acesso contínuo a informações.

6.11.2.8 - Teste de segurança do sistema

Preocupação

Os testes para desenvolvimentos internos são realizados no ambiente de desenvolvimento e para projetos dos clientes, são utilizadas as ferramentas dos clientes.

Em auditoria, foi apresentado um plano básico de testes do cliente Santander, mas sem relatórios de resultados e verificação de eficácia referentes aos testes realizados. Ainda, foi informado que são realizados testes somente com dados fictícios.

PP 18: O fato de os testes serem realizados apenas no ambiente de desenvolvimento, sem uma estrutura formalizada para testes de segurança, pode comprometer a detecção e mitigação de vulnerabilidades antes da implementação em produção. Também, apesar da apresentação de um plano básico de testes para o cliente Santander, não foram evidenciados relatórios de resultados e verificação da eficácia dos testes realizados, e a ausência de documentação formal impede a rastreabilidade e a melhoria contínua do processo de segurança, dificultando a análise de riscos.

6.11.2.9 - Teste de aceitação de sistemas

Preocupação

Os testes para desenvolvimentos internos são realizados no ambiente de desenvolvimento e para projetos dos clientes, são utilizadas as ferramentas dos clientes.

Em auditoria, foi apresentado um plano básico de testes do cliente Santander, mas sem relatórios de resultados e verificação de eficácia referentes aos testes realizados. Ainda, foi informado que são realizados testes somente com dados fictícios.

PP 18: O fato de os testes serem realizados apenas no ambiente de desenvolvimento, sem uma estrutura formalizada para testes de segurança, pode comprometer a detecção e mitigação de vulnerabilidades antes da implementação em produção. Também, apesar da apresentação de um plano básico de testes para o cliente Santander, não foram evidenciados relatórios de resultados e verificação da eficácia dos testes realizados, e a ausência de documentação formal impede a rastreabilidade e a melhoria contínua do processo de segurança, dificultando a análise de riscos.

6.11.3 - Dados para teste

6.11.3.1 - Proteção dos dados para teste

Não Conforme

Foi verificado, em entrevista, que foi realizado um pentest em 2022, com a empresa ESecurity e foi mostrado um pentest da Equinix, de 2023, todavia, após essa data não foram realizados mais testes de penetração.

Ainda, o tema é tratado no Plano de Testes de Continuidade, todavia o documento está desatualizado. Por exemplo: não há realização de testes de phishing com o RH, o prazo de testes do fornecedor Equinix não foi confirmado e o formulário "FO Registro de Testes de Continuidade" mencionado no referido procedimento não é utilizado.

NC Menor 21: A ausência de pentests após 2023 indica que a organização não está realizando verificações regulares da segurança dos seus sistemas, o que pode levar à manutenção de vulnerabilidades desconhecidas. A norma exige que informações de teste sejam gerenciadas e protegidas, o que inclui a realização periódica de testes para identificar falhas e corrigir possíveis riscos. Sem essa prática contínua, há um risco significativo de exposição a ataques cibernéticos, especialmente considerando a evolução constante das ameaças digitais. Em complemento, a desatualização do Plano de Testes de Continuidade agrava essa não conformidade, pois compromete a confiabilidade das diretrizes estabelecidas para a proteção e gerenciamento das informações de teste. A ausência de testes de phishing com o RH, a falta de confirmação dos prazos de testes com fornecedores e a não utilização do formulário de registro evidenciam um desalinhamento entre a documentação e a prática real.

6.12 - Relacionamento na cadeia de suprimento

6.12.1 - Segurança da informação na cadeia de suprimento

Não Conforme

NC Maior 05: Foram constatadas falhas críticas no processo de gestão de fornecedores da ALWAYS ON como ter um procedimento desatualizado, a falta de evidências com relação as avaliações de fornecedores; não listar seus fornecedores críticos; a ausência de instrumento contratual com o fornecedor Simionato; a falta de monitoramento e análise crítica dos fornecedores, não cumprindo, dessa forma, o que estabelecem os controles 6.12.1.1, 6.12.1.2, 6.12.1.3, 6.12.2.1 e 6.12.2.2 da ISO 27701/2019.

6.12.1.1 - Política de segurança da informação no relacionamento com os fornecedores

Não Conforme

NC Maior 05: Foram constatadas falhas críticas no processo de gestão de fornecedores da ALWAYS ON como ter um procedimento desatualizado, a falta de evidências com relação as avaliações de fornecedores; não listar seus fornecedores críticos; a ausência de instrumento contratual com o fornecedor Simionato; a falta de monitoramento e análise crítica dos fornecedores, não cumprindo, dessa forma, o que estabelecem os controles 6.12.1.1, 6.12.1.2, 6.12.1.3, 6.12.2.1 e 6.12.2.2 da ISO 27701/2019.

6.12.1.2 - Identificando segurança da informação nos acordos com fornecedores

Não Conforme

NC Maior 05: Foram constatadas falhas críticas no processo de gestão de fornecedores da ALWAYS ON como ter um procedimento desatualizado, a falta de evidências com relação as avaliações de fornecedores; não listar seus fornecedores críticos; a ausência de instrumento contratual com o fornecedor Simionato; a falta de monitoramento e análise crítica dos fornecedores, não cumprindo, dessa forma, o que estabelecem os controles 6.12.1.1, 6.12.1.2, 6.12.1.3, 6.12.2.1 e 6.12.2.2 da ISO 27701/2019.

6.12.1.3 - Cadeia de suprimento na tecnologia da informação

Não Conforme

e comunicação

NC Maior 05: Foram constatadas falhas críticas no processo de gestão de fornecedores da ALWAYS ON como ter um procedimento desatualizado, a falta de evidências com relação as avaliações de fornecedores; não listar seus fornecedores críticos; a ausência de instrumento contratual com o fornecedor Simionato; a falta de monitoramento e análise crítica dos fornecedores, não cumprindo, dessa forma, o que estabelecem os controles 6.12.1.1, 6.12.1.2, 6.12.1.3, 6.12.2.1 e 6.12.2.2 da ISO 27701/2019.

6.12.2 - Gerenciamento da entrega do serviço do fornecedor

6.12.2.1 - Monitoramento e análise crítica de serviços com fornecedores

Não Conforme

NC Maior 05: Foram constatadas falhas críticas no processo de gestão de fornecedores da ALWAYS ON como ter um procedimento desatualizado, a falta de evidências com relação as avaliações de fornecedores; não listar seus fornecedores críticos; a ausência de instrumento contratual com o fornecedor Simionato; a falta de monitoramento e análise crítica dos fornecedores, não cumprindo, dessa forma, o que estabelecem os controles 6.12.1.1, 6.12.1.2, 6.12.1.3, 6.12.2.1 e 6.12.2.2 da ISO 27701/2019.

6.12.2.2 - Gerenciamento de mudanças para serviços com fornecedores

Não Conforme

NC Maior 05: Foram constatadas falhas críticas no processo de gestão de fornecedores da ALWAYS ON como ter um procedimento desatualizado, a falta de evidências com relação as avaliações de fornecedores; não listar seus fornecedores críticos; a ausência de instrumento contratual com o fornecedor Simionato; a falta de monitoramento e análise crítica dos fornecedores, não cumprindo, dessa forma, o que estabelecem os controles 6.12.1.1, 6.12.1.2, 6.12.1.3, 6.12.2.1 e 6.12.2.2 da ISO 27701/2019.

6.13 - Gestão de incidentes de segurança da informação

6.13.1 - Gestão de incidentes de segurança da informação e melhorias

6.13.1.1 - Responsabilidades e procedimentos

Não Conforme

Há um Procedimento de Gerenciamento de Incidentes, mas nele não constam os papéis e responsabilidades referentes à SI e o procedimento de comunicação incidentes escrito não condiz com o que acontece na realidade.

Segundo informações do Diretor Wesley, durante a entrevista, para o reporte de incidentes é utilizado um formulário em Excel chamado FO de Gestão de Incidentes. O formulário é enviado ao Alexandre Rocha e ele traz a demanda para o GLPI (o objetivo é passar toda gestão de incidentes para o GLPI). Contudo, foi verificado que, na prática, isso não ocorre.

Foi apresentando um Procedimento de Preparação e Resposta à Emergências, mas tem apenas um parágrafo genérico sobre emergências e riscos e foca na parte da brigada de incêndio somente. Foi verificado que a empresa não tem um plano de resposta a incidentes, não tem registros de relatórios de incidentes nem de lições aprendidas.

Em que pese existir um procedimento e o uso parcial da ferramenta GLPI, foram identificadas falhas críticas no processo de gestão de incidentes que comprometem a plena conformidade com os controles 6.13.1.1 e outros relacionados da ISO 27701/2019. As evidências objetivas das lacunas incluem a ausência de critérios claros para priorização de atendimentos, análises e respostas a incidentes, o que pode levar a uma gestão ineficaz de situações críticas. Também, não há registros consistentes de eventos e análises de incidentes, indicando uma falha na documentação e rastreabilidade dos processos.

Outra falha identificada é a inexistência de diretrizes estabelecidas para a coleta, preservação e cadeia de custódia de evidências em casos de incidentes, o que compromete a capacidade de análise técnica e o suporte a eventuais ações corretivas ou legais. Por fim, não foram encontradas evidências de que a

organização esteja realizando análises pós-incidente para aprendizado, limitando as oportunidades de melhoria contínua no sistema de gestão.

Embora exista uma base documentada para o gerenciamento de incidentes, as falhas mencionadas demonstram a necessidade urgente de revisões e aprimoramentos no processo. É essencial estabelecer critérios claros para priorização, registrar e analisar todos os incidentes de forma consistente, e implementar diretrizes para a preservação de evidências. Ademais, a criação de processos para capturar lições aprendidas fortalecerá o sistema de gestão e alinhará as práticas da organização aos requisitos normativos.

NC Maior 06: Foram constatadas falhas críticas no processo de gestão de incidentes, contrariando assim os controles 6.13.1.1, 6.13.1.4, 6.13.1.5, 6.13.1.6 e 6.13.1.7 da ISO 27701/2019. Evidências Objetivas: 1. Falta de critérios claros para priorização dos atendimentos, análises e respostas dos incidentes; 2. Falta de evidências objetivas sobre a realização de registros de eventos e análises de incidentes; 3. Falta de diretrizes estabelecidas para coleta, preservação e cadeia de custódia de eventuais evidências dos incidentes; 4. Não há nenhum documento que fale sobre o tema Lições Aprendidas, tampouco há relatórios ou comunicações sobre o tema.

6.13.1.2 - Notificação de eventos de segurança da informação

Oportunidade de Melhoria

Foi verificado, em entrevista, que para relato de eventos é utilizado o e-mail, "ouvidoria@aodigital.com.br", sem um formulário específico.

OM 08: Atualmente, a organização utiliza apenas um e-mail para relatos, sem um formulário estruturado ou um sistema dedicado para capturar informações de forma detalhada e organizada, podendo levar a relatos incompletos, falta de rastreabilidade e dificuldades na triagem e resposta a eventos e/ou incidentes. A implementação de um formulário padronizado garantiria que todos os incidentes fossem relatados com os detalhes essenciais, como data, tipo de evento, sistemas afetados e impacto percebido, facilitando uma resposta ágil e eficiente. Outra oportunidade de melhoria seria a adoção de um canal mais estruturado, como uma plataforma de gestão de incidentes, que permita rastreamento, notificação e resposta automatizada. Em complemento, campanhas de conscientização poderiam ser realizadas para garantir que os colaboradores saibam quando e como relatar um evento de segurança. Essas melhorias não apenas aumentariam a conformidade com a norma, mas também fortaleceriam a capacidade de resposta a incidentes da organização.

6.13.1.3 - Notificando fragilidades de segurança da informação

Oportunidade de Melhoria

Foi verificado, em entrevista, que para relato de eventos é utilizado o e-mail, "ouvidoria@aodigital.com.br", sem um formulário específico.

OM 08: Atualmente, a organização utiliza apenas um e-mail para relatos, sem um formulário estruturado ou um sistema dedicado para capturar informações de forma detalhada e organizada, podendo levar a relatos incompletos, falta de rastreabilidade e dificuldades na triagem e resposta a eventos e/ou incidentes. A implementação de um formulário padronizado garantiria que todos os incidentes fossem relatados com os detalhes essenciais, como data, tipo de evento, sistemas afetados e impacto percebido, facilitando uma resposta ágil e eficiente. Outra oportunidade de melhoria seria a adoção de um canal mais estruturado, como uma plataforma de gestão de incidentes, que permita rastreamento, notificação e resposta automatizada. Em complemento, campanhas de conscientização poderiam ser realizadas para garantir que os colaboradores saibam quando e como relatar um evento de segurança. Essas melhorias não apenas aumentariam a conformidade com a norma, mas também fortaleceriam a capacidade de resposta a incidentes da organização.

6.13.1.4 - Avaliação e decisão dos eventos de segurança da informação

Não Conforme

NC Maior 06: Foram constatadas falhas críticas no processo de gestão de incidentes, contrariando assim os controles 6.13.1.1, 6.13.1.4, 6.13.1.5, 6.13.1.6 e 6.13.1.7 da ISO 27701/2019. Evidências Objetivas: 1. Falta de critérios claros para priorização dos atendimentos, análises e respostas dos incidentes; 2. Falta de evidências objetivas sobre a realização de registros de eventos e análises de incidentes; 3. Falta de diretrizes estabelecidas para coleta, preservação e cadeia de custódia de eventuais evidências dos incidentes; 4. Não há nenhum documento que fale sobre o tema Lições Aprendidas, tampouco há relatórios ou comunicações sobre o tema.

6.13.1.5 - Resposta aos incidentes de segurança da informação

Não Conforme

NC Maior 06: Foram constatadas falhas críticas no processo de gestão de incidentes, contrariando assim os controles 6.13.1.1, 6.13.1.4, 6.13.1.5, 6.13.1.6 e 6.13.1.7 da ISO 27701/2019. Evidências Objetivas: 1. Falta de critérios claros para priorização dos atendimentos, análises e respostas dos incidentes; 2. Falta de evidências objetivas sobre a realização de registros de eventos e análises de incidentes; 3. Falta de diretrizes estabelecidas para coleta, preservação e cadeia de custódia de eventuais evidências dos incidentes; 4. Não há nenhum documento que fale sobre o tema Lições Aprendidas, tampouco há relatórios ou comunicações sobre o tema.

6.13.1.6 - Aprendendo com os incidentes de segurança da informação

Não Conforme

NC Maior 06: Foram constatadas falhas críticas no processo de gestão de incidentes, contrariando assim os controles 6.13.1.1, 6.13.1.4, 6.13.1.5, 6.13.1.6 e 6.13.1.7 da ISO 27701/2019. Evidências Objetivas: 1. Falta de critérios claros para priorização dos atendimentos, análises e respostas dos incidentes; 2. Falta de evidências objetivas sobre a realização de registros de eventos e análises de incidentes; 3. Falta de diretrizes estabelecidas para coleta, preservação e cadeia de custódia de eventuais evidências dos incidentes; 4. Não há nenhum documento que fale sobre o tema Lições Aprendidas, tampouco há relatórios ou comunicações sobre o tema.

6.14 - Aspectos da segurança da informação na gestão da continuidade do negócio**6.14.1 - Continuidade da segurança da informação****6.14.1.2 - Implementando a continuidade da segurança da informação**

Preocupação

O tema interrupção, especificamente, não é tratado em nenhum documento.

Foi verificado, em auditoria, que há um Plano de Continuidade de Negócios, mas que se confunde com um Plano de Recuperação de Desastres (não há documento específico sobre recuperação de desastres). O PCN apresentado trata extensivamente da recuperação da infraestrutura de TI, mas não aborda em detalhes todos os aspectos de um PCN abrangente.

Foi evidenciado, também, que são feitos testes de redundância em servidores.

PP 11: Embora exista um PCN, ele aparenta se confundir com um Plano de Recuperação de Desastres (PRD), sem distinção clara entre as estratégias de continuidade de operações críticas e as de restauração de infraestrutura e sistemas. Essa falta de delimitação compromete a eficácia do plano durante situações de crise, pois cada tipo de plano possui objetivos, escopos e respostas distintas. Em complemento, apesar da existência de testes de redundância em servidores, esses controles técnicos isolados não garantem, por si só, a manutenção da confidencialidade, integridade e disponibilidade das informações durante todo o período de interrupção. É necessário haver um plano estruturado e documentado, com responsabilidades definidas, procedimentos operacionais, estratégias de comunicação e salvaguardas específicas para segurança da informação, incluindo medidas para. A ausência de um documento específico e segregado sobre o PRD também dificulta a resposta coordenada e o cumprimento do controle de forma robusta.

6.14.1.3 - Verificação, análise crítica e avaliação da continuidade da segurança da informação

Preocupação

O tema interrupção, especificamente, não é tratado em nenhum documento.

Foi verificado, em auditoria, que há um Plano de Continuidade de Negócios, mas que se confunde com um Plano de Recuperação de Desastres (não há documento específico sobre recuperação de desastres). O PCN apresentado trata extensivamente da recuperação da infraestrutura de TI, mas não aborda em detalhes todos os aspectos de um PCN abrangente.

Foi evidenciado, também, que são feitos testes de redundância em servidores.

PP 11: Embora exista um PCN, ele aparenta se confundir com um Plano de Recuperação de Desastres (PRD), sem distinção clara entre as estratégias de continuidade de operações críticas e as de restauração de infraestrutura e sistemas. Essa falta de delimitação compromete a eficácia do plano durante situações de crise, pois cada tipo de plano possui objetivos, escopos e respostas distintas. Em complemento, apesar da existência de testes de redundância em servidores, esses controles técnicos isolados não garantem, por si só, a manutenção da confidencialidade, integridade e disponibilidade das informações durante todo o período de disrupção. É necessário haver um plano estruturado e documentado, com responsabilidades definidas, procedimentos operacionais, estratégias de comunicação e salvaguardas específicas para segurança da informação, incluindo medidas para. A ausência de um documento específico e segregado sobre o PRD também dificulta a resposta coordenada e o cumprimento do controle de forma robusta.

6.14.2 - Redundâncias

6.14.2.1 - Disponibilidade dos recursos de processamento da informação

Conforme

O tema é tratado no Procedimento de Infra de TI 2. Foram demonstradas as ferramentas Cloudstack, em que há três redundâncias de servidores e Azure, que já tem a redundância automática.

6.15 - Compliance

6.15.1 - Compliance com requisitos legais e contratuais

.Em que pese a empresa demonstrar a adoção de medidas de segurança estabelecidas em lei (há comprovações de utilização de ferramentas de antivírus, monitoramentos, bloqueios, treinamentos etc.), por exemplo, em auditoria, foi constatado que a empresa não listou quais as legislações se aplicam à empresa, nem utiliza ferramentas para monitoramento de legislações. PP 12: Este controle exige que a organização identifique, documente e mantenha atualizados os requisitos legais, estatutários, regulamentares e contratuais pertinentes à segurança da informação e, sem essa identificação formalizada, a empresa pode operar sem conhecer integralmente suas obrigações legais, aumentando o risco de não conformidade com legislações vigentes e aplicáveis. Em complemento, a ausência de uma ferramenta de monitoramento de legislação representa um risco contínuo para a atualização dos requisitos legais da empresa. Mudanças regulatórias ocorrem frequentemente, e sem um mecanismo eficaz para acompanhar essas atualizações, a organização pode falhar na adoção tempestiva de medidas de adequação, resultando em exposição a penalidades legais e falhas de governança corporativa. Para mitigar esses riscos, a empresa deve estabelecer um processo formal de identificação e acompanhamento das legislações aplicáveis e implementar um sistema de monitoramento regulatório, garantindo a conformidade contínua e a minimização de riscos jurídicos.

6.15.1.1

Em que pese a empresa demonstrar a adoção de medidas de segurança estabelecidas em lei (há comprovações de utilização de ferramentas de antivírus, monitoramentos, bloqueios, treinamentos etc.), por exemplo, em auditoria, foi constatado que a empresa não listou quais as legislações se aplicam à empresa, nem utiliza ferramentas para monitoramento de legislações.

PP 12: Este controle exige que a organização identifique, documente e mantenha atualizados os requisitos legais, estatutários, regulamentares e contratuais pertinentes à segurança da informação e, sem essa identificação formalizada, a empresa pode operar sem conhecer integralmente suas obrigações legais, aumentando o risco de não conformidade com legislações vigentes e aplicáveis. Em complemento, a ausência de uma ferramenta de monitoramento de legislação representa um risco contínuo para a atualização dos requisitos legais da empresa. Mudanças regulatórias ocorrem frequentemente, e sem um mecanismo eficaz para acompanhar essas atualizações, a organização pode falhar na adoção tempestiva de medidas de adequação, resultando em exposição a penalidades legais e falhas de governança corporativa. Para mitigar esses riscos, a empresa deve estabelecer um processo formal de identificação e acompanhamento das legislações aplicáveis e implementar um sistema de monitoramento regulatório, garantindo a conformidade contínua e a minimização de riscos jurídicos.

6.15.1.2 - Direitos de propriedade intelectual

Conforme

No contrato com a empresa MARTINELLI E PESSOA LTDA. foram localizadas cláusulas que tratam sobre

propriedade intelectual. Foi verificado, em auditoria, que o Bitdefender faz um controle de licenças, a fim de evitar o uso de pirataria. Foram apresentadas telas do Bitdefender e do AD, demonstrando que há bloqueios que não permitem que os colaboradores baixem programas piratas.

6.15.1.3 - Proteção de registros

Oportunidade de Melhoria

Não há um procedimento específico sobre o tema, mas a proteção de registros é tratada, por exemplo, na PSI, na Política de Uso e Controle de Acessos, No Procedimento de Tratamento de Dados Pessoais e no Procedimento de Controle de Informação Documentada.

Também, há evidências de proteção de registros pelo uso de antivírus (BitDefender), firewall (Fortinet), realização de criptografia (Bitlocker), realização de backups e controle de acessos físicos e lógicos.

OM 07: A fragmentação do tema entre diferentes políticas e procedimentos pode levar a inconsistências na aplicação e monitoramento das práticas de segurança. O uso de ferramentas como BitDefender para proteção contra malware, Bitlocker para criptografia, além do controle de acessos, demonstra boas práticas, mas a falta de um documento consolidado e abrangente pode dificultar a rastreabilidade e a governança eficaz sobre os registros. É recomendável que a organização elabore um procedimento específico que integre e detalhe as práticas existentes, garantindo que todos os registros sejam protegidos de forma uniforme contra perda, acesso não autorizado e outros riscos.

6.15.1.4 - Proteção e privacidade de DP

Não Conforme

NC Menor 14: Durante a auditoria, foi verificado que a política de privacidade que consta no site da empresa está desatualizada e não tem informações importantes sobre direitos dos titulares nem sobre o Encarregado pelo Tratamento de Dados Pessoais (não há um Encarregado nomeado formalmente), não há inventário de dados pessoais (ROPA), não há definições de bases legais (é utilizada, por exemplo, a base de consentimento na área de marketing, mas a gestão dos consentimentos não é realizada) com relação aos tratamentos de dados pessoais nem a elaboração de relatórios de impacto à proteção de dados pessoais, documentos essenciais para avaliar os riscos e adotar medidas preventivas adequadas. Em complemento, foi verificado que a organização não tem um procedimento nem fluxo para atendimento aos titulares de dados pessoais, contrariando o que estabelece a norma e a LGPD. É imprescindível que a organização invista em cursos e especializações sobre privacidade e proteção de dados pessoais, bem como considere a contratação de uma consultoria especializada em privacidade e proteção de dados pessoais, a fim de atingir conhecimento e maturidade no tema.

6.15.1.5 - Regulamentação de controles de criptografia

Conforme

O tema é tratado na Política de Controle Criptográfico. Em auditoria, foi constatado que todos os dispositivos são criptografados. São utilizadas as ferramentas Bitlocker, Fortinet e Azure, demonstradas em entrevista.

6.15.2 - Análise crítica da segurança da informação

6.15.2.1 - Análise crítica independente da segurança da informação

Não Conforme

NC Menor 15: Foi constatado que, até a data da realização desta auditoria interna, não foram realizadas análises críticas independentes.

6.15.2.2 - Compliance com as políticas e normas de segurança da informação

Não Conforme

NC Menor 16: Foi verificado que algumas políticas e procedimento estabelecem regras que não são cumpridas na prática. Evidências objetivas: O Procedimento de Gerenciamento de Incidentes descreve um fluxo que não ocorre na prática. A Política de Privacidade que consta no site (<https://aodigital.com.br/o-que-e-politica-de-privacidade/>) da empresa está desatualizada e não menciona os direitos dos titulares nem um canal de para atendimentos dos seus direitos. A empresa não nomeou formalmente um Encarregado pelo Tratamento de Dados Pessoais. O Procedimento de Aquisição descreve um fluxo que não ocorre na prática.

6.15.2.3 - Análise crítica técnica do compliance

Não Conforme

NC Menor 16: Foi verificado que algumas políticas e procedimento estabelecem regras que não são cumpridas na prática. Evidências objetivas: O Procedimento de Gerenciamento de Incidentes descreve um fluxo que não ocorre na prática. A Política de Privacidade que consta no site (<https://aodigital.com.br/o-que-e-politica-de-privacidade/>) da empresa está desatualizada e não menciona os direitos dos titulares nem um canal de para atendimentos dos seus direitos. A empresa não nomeou formalmente um Encarregado pelo Tratamento de Dados Pessoais. O Procedimento de Aquisição descreve um fluxo que não ocorre na prática.

Fotos

7 Diretrizes adicionais da ABNT NBR ISO/IEC 27002 para controladores de DP

7.2 - Condições para coleta e tratamento

7.2.1 - Identificação e documentação do propósito

Não Conforme

NC Menor 01: Foi identificado em auditoria que a empresa não elaborou um inventário que documentasse e identificasse os propósitos específicos pelos quais os dados pessoais são tratados.

7.2.2 - Identificação de bases legais

Não Conforme

NC Menor 02: Foi identificado, em auditoria, que a empresa não determinou nem documentou as bases legais referentes aos tratamentos de dados pessoais realizados.

7.2.3 - Determinando quando e como o consentimento deve ser obtido

Não Conforme

NC Menor 03: Em que pese a área de Marketing realizar tratamentos de dados pessoais baseados em consentimento, não há um procedimento que trate especificamente sobre como o consentimento é coletado e como é feita a gestão dos consentimentos. O consentimento é coletado, por exemplo, quando alguém se interessa por algum conteúdo ou serviço da empresa e preenche o formulário que consta no site da ALWAYS ON. Ainda, foi verificado que há a utilização de termos de consentimento de forma errônea, quando a base legal para o tratamento de dados pessoais deveria ser outra.

7.2.4 - Obtendo e registrando o consentimento

Preocupação

Foi verificado, em entrevista, que não há um procedimento específico que trate sobre o tema consentimento. Foi apresentado, em entrevista, via plataforma sharpspring, uma tela com informações de um cliente que fez opt-in preenchendo o formulário que consta no site da empresa, todavia, não há um processo que demonstre que o consentimento foi devidamente obtido, registrado e gerenciado.

PP 01: Sem um processo documentado, a empresa não consegue demonstrar, de forma clara e auditável, que o consentimento foi obtido de maneira válida, informada e inequívoca. Outro ponto crítico é o risco de uso indevido do consentimento, especialmente se a base legal correta para o tratamento dos dados pessoais não for avaliada corretamente. Sem um sistema eficaz de rastreamento, há dificuldades em comprovar que os dados estão sendo usados conforme a permissão concedida, além de desafios para atender solicitações de revogação do consentimento, conforme previsto na ISO e na LGPD. Para mitigar essas falhas, a empresa deve implementar um processo estruturado e documentado, garantindo registros claros e mecanismos que permitam a gestão transparente do consentimento ao longo do tempo.

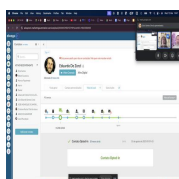


Foto 5

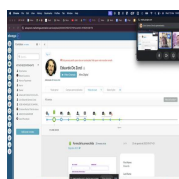


Foto 6

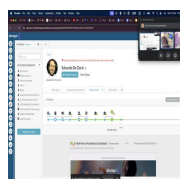


Foto 7

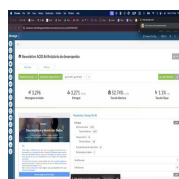


Foto 8

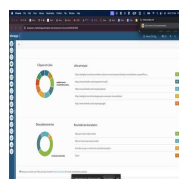


Foto 9

7.2.5 - Avaliação de impacto de privacidade

Preocupação

Foi verificado um documento nomeado "Relatório de Impacto de Dados Pessoais" que menciona dados de campanhas publicitárias, mas a justificativa do documento não está muito clara e o campo de ciclo de vida está muito limitado. Ainda, não há relatórios de impactos com relação à outros processos.

PP 02: Convém que a organização determine os elementos que são necessários para uma avaliação de impacto de privacidade completa, podendo incluir uma lista dos tipos de DP tratados, onde o DP é armazenado e onde ele pode ser transferido. Diagramas de fluxos de dados e mapas de dados podem também ser úteis neste contexto.

[RIPD.pdf](#)

7.2.6 - Contratos com operadores de DP

Conforme

Em entrevista, foi verificado o contrato do fornecedor Santander, demonstrando cláusulas de proteção de dados pessoais.

[CW254386-Manifesto \(1\).pdf](#)

7.2.7 - Controlador conjunto de DP

Não Aplicável

Em entrevista, o Diretor Wesley Ruiz informou que a empresa fez uma análise e não há controladoria conjunta com qualquer outra organização.

7.2.8 - Registros relativos ao tratamento de DP

Preocupação

Foi apresentado, em entrevista, um documento nomeado "Manifestação de Dados Pessoais", mostrando registro de alguns dados, mas o documentos não está completo, e com alguns campos não assinalados.

PP 03: É fundamental que o ROPA seja realizado com base em todos os processos dentro da organização que envolvam dados pessoais. Esse documento deve abranger todos os processos da empresa que tratem dados pessoais, pois cada operação (como coleta, armazenamento, compartilhamento ou exclusão) pode gerar riscos diferentes à privacidade dos titulares. A ausência de um registro abrangente pode resultar em lacunas no gerenciamento de riscos, dificultando a demonstração de conformidade em auditorias ou fiscalizações pela Autoridade Nacional de Proteção de Dados (ANPD). Ademais, o registro com base em todos os processos facilita a identificação de vulnerabilidades e ajustes necessários para atender o que estabelece a norma ISO e aos princípios da LGPD, como minimização de dados e segurança. O registro também é fundamental para documentar a base legal do tratamento de dados pessoais em cada processo, servindo não apenas para cumprir a norma e a legislação, mas também como ferramenta de gestão para proteger a privacidade dos titulares e mitigar os riscos de sanções administrativas.

7.3 - Obrigações dos titulares de DP

7.3.1 - Determinando e cumprindo as obrigações para os titulares de DP

Não Conforme

NC Maior 01: A política de privacidade verificada no site da empresa, na data de 12/03/2025, não menciona os direitos dos titulares nem um canal para atendimentos dos seus direitos, conforme prints anexos. Além de não ter um Encarregado pelo Tratamento de Dados pessoais nomeado, a empresa não tem um procedimento nem um fluxo para atendimento às demandas dos titulares. Em auditoria, foi verificado que a empresa não criou processos e estruturas que permitam o atendimento aos titulares, nem cumprir os requisitos A.7.3.1 até A.7.3.9, configurando, dessa forma, uma NC Maior no que se refere ao controle 7.3 Obrigações para os Titulares de DP.

Modificações

Política de Privacidade não menciona os direitos dos titulares e qualquer mecanismo, sem aviso prévio.

Assim sendo, você concorda em não enviar dados pessoais de acordo com a política de privacidade.

Lei aplicável

Esta política de privacidade é regida e interpretada de acordo com as leis do Brasil e a legislação brasileira.

Política de Privacidade

Política de Privacidade

Precisão dos materiais

Os materiais enviados no site da empresa não incluem informações, informações e informações. A empresa não garante que qualquer material em seu site seja preciso, completo ou atual.

A empresa não garante que qualquer material em seu site seja preciso, completo ou atual.

Adicionalmente, a empresa não garante que qualquer material em seu site seja preciso, completo ou atual.

6. Links

A inclusão de qualquer link não implica endosso por parte da empresa.

O uso de qualquer site vinculado é por conta e risco do usuário.

Limitações

Em nenhum caso a empresa se responsabiliza por danos ou danos decorrentes do uso de qualquer material em seu site.

Inclusão, sem limitação, de dados pessoais ou dados de terceiros.

Inclusão, sem limitação, de dados pessoais ou dados de terceiros.

Como algumas jurisdições não permitem limitações em garantias implícitas, ou limitações de responsabilidade por danos consequentes ou incidentais, essas limitações podem não se aplicar a você.

Isenção de responsabilidade

A empresa não oferece garantias, expressas ou implícitas, e, por isso, não assume responsabilidade por danos pessoais, materiais ou danos de qualquer natureza decorrentes do uso de qualquer material em seu site.

A empresa não oferece garantias, expressas ou implícitas, e, por isso, não assume responsabilidade por danos pessoais, materiais ou danos de qualquer natureza decorrentes do uso de qualquer material em seu site.

1. Termos

Assim sendo, você concorda em cumprir os termos da política de privacidade e de qualquer outro documento que a empresa possa publicar, atualizar ou modificar sem aviso prévio.

Se você não concorda com algum desses termos, está proibido de usar ou acessar este site.

2. Uso de Licença

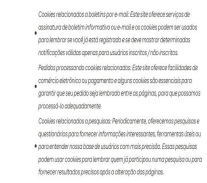
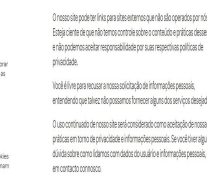
O site da empresa não concede permissão para que você não compartilhe uma cópia dos materiais (informações ou conteúdo) apenas para visualização pessoal e não comercial.

Esta política de privacidade é uma política de privacidade de caráter geral e não se aplica a todos os produtos e serviços oferecidos pela empresa.

Mais informações

Esta política de privacidade é uma política de privacidade de caráter geral e não se aplica a todos os produtos e serviços oferecidos pela empresa.

Esta política de privacidade é uma política de privacidade de caráter geral e não se aplica a todos os produtos e serviços oferecidos pela empresa.

 Cookies de Terceiros Em alguns casos, também usamos cookies fornecidos por terceiros confiáveis. A seguir, apresentamos uma lista dos cookies de terceiros que usamos em nosso site. Este site usa o Google Analytics, que é um serviço de análise web para ajudar a entender como os visitantes usam o site e melhorar a experiência deles. • Para analisar o uso do site e melhorar a experiência do usuário. • Para analisar o uso do site e melhorar a experiência do usuário.	 Cookies de Terceiros Em alguns casos, também usamos cookies fornecidos por terceiros confiáveis. A seguir, apresentamos uma lista dos cookies de terceiros que usamos em nosso site. Este site usa o Google Analytics, que é um serviço de análise web para ajudar a entender como os visitantes usam o site e melhorar a experiência deles. • Para analisar o uso do site e melhorar a experiência do usuário. • Para analisar o uso do site e melhorar a experiência do usuário.	 Desativar cookies Você pode impedir a configuração de cookies ajustando as configurações do seu navegador (conforme a ajuda do navegador para o site que você está visitando). No entanto, algumas partes do site podem não funcionar corretamente se você desativar os cookies. • Para desativar os cookies, vá para as configurações do seu navegador e desative os cookies. • Para desativar os cookies, vá para as configurações do seu navegador e desative os cookies.	 Política de Cookies Always ON O que são cookies? Como política corporativa, usamos cookies para melhorar a experiência do usuário e para fornecer informações sobre o uso do site. Os cookies são pequenos arquivos de texto que são armazenados no seu navegador e que permitem que o site lembre de você e da sua preferência. • Para melhorar a experiência do usuário e fornecer informações sobre o uso do site. • Para melhorar a experiência do usuário e fornecer informações sobre o uso do site.	 Política de Cookies Always ON O que são cookies? Como política corporativa, usamos cookies para melhorar a experiência do usuário e para fornecer informações sobre o uso do site. Os cookies são pequenos arquivos de texto que são armazenados no seu navegador e que permitem que o site lembre de você e da sua preferência. • Para melhorar a experiência do usuário e fornecer informações sobre o uso do site. • Para melhorar a experiência do usuário e fornecer informações sobre o uso do site.	 Política de Cookies Always ON O que são cookies? Como política corporativa, usamos cookies para melhorar a experiência do usuário e para fornecer informações sobre o uso do site. Os cookies são pequenos arquivos de texto que são armazenados no seu navegador e que permitem que o site lembre de você e da sua preferência. • Para melhorar a experiência do usuário e fornecer informações sobre o uso do site. • Para melhorar a experiência do usuário e fornecer informações sobre o uso do site.
Foto 16	Foto 17	Foto 18	Foto 19	Foto 20	Foto 21

7.3.2 - Determinando as informações para os titulares de DP

Não Conforme

NC Maior 01: A política de privacidade verificada no site da empresa, na data de 12/03/2025, não menciona os direitos dos titulares nem um canal para atendimentos dos seus direitos, conforme prints anexos. Além de não ter um Encarregado pelo Tratamento de Dados pessoais nomeado, a empresa não tem um procedimento nem um fluxo para atendimento às demandas dos titulares. Em auditoria, foi verificado que a empresa não criou processos e estruturas que permitam o atendimento aos titulares, nem cumprir os requisitos A.7.3.1 até A.7.3.9, configurando, dessa forma, uma NC Maior no que se refere ao controle 7.3 Obrigações para os Titulares de DP.

7.3.3 - Fornecendo informações aos titulares de DP

Não Conforme

NC Maior 01: A política de privacidade verificada no site da empresa, na data de 12/03/2025, não menciona os direitos dos titulares nem um canal para atendimentos dos seus direitos, conforme prints anexos. Além de não ter um Encarregado pelo Tratamento de Dados pessoais nomeado, a empresa não tem um procedimento nem um fluxo para atendimento às demandas dos titulares. Em auditoria, foi verificado que a empresa não criou processos e estruturas que permitam o atendimento aos titulares, nem cumprir os requisitos A.7.3.1 até A.7.3.9, configurando, dessa forma, uma NC Maior no que se refere ao controle 7.3 Obrigações para os Titulares de DP.

7.3.4 - Fornecendo mecanismos para modificar ou cancelar o consentimento

Não Conforme

NC Maior 01: A política de privacidade verificada no site da empresa, na data de 12/03/2025, não menciona os direitos dos titulares nem um canal para atendimentos dos seus direitos, conforme prints anexos. Além de não ter um Encarregado pelo Tratamento de Dados pessoais nomeado, a empresa não tem um procedimento nem um fluxo para atendimento às demandas dos titulares. Em auditoria, foi verificado que a empresa não criou processos e estruturas que permitam o atendimento aos titulares, nem cumprir os requisitos A.7.3.1 até A.7.3.9, configurando, dessa forma, uma NC Maior no que se refere ao controle 7.3 Obrigações para os Titulares de DP.

7.3.5 - Fornecendo mecanismos para negar o consentimento ao tratamento de DP

Não Conforme

NC Maior 01: A política de privacidade verificada no site da empresa, na data de 12/03/2025, não menciona os direitos dos titulares nem um canal para atendimentos dos seus direitos, conforme prints anexos. Além de não ter um Encarregado pelo Tratamento de Dados pessoais nomeado, a empresa não tem um procedimento nem um fluxo para atendimento às demandas dos titulares. Em auditoria, foi verificado que a empresa não criou processos e estruturas que permitam o atendimento aos titulares, nem cumprir os requisitos A.7.3.1 até A.7.3.9, configurando, dessa forma, uma NC Maior no que se refere ao controle 7.3 Obrigações para os Titulares de DP.

7.3.6 - Acesso, correção e/ou exclusão

Não Conforme

NC Maior 01: A política de privacidade verificada no site da empresa, na data de 12/03/2025, não menciona os direitos dos titulares nem um canal para atendimentos dos seus direitos, conforme prints anexos. Além de não ter um Encarregado pelo Tratamento de Dados pessoais nomeado, a empresa não tem um procedimento nem um fluxo para atendimento às demandas dos titulares. Em auditoria, foi verificado que a empresa não criou processos e estruturas que permitam o atendimento aos titulares, nem cumprir os requisitos A.7.3.1 até A.7.3.9, configurando, dessa forma, uma NC Maior no que se refere ao controle 7.3 Obrigações para os Titulares de DP.

7.3.7 - Obrigações dos controladores de DP para informar aos terceiros

Não Conforme

NC Maior 01: A política de privacidade verificada no site da empresa, na data de 12/03/2025, não menciona os direitos dos titulares nem um canal para atendimentos dos seus direitos, conforme prints anexos. Além de não ter um Encarregado pelo Tratamento de Dados pessoais nomeado, a empresa não tem um procedimento nem um fluxo para atendimento às demandas dos titulares. Em auditoria, foi verificado que a empresa não criou processos e estruturas que permitam o atendimento aos titulares, nem cumprir os requisitos A.7.3.1 até A.7.3.9, configurando, dessa forma, uma NC Maior no que se refere ao controle 7.3 Obrigações para os Titulares de DP.

7.3.8 - Fornecendo cópia do DP tratado

Não Conforme

NC Maior 01: A política de privacidade verificada no site da empresa, na data de 12/03/2025, não menciona os direitos dos titulares nem um canal para atendimentos dos seus direitos, conforme prints anexos. Além de não ter um Encarregado pelo Tratamento de Dados pessoais nomeado, a empresa não tem um procedimento nem um fluxo para atendimento às demandas dos titulares. Em auditoria, foi verificado que a empresa não criou processos e estruturas que permitam o atendimento aos titulares, nem cumprir os requisitos A.7.3.1 até A.7.3.9, configurando, dessa forma, uma NC Maior no que se refere ao controle 7.3 Obrigações para os Titulares de DP.

7.3.9 - Tratamento de solicitações

Não Conforme

NC Maior 01: A política de privacidade verificada no site da empresa, na data de 12/03/2025, não menciona os direitos dos titulares nem um canal para atendimentos dos seus direitos, conforme prints anexos. Além de não ter um Encarregado pelo Tratamento de Dados pessoais nomeado, a empresa não tem um procedimento nem um fluxo para atendimento às demandas dos titulares. Em auditoria, foi verificado que a empresa não criou processos e estruturas que permitam o atendimento aos titulares, nem cumprir os requisitos A.7.3.1 até A.7.3.9, configurando, dessa forma, uma NC Maior no que se refere ao controle 7.3 Obrigações para os Titulares de DP.

7.3.10 - Tomada de decisão automatizada

Não Aplicável

Foi informado, em entrevista, pelo Diretor Wesley Ruiz, que todos os processos automatizados têm supervisão humana.

7.4 - Privacy by Design e Privacy by Default

7.4.1 - Limite de coleta

Não Conforme

O tema é tratado na Política de Privacidade (Nomeada como Política de SI e Dados Pessoais, mas confirmado, em auditoria, que esse documento é a Política de Privacidade atualizada):

2. Coleta e Uso de Informações Pessoais

Neste sentido, todos os dados pessoais coletados e suas finalidades estão disponíveis no Mapa Geral de DP da empresa ALWAYS ON DIGITAL LTDA e o titular do dado pessoal pode solicitar as informações disponíveis em qualquer momento que julgar necessário. A empresa tem um prazo de 03 dias úteis para fornecer todas as informações.

Os dados pessoais que não se enquadram em bases legais, tais como 7º da Lei Geral de Proteção de Dados Pessoais (LGPD), Lei nº 13.709/2018, estabelece as hipóteses em que é permitido o tratamento de dados pessoais. , possuem consentimento expresso do titular para o devido tratamento.

Porém, há erros técnicos, como por exemplo, no trecho: "Os dados pessoais que não se enquadram em bases legais, tais como 7º da Lei Geral de Proteção de Dados Pessoais (LGPD), Lei nº 13.709/2018, estabelece as hipóteses em que é permitido o tratamento de dados pessoais. , possuem consentimento expresso do titular para o devido tratamento."

Ainda, a Política de Privacidade apresentada na auditoria é diferente da Política de Privacidade que consta no site da empresa, e não foram passadas informações referentes à limitação da coleta.

NC Menor 04: A não conformidade com o controle A.7.4.1 da ISO 27701/2019 decorre da falta de transparência e inconsistência nas informações sobre o tratamento de dados pessoais. A Política de Privacidade interna contém um erro técnico na explicação das bases legais da LGPD, podendo levar a interpretações errôneas, comprometendo a clareza da informação fornecida aos titulares e, consequentemente, violando o princípio da transparência exigido pela norma. Em complemento, há

divergência entre a Política de Privacidade apresentada nos auditorias e a versão disponível no site da empresa, o que compromete a confiabilidade e acessibilidade das informações prestadas ao titular dos dados. A ISO 27701 exige que as organizações garantam que todas as informações sobre privacidade sejam consistentes, precisas e facilmente acessíveis. A existência de duas versões distintas da política pode gerar confusão, minar a confiança dos titulares e até resultar em risco regulatório, caso alguma das versões não esteja alinhada com as exigências legais. Para garantir a conformidade, é essencial corrigir esses pontos, harmonizar os documentos e garantir que a comunicação com os titulares seja clara, consistente e acessível.

[POLÍTICA DE SEGURANÇA DA INFORMAÇÃO E DADOS PESSOAIS.pdf](#)

7.4.2 - Limite de tratamento

Preocupação

Em auditoria, foi constatado que a empresa não mapeou os dados pessoais nem elaborou o ROPA.

PP 04: Sem o referido mapeamento, a organização não tem clareza sobre quais dados são tratados, por quem, com que finalidade e por quanto tempo, o que impossibilita assegurar o princípio da minimização de dados. Esse cenário representa um risco significativo de tratamento excessivo ou inadequado de dados pessoais, comprometendo tanto a conformidade com a norma quanto com legislações como a LGPD. Ademais, em caso de incidentes ou fiscalizações, a empresa pode não conseguir demonstrar controle sobre os dados que coleta e processa, o que pode levar a sanções administrativas, danos reputacionais e prejuízos à confiança dos titulares.

7.4.3 - Precisão e qualidade

Preocupação

Em que pese a organização ter uma política de privacidade e controle de acessos, não há uma política de governança de dados nem procedimentos claros para corrigir dados pessoais imprecisos ou desatualizados quando identificados.

PP 05: Sem diretrizes bem definidas, a organização pode falhar na manutenção da exatidão, completude e atualização dos dados pessoais, comprometendo a qualidade do tratamento de dados e aumentando a possibilidade de decisões baseadas em informações incorretas, podendo gerar impactos tanto para os titulares, que podem sofrer prejuízos devido a informações erradas, quanto para a própria organização, que pode enfrentar sanções regulatórias por não garantir a precisão dos dados tratados. Ademais, a ausência de um processo estruturado para identificar e corrigir inconsistências pode dificultar a resposta a solicitações de retificação feitas pelos titulares, conforme previsto na LGPD (Art. 18, III). A falta de mecanismos automatizados ou procedimentos manuais claros para revisar e corrigir dados pode resultar em falhas operacionais, dificultando a rastreabilidade das ações corretivas.

7.4.4 - Objetivos de minimização de DP

Preocupação

O tema é tratado no Procedimento de Exclusão Segura de Informações:

Além da exclusão das informações em casos específicos podem ser adotados pela Always on técnicas de mascaramento das informações seguindo os princípios de Anonimização, Minimização e da anonimização das informações sensíveis e dados pessoais:

Anonimização: O objetivo da anonimização é basicamente garantir a segurança e a privacidade de uma pessoa, desvinculando os dados pessoais do seu titular. Em outras palavras, a anonimização garante que o titular não seja identificado pelos dados pessoais.

Minimização: O objetivo da minimização é basicamente garantir que somente os dados pessoais necessários para operação são utilizados nos processos internos ou externos da organização.

Pseudo-anonimização: O objetivo da pseudo-anonimização é basicamente garantir que os dados dos titulares quando necessário sejam anonimizados de forma reversível para garantir a privacidade dos dados pessoais durante a operação.

Todavia, a política de privacidade não menciona o tema e a organização não elaborou um inventário dos processos que envolvem dados pessoais (ROPA).

PP 06: Em que pese o Procedimento de Exclusão Segura de Informações mencione técnicas como anonimização, minimização e pseudonimização, não há uma abordagem detalhada sobre como esses métodos são aplicados de forma sistemática nos processos da organização. Também, a ausência de um inventário de processos que envolvem dados pessoais (ROPA) compromete a rastreabilidade e a efetividade das práticas de minimização, dificultando auditorias e avaliações de conformidade regulatória. Outro ponto crítico é que a política de privacidade da organização não menciona a minimização de dados, o que pode levar a uma falta de transparência com os titulares de dados e partes interessadas. A minimização é um

princípio fundamental da privacidade e deve estar explicitamente documentada para garantir que apenas os dados estritamente necessários para os processos sejam coletados e tratados. Para mitigar esses riscos, a organização deve revisar e atualizar a política de privacidade, além de desenvolver um ROPA.

[PROCEDIMENTO DE EXCLUSÃO SEGURA DE INFORMAÇÕES.pdf](#)

7.4.5 - Anonimização e exclusão de DP ao final do tratamento

Conforme

O tema é tratado no Procedimento de Exclusão Segura de Informações:

3. PROCEDIMENTO

Para evitar a exposição desnecessária de informações sensíveis é definido pela (Always on) e devem ser analisados regularmente, sejam eles mantidos eletronicamente ou em papel, para serem eliminados, os dados podem ser eliminados nas seguintes ocasiões:

- Quando não houver mais a necessidade de manter as informações salvas
- Quando houver o acordo com partes externas na exclusão das informações após término de contrato
- Definição técnica e estratégica da empresa para redução de custo no armazenamento de informações

Além da exclusão das informações em casos específicos podem ser adotados pela Always on técnicas de mascaramento das informações seguindo os princípios de Anonimização, Minimização e da anonimização das informações sensíveis e dados pessoais:

Anonimização: O objetivo da anonimização é basicamente garantir a segurança e a privacidade de uma pessoa, desvinculando os dados pessoais do seu titular. Em outras palavras, a anonimização garante que o titular não seja identificado pelos dados pessoais.

Minimização: O objetivo da minimização é basicamente garantir que somente os dados pessoais necessários para operação são utilizados nos processos internos ou externos da organização.

Pseudo-anonimização: O objetivo da pseudo-anonimização é basicamente garantir que os dados dos titulares quando necessário sejam anonimizados de forma reversível para garantir a privacidade dos dados pessoais durante a operação.

Ainda, nos servidores, é utilizada a técnica DBAN - Darik's Boot and Nuke.

[PROCEDIMENTO DE EXCLUSÃO SEGURA DE INFORMAÇÕES.pdf](#)

7.4.6 - Arquivos temporários

Conforme

O tema é tratado no Procedimento de Tratamento de Dados Pessoais:

2. PROCEDIMENTO

2.1 ARQUIVOS TEMPORÁRIOS

Os arquivos temporários que são criados devido ao tratamento de dados são excluídos diariamente.

Para verificar se o sistema de exclusão está funcionando corretamente são realizadas verificações diariamente. Caso a verificação identifique não exclusão no período determinado é aberta uma não conformidade e tratada no plano de ação adequado para garantir operação de exclusão de forma contínua na organização.

São aplicados procedimentos de reciclagem (garbage collection) para garantir a varredura adequada dos arquivos temporários e sua exclusão.

Durante a auditoria, foi verificada a máquina (DEADPOOL40) do colaborador Alexandre da Rocha.

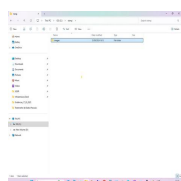


Foto 22

[PROCEDIMENTO DE TRATAMENTO DE DADOS PESSOAIS.pdf](#)

7.4.7 - Retenção

Preocupação

O tema é tratado no Mapa de DP e em cláusulas contratuais.

PP 07: No Mapa de DP quase todos os dados estão com o prazo de retenção de 5 anos. É fundamental verificar se todos os prazos estão atualizados e corretos. Utilizar uma tabela de temporalidade é de suma importância quando se fala em retenção e descarte de dados pessoais. Ainda, é importante realizar auditorias internas e revisões periódicas, verificando se o tratamento de dados segue os princípios da minimização, bem como treinar colaboradores e terceiros, garantindo que todos compreendam os limites do tratamento de dados.

7.4.8 - Descarte

Conforme

O tema é tratado no Procedimento de Descarte de Dados Pessoais:

3. 1 PROCEDIMENTO DE DESCARTE

A escolha da técnica de descarte do dado pessoal deve ser realizada de maneira que não seja possível a restauração da informação.

Local que está contido o Dado Pessoal

Servidores virtuais Seguros, com acesso restrito a pastas às pessoas autorizadas e com redundância e Backup diariamente.

Técnica de descarte

Métodos de Exclusão Segura, Eraser e BleachBit, Criptografia Antes da Exclusão, para dados digitais e após tempo de retenção conforme (Gestão de Ativos-(aba) Mapa de DP conforme lei LGPD

Para alguns papéis assinados não digitais, são armazenados com o RH (% muito pequena) É utilizado triturador de alta segurança (nível P-4, recomendado pela norma DIN 66399), que fragmentam os papéis em pedaços pequenos.

[PROCEDIMENTO DE DESCARTE DE DADOS PESSOAIS.pdf](#)

7.4.9 - Controle de transmissão de DP

Oportunidade de Melhoria

O tema é tratado no Procedimento de Tratamento de Dados Pessoais:

2.3 CONTROLE DE TRANSMISSÃO DE DP

Toda transmissão de dados pessoais realizada seguem as medidas de segurança em redes internas e externas descrita no PR Infraestrutura de TI - 2.

De forma adicional, o cliente é informado contratualmente sobre as transmissões necessárias na operação.

Há a realização de backup e gerenciamento de vulnerabilidades.

OM 01: Para fortalecer esse controle, recomenda-se que a organização inclua no Procedimento de Tratamento de DP uma descrição mais clara das medidas aplicadas à transmissão de dados pessoais, especificando os protocolos, ferramentas de segurança e procedimentos de monitoramento ativos. Embora a organização informe contratualmente os clientes sobre a transmissão de dados, não há menção à validação contínua dessas transmissões para garantir que os dados cheguem corretamente ao destino pretendido, sem alterações ou interceptações não autorizadas. A implementação de um sistema de logs de auditoria específico para transmissões de DP e a realização de testes periódicos de segurança na rede ajudariam a garantir que os controles aplicados são eficazes e que eventuais vulnerabilidades possam ser detectadas e corrigidas de maneira proativa.

[PROCEDIMENTO DE TRATAMENTO DE DADOS PESSOAIS.pdf](#)

7.5 Compartilhamento, transferência e divulgação de DP

7.5.1 - Identificando as bases para a transferência de DP entre jurisdições

Não Conforme

O tema é tratado no Procedimento de Tratamento de Dados Pessoais, contudo, não foi elaborado um ROPA nem identificadas bases legais.

Foi verificado, em auditoria, que a única transferência internacional existente é com relação a utilização de

servidores Google, que ficam fora do país, mas a ALWAYS ON não sabe dizer em quais países se encontram os referidos servidores.

NC Menor 05: A organização não elaborou um ROPA (Registro de Operações de Processamento de Dados) e não identificou as bases legais para a transferência internacional de dados. O controle exige que a organização identifique e documente as bases relevantes para a transferência de dados pessoais entre jurisdições, e a ausência dessas informações demonstra uma falha na conformidade.

[PROCEDIMENTO DE TRATAMENTO DE DADOS PESSOAIS.pdf](#)

7.5.2 - Países e organizações internacionais para os quais os DP podem ser transferidos

Não Conforme

O tema é tratado no Procedimento de Tratamento de Dados Pessoais, contudo, não foi elaborado um ROPA nem identificadas bases legais.

Foi verificado, em auditoria, que a única transferência internacional existente é com relação a utilização de servidores Google, que ficam fora do país, mas a ALWAYS ON não sabe dizer em quais países se encontram os referidos servidores.

NC Menor 06: O fato de a organização não saber informar em quais países os servidores do Google estão localizados compromete a transparência e dificulta a comprovação da conformidade com regulamentos com esta norma e com a LGPD, por exemplo, que exige que os titulares sejam informados sobre a localização de seus dados. Em complemento, a falta de bases legais identificadas para a transferência internacional de dados também reforça a não conformidade, pois a empresa precisa demonstrar que sua operação está amparada por um fundamento jurídico adequado.

[PROCEDIMENTO DE TRATAMENTO DE DADOS PESSOAIS.pdf](#)

7.5.3 - Registros de transferência de DP

Preocupação

O tema é tratado no Mapa de DP (que precisa ser ajustado) e no Procedimento de Tratamento de Dados Pessoais:

2.4 COMPARTILHAMENTO, TRANSFERÊNCIA E DIVULGAÇÃO DE DP

Todo compartilhamento, transferência ou divulgação de dado pessoal, é determinado em contrato com o cliente. Quando há necessidade de mudança para tal atividade, o cliente é consultado antes da realização da transferência e essa só ocorre com aprovação do cliente.

Quando os dados pessoais podem ser transferidos para outros países também é informado em contrato e obedecendo as legislações do país de origem e destino e garantindo o atendimento à Lei Geral de Proteção de Dados do Brasil.

No entanto a organização não realizou mapeamento de dados pessoais nem elaborou o ROPA.

PP 08: Embora a organização trate o tema no Mapa de DP (que precisa ser ajustado) e no Procedimento de Tratamento de Dados Pessoais, a falta de um mapeamento estruturado pode comprometer a rastreabilidade das transferências de dados pessoais, dificultando a conformidade com requisitos regulatórios. Sem um ROPA devidamente documentado, a empresa não tem um registro claro das operações de tratamento e compartilhamento, o que pode afetar sua capacidade de responder a solicitações de titulares e sua governança de privacidade. Em complemento, mesmo havendo cláusulas contratuais que abordam o compartilhamento e a transferência internacional de dados, não há um processo documentado que garanta a rastreabilidade e a comprovação das transferências realizadas. A ausência desse registro pode gerar riscos de descumprimento de obrigações contratuais, bem como dificuldades em auditorias e no atendimento a eventuais investigações regulatórias. É imprescindível a implementação de um ROPA, a fim de cumprir a norma, bem como o que estabelece a LGPD.

[PROCEDIMENTO DE TRATAMENTO DE DADOS PESSOAIS.pdf](#)

7.5.4 - Registro de divulgação de DP para terceiros

Oportunidade de Melhoria

O tema é tratado no Procedimento de Tratamento de Dados Pessoais:

2.5 REGISTRO DE DADOS DIVULGADOS PARA TERCEIROS

A divulgação de DP é descrita no contrato com o cliente e esse é informado quando ocorrer uma solicitação legalmente obrigatória, desde que não seja solicitado sigilo por lei.

OM 02: É essencial definir um procedimento formal de registro, a fim de garantir que qualquer transferência de DP para terceiros seja documentada, podendo utilizar planilhas, sistemas de gestão ou softwares de governança para rastrear todas as divulgações. Ainda, é recomendável detalhar o compartilhamento de dados, incluindo qual tipo de dado, para quem foi enviado, quando foi enviado, qual a finalidade da divulgação, quem é o responsável pela divulgação e qual a base legal utilizada. Também, é importante implementar controles de acesso para que apenas pessoas autorizadas possam visualizar ou modificar os registros de divulgação.

[PROCEDIMENTO DE TRATAMENTO DE DADOS PESSOAIS.pdf](#)

Fotos

8 Diretrizes adicionais da ABNT NBR ISO/IEC 27002 para os operadores de DP

8.2 - Condições para coleta e tratamento

8.2.1 - Acordos com o cliente

Conforme

Evidenciado por meio de cláusulas contratuais, sobre privacidade e proteção de dados nos contratos com os clientes.

[CW254386-Manifesto \(1\).pdf](#)

8.2.2 - Propósitos da organização

Preocupação

Os propósitos ficam evidenciados nos contratos contendo cláusulas específicas de privacidade e proteção de dados pessoais, mas é importante salientar que não foi realizado mapeamento de dados pessoais nem elaborado o ROPA.

PP 01: É fundamental que o ROPA seja realizado com base em todos os processos dentro da organização que tratem dados pessoais. Esse documento deve abranger todos os processos da empresa que envolvam dados pessoais, pois cada operação (como coleta, armazenamento, compartilhamento ou exclusão) pode gerar riscos diferentes à privacidade dos titulares. A ausência de um registro abrangente pode resultar em lacunas no gerenciamento de riscos, dificultando a demonstração de conformidade em auditorias ou fiscalizações pela Autoridade Nacional de Proteção de Dados (ANPD). Ademais, o registro com base em todos os processos facilita a identificação de vulnerabilidades e ajustes necessários para atender aos princípios da LGPD, como minimização de dados e segurança. Por exemplo, em uma loja virtual, o registro pode identificar que dados coletados no cadastro de clientes estão sendo armazenados por um período maior do que o necessário, expondo a empresa a riscos desnecessários. O registro também é fundamental para documentar a base legal do tratamento de dados em cada processo, servindo não apenas para cumprir a legislação, mas também como ferramenta de gestão para proteger a privacidade dos titulares e mitigar os riscos de sanções administrativas.

8.2.3 - Uso de marketing e propaganda

Preocupação

Em que pese a área de Marketing realizar tratamentos de dados pessoais baseados em consentimento, não há um procedimento que trate especificamente sobre como o consentimento é coletado e como é feita a gestão dos consentimentos. O consentimento é coletado, por exemplo, quando alguém se interessa por algum conteúdo ou serviço da empresa e preenche o formulário que consta no site da ALWAYS ON. Ainda, foi verificado que há a utilização de termos de consentimento de forma errônea, quando a base legal para o tratamento de dados pessoais deveria ser outra.

PP 02: Embora a organização utilize uma base de consentimento para suas campanhas de tráfego pago e trabalhe com prestadores de serviço, a falta de um sistema estruturado para monitorar, atualizar e revogar consentimentos representa um risco significativo de não conformidade com a ISO 27701/2019 e a LGPD. Sem um gerenciamento eficaz, não há como garantir que os titulares tenham controle contínuo sobre seus dados ou que as campanhas de marketing estejam sendo direcionadas apenas a pessoas que deram

consentimento válido e atual. Ademais, a falta de rastreabilidade dos consentimentos pode comprometer a capacidade da organização de responder a auditorias, solicitações de titulares para exclusão de seus dados ou questionamentos de autoridades regulatórias. Caso um titular de DP solicite a revogação do consentimento, a empresa pode não conseguir comprovar quando e como esse consentimento foi obtido e atualizado, o que pode resultar em reclamações, sanções e danos à reputação da organização. Para mitigar esse risco, é essencial implementar um sistema automatizado de gerenciamento de consentimentos, garantindo que todas as interações de marketing respeitem as preferências dos titulares e que seja possível demonstrar conformidade em caso de auditorias ou fiscalizações.

8.2.4 - Violando instruções

Conforme

Evidenciado através da Política de Privacidade, da Política de Segurança da Informação e Privacidade e do Procedimento de Tratamento de Dados Pessoais.

[PSI.pdf](#)

[POLÍTICA DE SEGURANÇA DA INFORMAÇÃO E DADOS PESSOAIS.pdf](#)

[PROCEDIMENTO DE TRATAMENTO DE DADOS PESSOAIS.pdf](#)

8.2.5 - Obrigações do cliente

Conforme

A organização demonstrou seu compromisso com este requisito por meio de contratos estabelecidos com clientes, incluindo cláusulas referentes à privacidade e proteção de dados pessoais.

[CW254386-Manifesto \(1\).pdf](#)

[019-22-B - ALWAYS ON DIGITAL LTDA v1.pdf](#)

8.2.6 - Registros relativos ao tratamento de DP

Preocupação

Foi apresentado, em entrevista, um documento nomeado "Manifestação de Dados Pessoais", mostrando registro de alguns dados, mas o documentos não está completo, e com alguns campos não assinalados.

PP 03: É fundamental que o ROPA seja realizado com base em todos os processos dentro da organização que envolvam dados pessoais. Esse documento deve abranger todos os processos da empresa que tratem dados pessoais, pois cada operação (como coleta, armazenamento, compartilhamento ou exclusão) pode gerar riscos diferentes à privacidade dos titulares. A ausência de um registro abrangente pode resultar em lacunas no gerenciamento de riscos, dificultando a demonstração de conformidade em auditorias ou fiscalizações pela Autoridade Nacional de Proteção de Dados (ANPD). Ademais, o registro com base em todos os processos facilita a identificação de vulnerabilidades e ajustes necessários para atender o que estabelece a norma ISO e aos princípios da LGPD, como minimização de dados e segurança. O registro também é fundamental para documentar a base legal do tratamento de dados pessoais em cada processo, servindo não apenas para cumprir a norma e a legislação, mas também como ferramenta de gestão para proteger a privacidade dos titulares e mitigar os riscos de sanções administrativas.

8.3 - Obrigações para os titulares de DP

8.3.1 - Obrigações para os titulares de DP

Não Conforme

NC Menor 01: A política de privacidade verificada no site da empresa (<https://aodigital.com.br/o-que-e-politica-de-privacidade/>), na data de 12/03/2025, não menciona os direitos dos titulares nem um canal para atendimentos dos seus direitos, conforme prints anexos. Além de não ter um Encarregado pelo Tratamento de Dados pessoais nomeado, a empresa não tem um procedimento nem um fluxo para atendimento às demandas dos titulares. Em auditoria, foi verificado que a empresa não criou processos e estruturas que permitam o atendimento aos titulares.

8.4 - Privacy by design e privacy by default

8.4.1 - Arquivos temporários

Conforme

O tema é tratado no Procedimento de Tratamento de Dados Pessoais:

2. PROCEDIMENTO

2.1 ARQUIVOS TEMPORÁRIOS

Os arquivos temporários que são criados devido ao tratamento de dados são excluídos diariamente. Para verificar se o sistema de exclusão está funcionando corretamente são realizadas verificações diariamente. Caso a verificação identifique não exclusão no período determinado é aberta uma não conformidade e tratada no plano de ação adequado para garantir operação de exclusão de forma contínua na organização.

São aplicados procedimentos de reciclagem (garbage collection) para garantir a varredura adequada dos arquivos temporários e sua exclusão.

Durante a auditoria, foi verificada a máquina (DEADPOOL40) do colaborador Alexandre da Rocha.

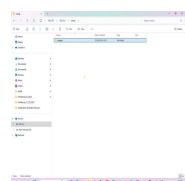


Foto 23

[PROCEDIMENTO DE TRATAMENTO DE DADOS PESSOAIS.pdf](#)

8.4.2 - Retorno, transferência ou descarte de DP

Oportunidade de Melhoria

O tema é tratado no Procedimento de Tratamento de Dados Pessoais:

2.2 RETORNO, TRANSFERÊNCIA OU DESCARTE DE DADOS PESSOAIS (DP)

Quando o cliente solicita retorno, transferência ou existe a necessidade de descarte. Tal situação é realizada de acordo com o fluxo de informação apresentado no documento Gestão de Ativos.

O período de descarte de cada mídia é realizado de acordo com o mapa de dados pessoais descrito no documento Gestão de Ativos.

O cliente é informado de acordo com a Política de Privacidade de Dados Pessoais e medidas de segurança são implementadas para garantir a proteção de dados do cliente.

São utilizados Criptografia de Dados, Controles de Acesso, Registro e Monitoramento de Atividades (Log), Firewall e Sistemas de Detecção e Prevenção de Intrusões (IDS/IPS), Gestão de Vulnerabilidades e Atualizações de Segurança, Política de Backup e Recuperação de Desastres, Treinamento e Conscientização de Segurança, Acordos de Confidencialidade e Políticas Internas de Privacidade.

OM 01: Uma melhoria seria incluir um processo claro de requisição e confirmação de descarte, bem como auditorias regulares para garantir que a remoção dos dados foi realizada corretamente e que não há armazenamento residual em backups. Adicionar diretrizes específicas sobre políticas de retenção de dados, controles de acesso pós-contrato e a necessidade de garantir que cópias de segurança sejam devidamente apagadas quando não forem mais necessárias ajudaria a elevar o nível de conformidade com a ISO 27701/2019.

[PROCEDIMENTO DE TRATAMENTO DE DADOS PESSOAIS.pdf](#)

8.4.3 - Controles de transmissão de DP

Oportunidade de Melhoria

O tema é tratado no Procedimento de Tratamento de Dados Pessoais:

2.3 CONTROLE DE TRANSMISSÃO DE DP

Toda transmissão de dados pessoais realizada seguem as medidas de segurança em redes internas e externas descrita no PR Infraestrutura de TI - 2.

De forma adicional, o cliente é informado contratualmente sobre as transmissões necessárias na operação.

Há a realização de backup e gerenciamento de vulnerabilidades.

OM 02: Para fortalecer esse controle, recomenda-se que a organização inclua no Procedimento de Tratamento de DP uma descrição mais clara das medidas aplicadas à transmissão de dados pessoais, especificando os protocolos, ferramentas de segurança e procedimentos de monitoramento ativos. Embora a organização informe contratualmente os clientes sobre a transmissão de dados, não há menção à validação contínua dessas transmissões para garantir que os dados cheguem corretamente ao destino pretendido, sem alterações ou interceptações não autorizadas. A implementação de um sistema de logs de

auditoria específico para transmissões de DP e a realização de testes periódicos de segurança na rede ajudariam a garantir que os controles aplicados são eficazes e que eventuais vulnerabilidades possam ser detectadas e corrigidas de maneira proativa.

[PROCEDIMENTO DE TRATAMENTO DE DADOS PESSOAIS.pdf](#)

8.5 - Compartilhamento, transferência e divulgação de DP

8.5.1 - Bases para a transferência de DP entre jurisdições

Não Conforme

NC Menor 02: A organização não elaborou um ROPA (Registro de Operações de Processamento de Dados) e não identificou as bases legais para a transferência internacional de dados. O controle exige que a organização identifique e documente as bases relevantes para a transferência de dados pessoais entre jurisdições, e a ausência dessas informações demonstra uma falha na conformidade.

8.5.2 - Países e organizações internacionais para os quais DP podem ser transferidos

Não Conforme

NC Menor 03: O fato de a organização não sabe informar em quais países os servidores do Google estão localizados compromete a transparência e dificulta a comprovação da conformidade com regulamentos com esta norma e com a LGPD, por exemplo, que exige que os titulares sejam informados sobre a localização de seus dados. Em complemento, a falta de bases legais identificadas para a transferência internacional de dados também reforça a não conformidade, pois a empresa precisa demonstrar que sua operação está amparada por um fundamento jurídico adequado.

8.5.3 - Registros de DP divulgados para terceiros

Oportunidade de Melhoria

O tema é tratado no Procedimento de Tratamento de Dados Pessoais:

2.5 REGISTRO DE DADOS DIVULGADOS PARA TERCEIROS

A divulgação de DP é descrita no contrato com o cliente e esse é informado quando ocorrer uma solicitação legalmente obrigatória, desde que não seja solicitado sigilo por lei.

OM 03: É essencial definir um procedimento formal de registro, a fim de garantir que qualquer transferência de DP para terceiros seja documentada, podendo utilizar planilhas, sistemas de gestão ou softwares de governança para rastrear todas as divulgações. Ainda, é recomendável detalhar o compartilhamento de dados, incluindo qual tipo de dado, para quem foi enviado, quando foi enviado, qual a finalidade da divulgação, quem é o responsável pela divulgação e qual a base legal utilizada. Também, é importante implementar controles de acesso para que apenas pessoas autorizadas possam visualizar ou modificar os registros de divulgação.

[PROCEDIMENTO DE TRATAMENTO DE DADOS PESSOAIS.pdf](#)

8.5.4 - Notificação de solicitações de divulgação de DP

Não Conforme

O tema é tratado no Procedimento para o Tratamento de Dados Pessoais:

2.5 REGISTRO DE DADOS DIVULGADOS PARA TERCEIROS

A divulgação de DP é descrita no contrato com o cliente e esse é informado quando ocorrer uma solicitação legalmente obrigatória, desde que não seja solicitado sigilo por lei.

NC Menor 04: Em que pese o que consta no referido procedimento, durante a auditoria não foi localizada cláusula contratual que garantisse notificação sobre solicitações legalmente obrigatórias para a divulgação de dados pessoais.

[PROCEDIMENTO DE TRATAMENTO DE DADOS PESSOAIS.pdf](#)

8.5.5 - Divulgações legalmente obrigatórias de DP

Preocupação

Ainda que o tema seja tratado no Procedimento de Tratamento de Dados Pessoais, as divulgações legalmente obrigatórias de DP não são citadas.

PP 04: Sem uma diretriz clara sobre como lidar com solicitações de órgãos governamentais, autoridades judiciais ou outras entidades com base legal, a organização pode acabar divulgando dados sem o devido controle ou, inversamente, recusando divulgações obrigatórias, resultando em não conformidade legal e possíveis penalidades. Também, a falta de procedimentos formais pode gerar inconsistências operacionais, levando a decisões arbitrárias ou à ausência de registro adequado dessas solicitações. Outro ponto crítico é a necessidade de consultar o cliente antes de qualquer divulgação não obrigatória e de garantir que somente solicitações autorizadas sejam atendidas. Sem um procedimento detalhado, a empresa corre o risco de não realizar essa consulta ou de não registrar adequadamente a decisão do cliente, dificultando auditorias e investigações futuras. Para mitigar esse problema, o Procedimento de Tratamento de Dados Pessoais deve ser atualizado para incluir diretrizes claras sobre como identificar, documentar e processar solicitações legais de divulgação de DP, assegurando que apenas pedidos legítimos sejam atendidos e que haja transparência e rastreabilidade em todas as operações de compartilhamento de dados.

[PROCEDIMENTO DE TRATAMENTO DE DADOS PESSOAIS.pdf](#)

8.5.6 - Divulgação de subcontratados usados para tratar DP

Preocupação

O tema não é tratado no Procedimento de Tratamento de Dados Pessoais nem em nenhum outro documento da organização.

Em auditoria, foi o mostrado o contrato nº 4400079541, do cliente Santander, com a seguinte cláusula: "A Contratada não poderá subcontratar quaisquer Serviços, sem a prévia e expressa autorização do Contratante. Em caso de subcontratação, a Contratada deverá: (i) utilizar somente profissionais contratados de acordo com a CLT – Consolidação das Leis do Trabalho; (ii) ser solidária e individualmente responsável perante o Contratante por todas as ações das subcontratadas, incluindo o cumprimento da legislação aplicável e deste Contrato; (iii) não utilizar ou subcontratar cooperativa de mão-de-obra e/ ou pessoa(s) jurídica(s), que se enquadre(m) na(s) categoria(s) de empresários individuais e/ou empresas individuais de responsabilidade limitada". Ainda, o referido contrato tem cláusulas que tratam sobre proteção de dados e SI.

Ocorre que não há menção sobre a divulgação de subcontratados nem sobre mudanças nos contratos de subcontratação.

PP 05: O fato de o tema em tela não estar tratado no Procedimento de Tratamento de Dados Pessoais nem em nenhum outro documento da organização demonstra ausência de governança e controle na gestão de subcontratados, podendo gerar riscos operacionais e jurídicos, pois não há garantia de que os clientes sejam devidamente informados sobre quais terceiros terão acesso ou tratarão dados pessoais. A ausência desse controle também pode comprometer a conformidade com a LGPD, por exemplo, que exige transparência no tratamento de dados. Ademais, embora tenha sido apresentado um contrato com o cliente Santander que restringe a subcontratação sem prévia autorização, não há nenhuma menção sobre a obrigatoriedade de divulgação desses subcontratados aos clientes nem sobre como eventuais mudanças contratuais serão comunicadas, o que pode ocasionar insegurança jurídica e risco de descumprimento contratual, caso a empresa utilize subcontratados sem um processo estruturado de comunicação e aprovação formal.

[CW254386-Manifesto.pdf](#)

8.5.7 - Contratação de um subcontratado para tratar DP

Oportunidade de Melhoria

O tema não é tratado no Procedimento de Tratamento de Dados Pessoais nem em nenhum outro documento da organização.

Em auditoria, foi o mostrado o contrato nº 4400079541, do cliente Santander, com a seguinte cláusula: "A Contratada não poderá subcontratar quaisquer Serviços, sem a prévia e expressa autorização do Contratante. Em caso de subcontratação, a Contratada deverá: (i) utilizar somente profissionais contratados de acordo com a CLT – Consolidação das Leis do Trabalho; (ii) ser solidária e individualmente responsável perante o Contratante por todas as ações das subcontratadas, incluindo o cumprimento da legislação aplicável e deste Contrato; (iii) não utilizar ou subcontratar cooperativa de mão-de-obra e/ ou pessoa(s) jurídica(s), que se enquadre(m) na(s) categoria(s) de empresários individuais e/ou empresas individuais de responsabilidade limitada". Ainda, o referido contrato tem cláusulas que tratam sobre proteção de dados e SI.

OM 04: É fundamental incluir no Procedimento de Tratamento de Dados Pessoais um processo específico para a contratação de subcontratados, definindo critérios claros para a avaliação, aprovação e

monitoramento desses terceiros. Esse procedimento deve prever a necessidade de autorização prévia dos clientes antes de qualquer subcontratação, assegurando que todas as exigências contratuais e regulatórias sejam cumpridas. Em complemento, a organização pode criar um registro centralizado de subcontratados, onde constem todas as autorizações dos clientes, cláusulas específicas dos contratos e os compromissos assumidos pelos terceiros em relação à segurança da informação e privacidade, o que permitiria um melhor acompanhamento das obrigações contratuais e facilitaria auditorias futuras.

[CW254386-Manifesto.pdf](#)

8.5.8 - Mudança de subcontratado para tratar DP

Preocupação

O tema não é tratado no Procedimento de Tratamento de Dados Pessoais nem em nenhum outro documento da organização.

Em auditoria, foi o mostrado o contrato nº 4400079541, do cliente Santander, com a seguinte cláusula: "A Contratada não poderá subcontratar quaisquer Serviços, sem a prévia e expressa autorização do Contratante. Em caso de subcontratação, a Contratada deverá: (i) utilizar somente profissionais contratados de acordo com a CLT – Consolidação das Leis do Trabalho; (ii) ser solidária e individualmente responsável perante o Contratante por todas as ações das subcontratadas, incluindo o cumprimento da legislação aplicável e deste Contrato; (iii) não utilizar ou subcontratar cooperativa de mão-de-obra e/ ou pessoa(s) jurídica(s), que se enquadre(m) na(s) categoria(s) de empresários individuais e/ou empresas individuais de responsabilidade limitada". Ainda, o referido contrato tem cláusulas que tratam sobre proteção de dados e SI.

Ocorre que não há menção sobre a divulgação de subcontratados nem sobre mudanças nos contratos de subcontratação.

PP 06: Os pontos de preocupação identificados estão relacionados à ausência de um processo formal para comunicação de mudanças nos subcontratados que tratam dados pessoais. Embora o contrato com o cliente Santander estabeleça que qualquer subcontratação exige autorização prévia, não há evidências de um mecanismo documentado que regulamente como essa autorização deve ser obtida e registrada, tampouco há diretrizes sobre a comunicação prévia de alterações nos subcontratados. A falta dessa regulamentação pode levar a falhas na transparência e no cumprimento dos requisitos contratuais, além de comprometer a conformidade com normas de privacidade e segurança da informação. Outro ponto crítico é que, apesar de o contrato conter cláusulas sobre proteção de dados e segurança da informação, não há menção específica sobre a necessidade de informar o cliente sobre mudanças de subcontratados e permitir que ele se oponha, podendo gerar riscos regulatórios, especialmente em auditorias ou em casos de incidentes de segurança e violações de dados pessoais, pois a organização não tem evidências concretas de que a substituição de subcontratados foi devidamente comunicada e aprovada. Para mitigar esses riscos, a organização deve estabelecer um processo formal de comunicação dessas mudanças, garantindo que os clientes tenham tempo hábil para avaliar e aprovar ou rejeitar qualquer nova subcontratação antes que ela ocorra.

[CW254386-Manifesto.pdf](#)

Fotos

Anexo A - Controladores de DP

A.7.2 - Requisitos para coleta e tratamento

A.7.2.1 - A organização identificou e documentou os propósitos essenciais referente ao tratamento do DP?	Não Conforme
A.7.2.2 - A organização está em compliance com os requisitos legais pertinentes para o tratamento dos DP?	Não Conforme
A.7.2.3 - A organização possui processos, pelo qual demonstra quando e como o foi obtido o consentimento titular de DP?	Não Conforme
A.7.2.4 - A organização possui documentado, consentimento de titulares referente ao tratamento dos DP?	Preocupação
A.7.2.5 - A organização possui Análises de impacto e de privacidade estabelecida ?	Preocupação
A.7.2.6 - A organização possui contratos com os operadores de DP estabelecido?	Conforme
A.7.2.7 - A organização possui documentos em que define as responsabilidades e papéis ao tratamento de DP com os Controladores conjunto de DP?	Não Aplicável
A.7.2.8 - A organização possui registros fundamentais mantidos de forma segura?	Preocupação

A.7.3 Deveres para os titulares de DP

A.7.3.1 -A organização determinou e documentou as responsabilidades e obrigações legais aos titulares de DP?	Não Conforme
A.7.3.2 - A organização possui documentada as informações em que fornece ao titular dos DP?	Não Conforme
A.7.3.3 - A organização fornece para os seus titulares de DP, informações claras e precisas para que possam identificar o Controlador e os	Não Conforme

tratamentos a serem feitos com os DP coletados ?	
A.7.3.4 - Fornecendo mecanismo para modificar ou cancelar o consentimento	Não Conforme
A.7.3.5 - A organização fornece para seus titulares, meios para que possam cancelar o consentimento fornecido?	Não Conforme
A.7.3.6 - A organização possui meios para que o u titular de DP possa acessar/modificar/eliminar as informações obtidas?	Não Conforme
A.7.3.7 - A organização force aos seu terceiros, informações sobre com quem os DP foram compartilhados e modificações como cancelamentos ?	Não Conforme
A.7.3.8 - A organização fornece a seus titulares, cópias dos dados coletas quando solicitado por eles ?	Não Conforme
A.7.3.9 - A organização possui políticas para o tratamento legítimo dos titulares de DP estabelecido?	Não Conforme
A.7.3.10 - A organização identificou e considerou as obrigações legais dos titulares de dados, para respostas e tratamentos automatizados ?	Não Aplicável
A.7.4 Privacy by design e Privacy by Default	
A.7.4.1 - A organização possui limites para coleta estabelecido?	Não Conforme
A.7.4.2 - A organização possui limites para tratamento de DP estabelecido?	Preocupação
A.7.4.3 - A organização possui documentos em que assegura que os DP coletados são essenciais para tais propósitos ?	Preocupação
A.7.4.4 - A organização possui formas de minimização dos DP, e quais os meios usados para que possa atender tais objetivos?	Preocupação
A.7.4.5 -A organização possui meios de eliminação dos DP de forma que , não sejam identificados ?	Conforme
A.7.4.6 - A organização assegura que os arquivos	Conforme

armazenados temporariamente são eliminados em um determinado período em específico?	
A.7.4.7 - A organização assegura que os DP coletados, são retidos somente a tempo necessário para o tratamento realizado ?	Preocupação
A.7.4.8 - A organização possui diretrizes para o descarte dos DP?	Conforme
A.7.4.9 - Controladores de transmissão de DP	Oportunidade de Melhoria
A.7.5 Compartilhamento, transferência e divulgação de DP	
A.7.5.1 - A organização possui controles para se certificar de que as transferências de DP estão seguras?	Não Conforme
A.7.5.2 - A organização possui documentos especificando a quais países e organizações internacionais os DP são possivelmente transferidos ?	Não Conforme
A.7.5.3 - A organização possui registros de transferência de DP para terceiros, e assegurar sobre futuras obrigações para os titulares de DP?	Preocupação
A.7.5.4 - A organização possui documentos de divulgações de DP a terceiros, especificando para onde, quem e quando foi transmitido ?	Oportunidade de Melhoria
Fotos	

Anexo B - Operadores de DP

B.8.2 Requisitos para coleta e tratamento

B.8.2.1 - A organização possui documentos em que asseguram sobre os reais objetivos e papéis da organização e obrigações do cliente em relações aos DP?	Conforme
B.8.2.2 - A organização assegura que os DP coletados, são tratados somente para os propósitos citados ao contrato com o cliente ?	Preocupação
B.8.2.3 - A organização assegura que os DP coletados não serão cedidos para outras finalidades como marketing e propaganda?	Preocupação
B.8.2.4 - A organização possui meios para comunicar o titular do DP em casos de violações a legislação ?	Conforme
B.8.2.5 - A organização fornece a seus clientes, informações adequadas de modo que, o cliente demonstre conformidades com seus deveres?	Conforme

B.8.3 Deveres para os titulares de DP

B.8.3.1 - A organização fornece aos seus titulares, meios para estarem em conformidade com os requisitos específicos ?	Não Conforme
---	--------------

B.8.4 Privacy by design e Privacy by Default

B.8.4.1 - A organização garante que os arquivos temporários, são guardados somente por tempo específico a realização do tratamento dos DP?	Conforme
B.8.4.2 - A organização assegura que os DP são retornados/transferidos e excluídos de forma segura ?	Oportunidade de Melhoria
B.8.4.3 - A organização possui meios de transferências seguros ?	Oportunidade de Melhoria

B.8.5 Compartilhamento, transferência e descarte de DP

B.8.5.1 - A organização informa ao seu cliente sobre as bases de transferência entre jurisdições e/ou qualquer mudança periódica, de modo que, o cliente tenha o livre direito em contestar ou cancelar o contrato?	Não Conforme
B.8.5.2 - A organização possui documentos em que	Não Conforme

especifiquem em que países e organizações podem ocorrer possíveis transferência de DP?	
B.8.5.3 - A organização possui registros de divulgações de DP a terceiros?	Oportunidade de Melhoria
B.8.5.4 - A organização notifica seu cliente sobre possíveis pedidos obrigatórios a divulgação de seus DP?	Não Conforme
B.8.5.5 - A organização consulta seu cliente antes de fornecer quaisquer divulgação sobre os seus DP?	Preocupação
B.8.5.6 - A organização notifica o seu cliente sobre a divulgação dos seus DP para subcontratados?	Preocupação
B.8.5.7 - Contratação de um subcontratado para tratar DP	Oportunidade de Melhoria
B.8.5.8 - A organização fornece ao cliente autorizações para informar sobre quaisquer alteração relativas a substituição do subcontratado?	Preocupação
Fotos	

Resumo de mídia

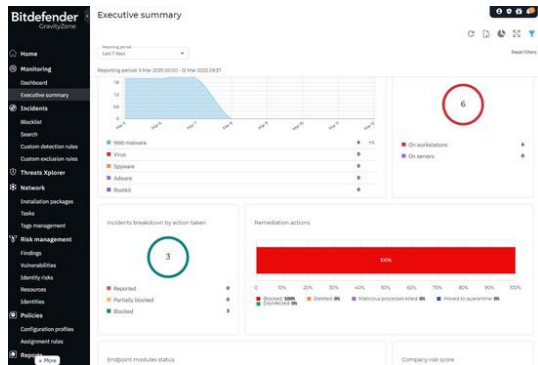


Foto 1

[illegible]

Foto 2

GGP

Cadastro de Funcionário

Home / Funcionários / Cadastro de Funcionário / ALFONSO DE OLIVEIRA DA SILVA JUNIOR

Novos Cadastros | **Existentes**

Novos Cadastros | **Existentes** | **Quais Funcionários** | **Filtros** | **Documentos** | **Relatório** | **Dependentes** | **Atualizar**

Chapa

Número Folha

Admissão

Data de Encalche

CPF

Nome

Racão/Cidade

Sexo

Racão/Cidade

Qualificação

Estado Civil

Estado Atual

Nat/Cidade

Assinatura

ENDEREÇO

E-mail

Atas

Foto 3

[illegible]

Foto 4

The screenshot displays the LinkedIn profile of Eduardo De Zorzi. The profile is for a 'Marketing Specialist' at 'Melo Digital'. The timeline shows a post from 15/04/2023. The interface is in Portuguese. The profile picture is a circular headshot of a man with dark hair. The name 'Eduardo De Zorzi' is prominently displayed. Below the name, the current position 'Marketing Specialist' and company 'Melo Digital' are listed. The timeline shows a post from 15/04/2023. The interface is in Portuguese.

Foto 5

Foto 6

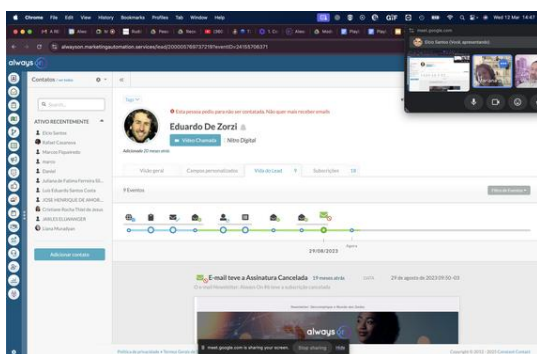


Foto 7

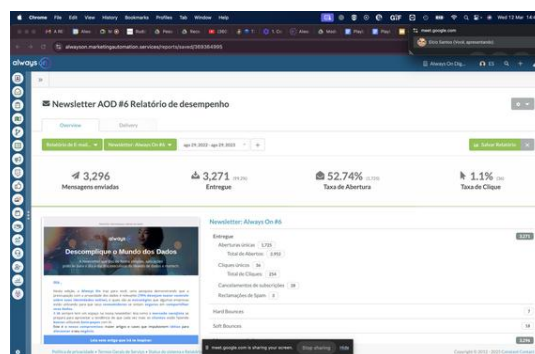


Foto 8

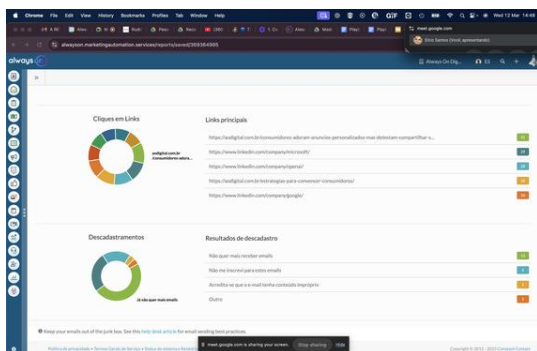


Foto 9

Modificações

Porém, a Always ON pode revisar estes termos de **serviço do site a qualquer momento**, sem aviso prévio.

Ao usar este site, você concorda em ficar vinculado à versão atual desses termos de serviço.

Lei aplicável

Estes termos e condições são regidos e interpretados de acordo com as leis do **Always ON** e você se submete irrevogavelmente à jurisdição exclusiva dos tribunais naquele estado ou localidade.

#Compliance Legal #Direitos de Privacidade #Política de Privacidade Explained #Privacidade do Usuário #Privacidade Online #Proteção de Dados Pessoais #Segurança de Informações #Transparência de Informações #Uso de Dados

Foto 10

2. Além disso, o Always ON não garante ou faz qualquer representação relativa à precisão, aos resultados prováveis ou à confiabilidade do uso dos materiais em seu site ou de outra forma relacionado a esses materiais ou em sites vinculados a este site.

4. Limitações

Em nenhum caso o Always ON ou seus fornecedores serão responsáveis por quaisquer danos.

Incluindo, sem limitação, danos por perda de dados ou lucro ou devido a interrupção dos negócios, decorrentes do uso ou da incapacidade de usar os materiais em Always ON.

Como algumas jurisdições não permitem limitações em garantias implícitas, ou limitações de responsabilidade por danos consequentes ou incidentais, essas limitações podem não se aplicar a você.

Foto 12

Precisão dos materiais

Os materiais exibidos no site da Always ON podem incluir erros técnicos, tipográficos ou fotográficos. Always ON não garante que qualquer material em seu site seja preciso, completo ou atual.

Always ON pode fazer alterações nos materiais contidos em seu site a qualquer momento, sem aviso prévio.

No entanto, Always ON não se compromete a atualizar os materiais.

6. Links

A inclusão de qualquer link não implica endosso por Always ON do site.

O uso de qualquer site vinculado é por conta e risco do usuário.

Foto 11

1. modificar ou copiar os materiais;
2. usar os materiais para qualquer finalidade comercial ou para exibição pública (comercial ou não comercial);
3. tentar descompilar ou fazer engenharia reversa de qualquer software contido no site Always ON;
4. remover quaisquer direitos autorais ou outras notações de propriedade dos materiais; ou
5. transferir os materiais para outra pessoa ou 'espelhar' os materiais em qualquer outro servidor.

3. Isenção de responsabilidade

1. Always ON não oferece garantias, expressas ou implícitas, e, por este meio, isenta e nega todas as outras garantias, incluindo, sem limitação, garantias implícitas ou condições de comercialização, adequação a um fim específico ou não violação de propriedade intelectual ou outra violação de direitos.

Foto 13

1. Termos

Ao acessar o site Always ON, concorda em cumprir estes termos de serviço, todas as leis e regulamentos aplicáveis e concorda que é responsável pelo cumprimento de todas as leis locais aplicáveis.

Se você não concordar com algum desses termos, está proibido de usar ou acessar este site.

2. Uso de Licença

O site Always ON concede permissão para que você baixe temporariamente uma cópia dos materiais (informações ou software), apenas para visualização transitória pessoal e não comercial.

Esta é a concessão de uma licença, não uma transferência de título e, sob esta licença, você não pode:

Foto 14

- Periodicamente, testamos novos recursos e fazemos alterações subtis na maneira como o site se apresenta.

À medida que vendemos produtos, é importante entendermos as estatísticas sobre quantos visitantes de nosso site realmente compram e, portanto, esse é o tipo de dados que esses cookies rastrearão. Isso é importante para você, pois significa que podemos fazer previsões de negócios com precisão que nos permitem analisar nossos custos de publicidade e produtos para garantir o melhor preço possível.

Mais informações

Esperamos ter esclarecido.

Esta política é efetiva a partir de Agosto/2020.

Foto 15

- Cookies relacionados a boletins por e-mail: Este site oferece serviços de assinatura de boletim informativo ou e-mail e os cookies podem ser usados para lembrar se você já está registrado e se deve mostrar determinadas notificações válidas apenas para usuários inscritos / não inscritos.
- Pedidos processando cookies relacionados: Este site oferece facilidades de comércio eletrônico ou pagamento e alguns cookies são essenciais para garantir que seu pedido seja lembrado entre as páginas, para que possamos processá-lo adequadamente.
- Cookies relacionados a pesquisas: Periodicamente, oferecemos pesquisas e questionários para fornecer informações interessantes, ferramentas úteis ou para entender nossa base de usuários com mais precisão. Essas pesquisas podem usar cookies para lembrar quem já participou numa pesquisa ou para fornecer resultados precisos após a alteração das páginas.

Foto 17

Política de Cookies Always ON

O que são cookies?

Como é prática comum em quase todos os sites profissionais, este site usa cookies, que são pequenos arquivos baixados no seu computador, para melhorar sua experiência. Esta página descreve quais informações eles coletam, como as usamos e por que às vezes precisamos armazenar esses cookies. Também compartilharemos como você pode impedir que esses cookies sejam armazenados, no entanto, isso pode fazer o *downgrade* ou 'quebrar' certos elementos da funcionalidade do site.

Como usamos os cookies?

Utilizamos cookies por vários motivos, detalhados abaixo. Infelizmente, na maioria dos casos, não existem opções padrão do setor para desativar os cookies sem desativar completamente a funcionalidade e os recursos que eles adicionam a este site.

Foto 19



The screenshot shows the homepage of the 'Always ON' website. The navigation bar includes links for Home, Por que Always ON, Como trabalha, O que faz, and Parceiros. The main heading is 'Política Privacidade'. The text explains that privacy is important and that the site respects user privacy by only collecting necessary information. It mentions that cookies are used for various purposes, including improving the user experience and analyzing site usage. The text is in Portuguese.

Foto 21

Cookies de Terceiros

Em alguns casos especiais, também usamos cookies fornecidos por terceiros confiáveis. A seção a seguir detalha quais cookies de terceiros você pode encontrar através deste site.

- Este site usa o Google Analytics, que é uma das soluções de análise mais difundidas e confiáveis da Web, para nos ajudar a entender como você usa o site e como podemos melhorar sua experiência. Esses cookies podem rastrear itens como quanto tempo você gasta no site e as páginas visitadas, para que possamos continuar produzindo conteúdo atraente.

Para mais informações sobre cookies do Google Analytics, consulte a página oficial do Google Analytics.

- Esses cookies podem rastrear itens como o tempo que você passa no site ou as páginas visitadas, o que nos ajuda a entender como podemos melhorar o site para você.

Foto 16

Desativar cookies

Você pode impedir a configuração de cookies ajustando as configurações do seu navegador (consulte a Ajuda do navegador para saber como fazer isso). Esteja ciente de que a desativação de cookies afetará a funcionalidade deste e de muitos outros sites que você visita. A desativação de cookies geralmente resultará na desativação de determinadas funcionalidades e recursos deste site. Portanto, é recomendável que você não desative os cookies.

Cookies que definimos

- Cookies relacionados à conta: Se você criar uma conta conosco, usaremos cookies para o gerenciamento do processo de inscrição e administração geral.
- Cookies relacionados ao login: Utilizamos cookies quando você está logado, para que possamos lembrar dessa ação. Isso evita que você precise fazer login sempre que visitar uma nova página.

Foto 18

O nosso site pode ter links para sites externos que não são operados por nós. Esteja ciente de que não temos controle sobre o conteúdo e práticas desses sites e não podemos aceitar responsabilidade por suas respectivas políticas de privacidade.

Você é livre para recusar a nossa solicitação de informações pessoais, entendendo que talvez não possamos fornecer alguns dos serviços desejados.

O uso continuado de nosso site será considerado como aceitação de nossas práticas em torno de privacidade e informações pessoais. Se você tiver alguma dúvida sobre como lidamos com dados do usuário e informações pessoais, entre em contacto conosco.

Foto 20

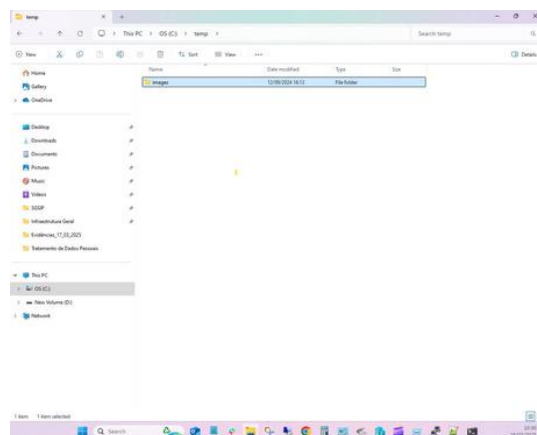


Foto 22

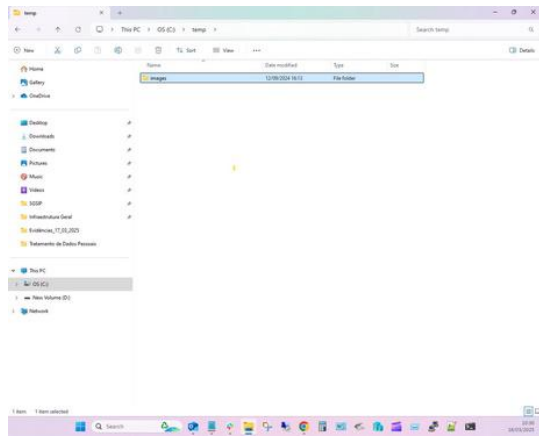


Foto 23

File summary

[PROCEDIMENTO DE CODIFICAÇÃO SEGURA.pdf](#)
[RIPD.pdf](#)
[CW254386-Manifesto \(1\).pdf](#)
[POLÍTICA DE SEGURANÇA DA INFORMAÇÃO E DADOS PESSOAIS.pdf](#)
[PROCEDIMENTO DE EXCLUSÃO SEGURA DE INFORMAÇÕES.pdf](#)
[PROCEDIMENTO DE EXCLUSÃO SEGURA DE INFORMAÇÕES.pdf](#)
[PROCEDIMENTO DE TRATAMENTO DE DADOS PESSOAIS.pdf](#)
[PROCEDIMENTO DE DESCARTE DE DADOS PESSOAIS.pdf](#)
[PROCEDIMENTO DE TRATAMENTO DE DADOS PESSOAIS.pdf](#)
[PROCEDIMENTO DE TRATAMENTO DE DADOS PESSOAIS.pdf](#)
[PROCEDIMENTO DE TRATAMENTO DE DADOS PESSOAIS.pdf](#)
[PROCEDIMENTO DE TRATAMENTO DE DADOS PESSOAIS.pdf](#)
[PROCEDIMENTO DE TRATAMENTO DE DADOS PESSOAIS.pdf](#)
[CW254386-Manifesto \(1\).pdf](#)
[PSI.pdf](#)
[POLÍTICA DE SEGURANÇA DA INFORMAÇÃO E DADOS PESSOAIS.pdf](#)
[PROCEDIMENTO DE TRATAMENTO DE DADOS PESSOAIS.pdf](#)
[CW254386-Manifesto \(1\).pdf](#)
[019-22-B - ALWAYS ON DIGITAL LTDA v1.pdf](#)
[PROCEDIMENTO DE TRATAMENTO DE DADOS PESSOAIS.pdf](#)
[PROCEDIMENTO DE TRATAMENTO DE DADOS PESSOAIS.pdf](#)
[PROCEDIMENTO DE TRATAMENTO DE DADOS PESSOAIS.pdf](#)
[PROCEDIMENTO DE TRATAMENTO DE DADOS PESSOAIS.pdf](#)
[PROCEDIMENTO DE TRATAMENTO DE DADOS PESSOAIS.pdf](#)
[CW254386-Manifesto.pdf](#)
[CW254386-Manifesto.pdf](#)
[CW254386-Manifesto.pdf](#)